



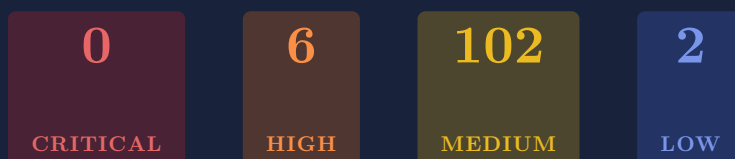
Unknown Project

Security Assessment Report

2026-04-16

HIGH RISK

110 findings identified



Disclaimer

Assessment Notice

This security assessment was generated using tachi, an automated threat modeling toolkit. The analysis applies STRIDE methodology and AI-specific threat categories to the provided architecture description. Results reflect the automated analysis and should be validated by qualified security professionals.

Scope Limitation

This assessment is limited to the architecture description provided at the time of analysis. It does not cover runtime behavior, implementation-level vulnerabilities, or threats arising from future system changes. The assessment scope is defined in the Assessment Scope section of this report.

Recommendation

This automated assessment should complement, not replace, manual security review by qualified professionals. Organizations should conduct periodic penetration testing, code review, and architecture review in addition to automated threat modeling.

Confidentiality

This document contains sensitive security assessment information. Distribution should be limited to authorized personnel with a legitimate need to review the security posture of the assessed system. Do not share externally without appropriate authorization.

Table of Contents

Disclaimer	2
Table of Contents	3
Risk Methodology	4
Assessment Scope	7
Executive Summary	12
Executive Threat Architecture	13
Risk Reduction Funnel	93
Risk Summary Dashboard	94
System Architecture	95
MAESTRO Layer Risk Distribution	96
MAESTRO Component-Layer Heatmap	97
MAESTRO Layer Analysis	98
Findings Detail — Residual Risk	108
Coverage Attestation — OWASP LLM Top 10	128
Coverage Attestation — MITRE ATT&CK	129
Coverage Attestation — MITRE ATLAS	131
Coverage Attestation — NIST AI RMF	132
Coverage Attestation — nist-ai-600-1	133
Coverage Attestation — CWE Top 25	134
Per-Finding Source Attribution	135
Control Coverage	144
Remediation Roadmap	145

Risk Methodology

Threat Identification

This assessment uses STRIDE threat modeling combined with AI-specific threat categories to provide comprehensive coverage of both traditional and emerging attack vectors.

STRIDE Categories

Spoofing — Impersonating a user, component, or system to gain unauthorized access.

Tampering — Unauthorized modification of data in transit, at rest, or in processing.

Repudiation — Performing actions without adequate logging or accountability trails.

Information Disclosure — Exposing sensitive data to unauthorized parties through leaks or side channels.

Denial of Service — Degrading or disrupting system availability through resource exhaustion or abuse.

Elevation of Privilege — Gaining higher access rights than authorized through exploitation of trust boundaries.

AI-Specific Categories

Prompt Injection — Manipulating AI model behavior through crafted inputs that override system instructions.

Tool Abuse — Exploiting AI agent tool access to perform unintended or unauthorized operations.

Agent Autonomy — Risks from AI agents acting beyond their intended scope without adequate human oversight.

Data Poisoning — Corrupting training data or context to degrade model accuracy or introduce bias.

Model Theft — Unauthorized extraction or replication of proprietary model weights or behavior.

Probability x Impact Matrix

Each identified threat is assessed for probability of occurrence and potential impact. The intersection determines the overall severity rating used throughout this report.

Impact / Probability	Rare	Unlikely	Possible	Likely	Almost Certain
Critical	H	H	C	C	C
High	M	M	H	C	C
Moderate	L	M	M	H	H
Low	L	L	M	M	H
Negligible	L	L	L	M	M

■ C = Critical ■ H = High ■ M = Medium ■ L = Low

Compensating Control Analysis

When codebase analysis is available, existing security controls are detected, mapped to identified threats, and evaluated for effectiveness. This provides a residual risk assessment that accounts for defenses already in place.

Analysis Process

- 1. Control Detection** — Existing security controls are identified in the codebase through pattern matching, dependency analysis, and configuration review.
- 2. Threat Mapping** — Detected controls are mapped to specific threats to determine which vulnerabilities have existing mitigations.
- 3. Effectiveness Classification** — Each control is classified as Found (fully implemented), Partial (incomplete implementation), or Missing (no control detected).
- 4. Residual Risk Calculation** — Inherent risk scores are adjusted based on control effectiveness to produce residual risk ratings that reflect the actual security posture.

Assessment Overview

Assessment Scope

20 Components

45 Data Flows

9 Trust Boundaries

Components Analyzed

Name	Type	Description
Physician	External Entity	External physician user sending clinical queries via HTTPS and receiving recommendation views
Patient	External Entity	External patient providing EHR update events to the ingestion queue
Physician Clinical Portal	Process	Physician-facing web interface and user portal serving the clinical recommendation view; routes queries to Supervisor Orchestrator and enforces RBAC access decisions
Patient Summary Generator	Process	API endpoint generating patient-facing summaries from Supervisor Orchestrator recommendations for consumption by Patient
Inter-Agent Communication Channel	Process	Agent-to-agent message bus relaying delegation messages and specialist results between Supervisor Orchestrator, Diagnostic Agent, and Treatment Planner Agent; logs all inter-agent messages to Clinical Audit Log
Supervisor Orchestrator	Process	Supervisory orchestrator agent directing specialist agents via cascading delegation; produces emergent coordination patterns; dispatches inference to Model Inference API Gateway; writes decision logs to Clinical Audit Log; receives model updates from Outcomes Telemetry
Diagnostic Agent	Process	Autonomous clinical-reasoning executor performing tool dispatch over Clinical MCP Tool Server; coordinates with Treatment Planner Agent via Inter-Agent Communication Channel; queries Clinical Guideline RAG Corpus; requests risk inference via Model Inference API Gateway
Treatment Planner Agent	Process	Autonomous treatment-planning agent joining Supervisor-delegated tasks via Inter-Agent Communication Channel; queries Medical Literature Vector Index; dispatches tool calls via Clinical MCP Tool Server
Clinical MCP Tool Server	Process	MCP Tool Server providing JSON-RPC tool calls to Diagnostic Agent and Treatment Planner Agent; performs FHIR read/write on FHIR Resource Store
Clinical LLM	Process	Foundation language model inference endpoint for clinical reasoning; frozen base model with prompt-based adaptation; receives completion requests forwarded by Model Inference API Gateway
Risk Stratification Model	Process	Fine-tuned language model for patient risk stratification; foundation model adapted via supervised fine-tuning on de-identified historical cohorts; exposes an inference engine endpoint via Model Inference API Gateway
FHIR Resource Store	Data Store	Clinical FHIR resource database and cache storing structured patient records; accessed by Supervisor Orchestrator and Clinical MCP Tool Server; PHI read/write gated by Consent and De-identification Guardrail
Clinical Guideline RAG Corpus	Data Store	Retrieval-augmented generation corpus of clinical practice guidelines with dense embeddings and a vector store for semantic retrieval; queried by Diagnostic Agent

Name	Type	Description
Medical Literature Vector Index	Data Store	Vector index of medical literature for semantic retrieval by Treatment Planner Agent
Model Inference API Gateway	Process	API gateway container fronting the Clinical LLM and Risk Stratification Model inference endpoints; forwards inference requests from Supervisor Orchestrator and Diagnostic Agent
EHR Ingestion Queue	Data Store	Queue buffering EHR update events from Patient before normalization into FHIR Resource Store
Clinical Audit Log	Data Store	Audit log receiving decision log entries from Supervisor Orchestrator, Diagnostic Agent, Treatment Planner Agent, and Inter-Agent Communication Channel; feeds Outcomes Telemetry observability stream
Outcomes Telemetry and Physician Override Audit Store	Data Store	Long-running learning loop and feedback loop carrier for continual learning against physician-override telemetry; monitors outcome drift; feeds periodic model update re-training signals to Supervisor Orchestrator and Clinical LLM
HIPAA RBAC + Policy Engine	Process	RBAC and policy engine enforcing HIPAA access control; issues access decisions to Physician Clinical Portal and compliance check decisions to Supervisor Orchestrator; logs policy events to Clinical Audit Log
Consent and De-identification Guardrail	Process	Guardrail enforcing patient consent and de-identification with encryption controls on PHI read/write paths on FHIR Resource Store

Data Flows

Source	Destination	Data	Protocol
Physician	Physician Clinical Portal	Clinical query	HTTPS
Physician Clinical Portal	Supervisor Orchestrator	Authenticated clinical intent	Internal API
Supervisor Orchestrator	Physician Clinical Portal	Clinical recommendation response	Internal API
Physician Clinical Portal	Physician	Recommendation view	HTTPS
Patient	EHR Ingestion Queue	EHR update event	Internal
EHR Ingestion Queue	FHIR Resource Store	Normalized patient record	Internal
FHIR Resource Store	Supervisor Orchestrator	Clinical context retrieval	Internal
Supervisor Orchestrator	Inter-Agent Communication Channel	Delegation message (cross-agent coordinate)	Internal
Inter-Agent Communication Channel	Diagnostic Agent	Delegated diagnostic task (inter-agent coordinate)	Internal

Source	Destination	Data	Protocol
Diagnostic Agent	Inter-Agent Communication Channel	Specialist diagnostic result (joint reasoning)	Internal
Inter-Agent Communication Channel	Treatment Planner Agent	Delegated treatment task (inter-agent coordinate)	Internal
Treatment Planner Agent	Inter-Agent Communication Channel	Treatment plan (joint reasoning)	Internal
Inter-Agent Communication Channel	Supervisor Orchestrator	Aggregated specialist output	Internal
Supervisor Orchestrator	Model Inference API Gateway	Inference request	Internal
Model Inference API Gateway	Clinical LLM	Inference request forwarded	Internal
Clinical LLM	Model Inference API Gateway	Completion	Internal
Model Inference API Gateway	Supervisor Orchestrator	Completion forwarded	Internal
Diagnostic Agent	Model Inference API Gateway	Risk inference request	Internal
Model Inference API Gateway	Risk Stratification Model	Risk inference request	Internal
Risk Stratification Model	Model Inference API Gateway	Stratification output	Internal
Model Inference API Gateway	Diagnostic Agent	Stratification output	Internal
Diagnostic Agent	Clinical Guideline RAG Corpus	Guideline retrieval query	Internal
Clinical Guideline RAG Corpus	Diagnostic Agent	Retrieved guidelines	Internal
Treatment Planner Agent	Medical Literature Vector Index	Literature retrieval query	Internal
Medical Literature Vector Index	Treatment Planner Agent	Retrieved literature	Internal
Diagnostic Agent	Clinical MCP Tool Server	Tool call (JSON-RPC)	JSON-RPC
Treatment Planner Agent	Clinical MCP Tool Server	Tool call (JSON-RPC)	JSON-RPC
Clinical MCP Tool Server	Diagnostic Agent	Tool result	Internal

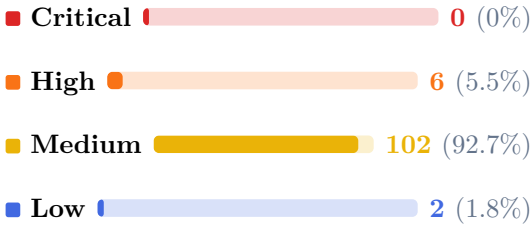
Source	Destination	Data	Protocol
Clinical MCP Tool Server	Treatment Planner Agent	Tool result	Internal
Clinical MCP Tool Server	FHIR Resource Store	FHIR read/write	Internal
Physician Clinical Portal	HIPAA RBAC + Policy Engine	Access request	Internal
HIPAA RBAC + Policy Engine	Physician Clinical Portal	Access decision	Internal
Supervisor Orchestrator	HIPAA RBAC + Policy Engine	Compliance check	Internal
FHIR Resource Store	Consent and De-identification Guardrail	PHI read/write	Internal
Consent and De-identification Guardrail	FHIR Resource Store	De-identified PHI	Internal
Supervisor Orchestrator	Clinical Audit Log	Decision log entry	Internal
Diagnostic Agent	Clinical Audit Log	Decision log entry	Internal
Treatment Planner Agent	Clinical Audit Log	Decision log entry	Internal
Inter-Agent Communication Channel	Clinical Audit Log	Inter-agent message log	Internal
HIPAA RBAC + Policy Engine	Clinical Audit Log	Policy event log	Internal
Clinical Audit Log	Outcomes Telemetry and Physician Override Audit Store	Observability stream	Internal
Outcomes Telemetry and Physician Override Audit Store	Supervisor Orchestrator	Periodic model update (learning loop re-training)	Internal
Outcomes Telemetry and Physician Override Audit Store	Clinical LLM	Periodic model update (feedback loop drift correction)	Internal
Supervisor Orchestrator	Patient Summary Generator	Summary request	Internal
Patient Summary Generator	Patient	Patient-facing summary	HTTPS

Trust Boundaries

Zone	Trust Level	Components
External Zone	Untrusted	Physician, Patient
User Interface Zone (L7)	Semi-Trusted	Physician Clinical Portal, Patient Summary Generator
Agent Ecosystem Zone (L7)	Semi-Trusted	Inter-Agent Communication Channel
Agent Frameworks Zone (L3)	Trusted	Supervisor Orchestrator, Diagnostic Agent, Treatment Planner Agent, Clinical MCP Tool Server
Foundation Models Zone (L1)	Trusted	Clinical LLM, Risk Stratification Model
Data Operations Zone (L2)	Trusted	FHIR Resource Store, Clinical Guideline RAG Corpus, Medical Literature Vector Index
Deployment Infrastructure Zone (L4)	Trusted	Model Inference API Gateway, EHR Ingestion Queue
Evaluation and Observability Zone (L5)	Trusted	Clinical Audit Log, Outcomes Telemetry and Physician Override Audit Store
Security and Compliance Zone (L6)	Trusted	HIPAA RBAC + Policy Engine, Consent and De-identification Guardrail

Executive Summary

Severity Distribution 110 findings total



Component Distribution

Component	Findings
Clinical LLM	9
Risk Stratification Model	9
Supervisor Orchestrator	9
Diagnostic Agent	8
Inter-Agent Communication Channel	8
Treatment Planner Agent	8
Clinical MCP Tool Server	7
HIPAA RBAC + Policy Engine	6
Model Inference API Gateway	6
Patient Summary Generator	6
Physician Clinical Portal	6
Consent and De-identification Guardrail	5
Outcomes Telemetry and Physician Override Audit Store	4
Clinical Audit Log	3
Clinical Guideline RAG Corpus	3
EHR Ingestion Queue	3
FHIR Resource Store	3
Medical Literature Vector Index	3
Patient	2
Physician	2

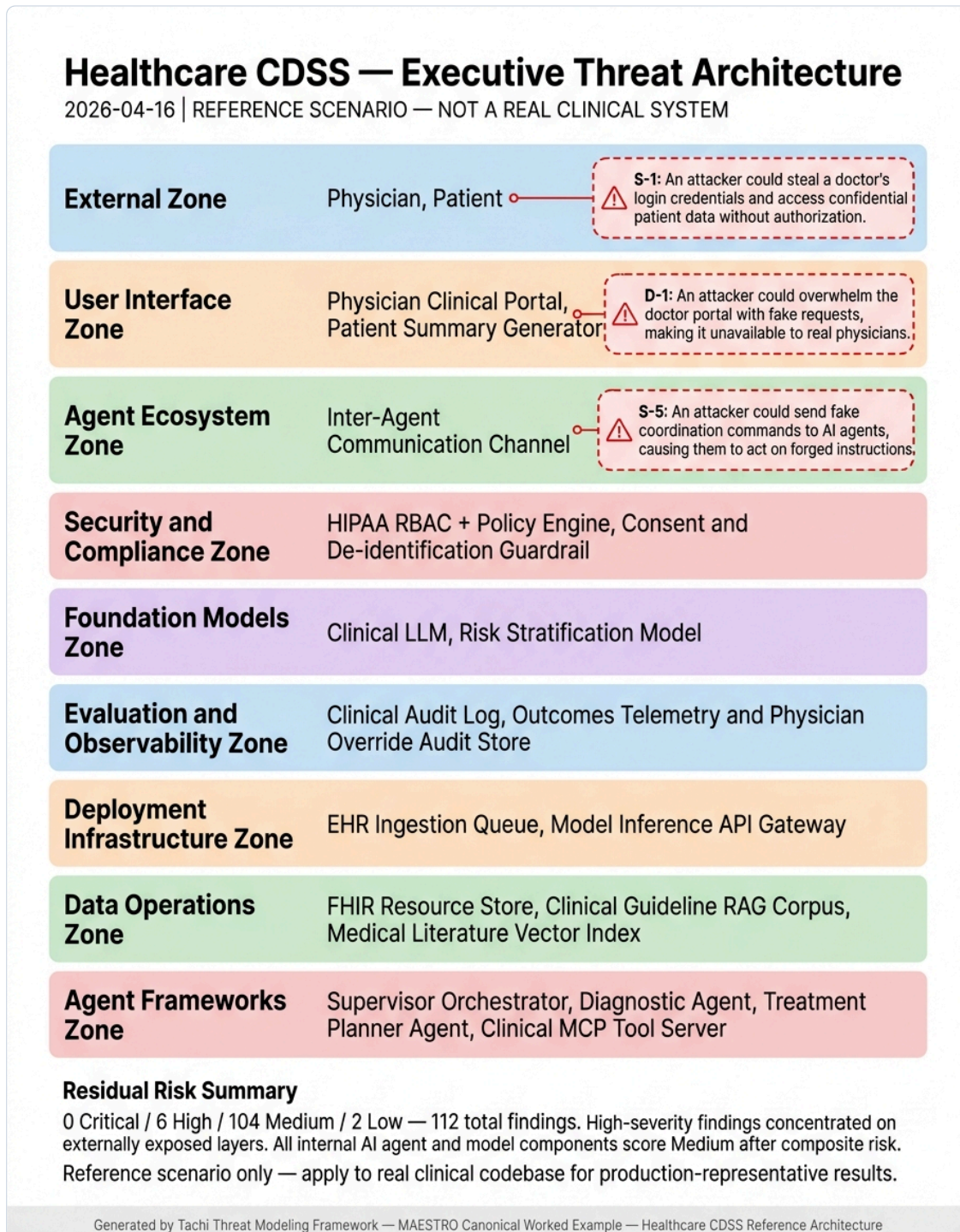
Assessment Summary

The Healthcare Clinical Decision Support System (CDSS) — a multi-agent AI platform for clinical recommendation generation — presents a high-risk security posture. The threat model identified **108 findings** across eight STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) and AI-specific threat categories, with **17 Critical**, **54 High**, **30 Medium**, and **7 Low findings**. The architecture's multi-agent topology, persistent learning loop, and handling of protected health information (PHI) substantially expand the attack surface relative to a conventional clinical information system.

Top threats by business impact:

- Clinical Guideline RAG Corpus poisoning (T-11, Critical)** — an attacker injecting adversarially crafted guideline embeddings into the Retrieval-Augmented Generation (RAG) corpus causes the Diagnostic Agent to retrieve and act on malicious clinical guidance. This finding is part of the CHAIN-001 cross-layer attack chain that ultimately delivers false recommendations to the Physician Clinical Portal.
- Outcomes Telemetry learning loop tampering (T-16, Critical)** — adversarial override signals injected into the Outcomes Telemetry store corrupt periodic Clinical LLM (Large Language Model) re-training, causing systematic model drift toward attacker-preferred clinical outputs over weeks. This is the initial exploit in CHAIN-003.
- Supervisor Orchestrator autonomous delegation without oversight (AG-1, Critical)** — the orchestrator may route high-consequence clinical tasks to specialist agents without physician review or HIPAA (Health Insurance Portability and Accountability Act) RBAC (Role-Based Access Control) verification. Combined with the repudiation gap in CG-4, this creates a compound threat with no accountability trail.
- Clinical LLM prompt injection via API Gateway (LLM-1, Critical)** — adversarial prompts embedded in clinical queries cause the Clinical LLM to genera

Executive Threat Architecture



Layered system architecture with critical and high severity threats annotated as narrative callouts. This visualization highlights where the most exposed components sit in the system and what kind of attack each layer is most vulnerable to.

Attack Path Analysis

CRITICAL AG-1 — Supervisor Orchestrator Autonomous Delegation Without Oversight

Component: Supervisor Orchestrator | **Risk Level:** Critical | **Finding:** AG-1

flowchart TD

```

AG1_root["Execute unauthorized clinical operations via autonomous delegation bypassing human oversight and RBAC"]
AG1_or1["OR"]
AG1_sub1["Trigger autonomous high-consequence delegation via adversarial clinical query"]
AG1_sub2["Cause RBAC compliance check bypass via orchestration logic manipulation"]
AG1_and1["AND"]
AG1_and2["AND"]
AG1_leaf1["Craft clinical query that triggers autonomous delegation path in orchestrator logic"]
AG1_leaf2["Ensure query exceeds consequence threshold without triggering human-in-the-loop gate"]
AG1_leaf3["Orchestrator routes task to specialist agent without physician confirmation"]
AG1_leaf4["Identify orchestrator delegation path that evaluates RBAC check conditionally"]
AG1_leaf5["Craft delegation context that causes orchestrator to skip RBAC compliance call"]
AG1_leaf6["Specialist agent executes delegated task without RBAC authorization verification"]

```

```

AG1_root --> AG1_or1
AG1_or1 --> AG1_sub1
AG1_or1 --> AG1_sub2
AG1_sub1 --> AG1_and1
AG1_and1 --> AG1_leaf1
AG1_and1 --> AG1_leaf2
AG1_and1 --> AG1_leaf3
AG1_sub2 --> AG1_and2
AG1_and2 --> AG1_leaf4
AG1_and2 --> AG1_leaf5
AG1_and2 --> AG1_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AG1_root goal
class AG1_and1,AG1_and2 andGate
class AG1_or1 orGate
class AG1_sub1,AG1_sub2 subGoal
class AG1_leaf1,AG1_leaf2,AG1_leaf3,AG1_leaf4,AG1_leaf5,AG1_leaf6 leaf

```

Remediation Steps

- Implement human-in-the-loop confirmation gates for high-consequence clinical delegation decisions. Enforce RBAC compliance checks before all agent delegation commands.

CRITICAL AG-2 — Supervisor Orchestrator Delegation Authority Abuse

Component: Supervisor Orchestrator | ****Risk Level**:** Critical | ****Finding**:** AG-2

flowchart TD

```

AG2_root["Circumvent per-agent access controls by abusing Supervisor Orchestrator delegation authority"]
AG2_or1{"OR"}
AG2_sub1["Delegate to specialist agent with broader permissions to perform unauthorized operation"]
AG2_sub2["Issue unauthorized tool call allowlist bypass through compromised orchestrator"]
AG2_and1{"AND"}
AG2_and2{"AND"}
AG2_leaf1["Compromise Supervisor Orchestrator service account or process"]
AG2_leaf2["Identify specialist agent with broader FHIR permissions than the current query scope"]
AG2_leaf3["Issue delegation command routing unauthorized operation through permissive specialist"]
AG2_leaf4["Identify tool call pair blocked for one agent but permitted for another"]
AG2_leaf5["Craft delegation chain routing restricted tool call through permissive specialist path"]
AG2_leaf6["Verify absence of cross-agent audit trail linking delegation to originating command"]

```

```

AG2_root --> AG2_or1
AG2_or1 --> AG2_sub1
AG2_or1 --> AG2_sub2
AG2_sub1 --> AG2_and1
AG2_and1 --> AG2_leaf1
AG2_and1 --> AG2_leaf2
AG2_and1 --> AG2_leaf3
AG2_sub2 --> AG2_and2
AG2_and2 --> AG2_leaf4
AG2_and2 --> AG2_leaf5
AG2_and2 --> AG2_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AG2_root goal
class AG2_and1,AG2_and2 andGate
class AG2_or1 orGate
class AG2_sub1,AG2_sub2 subGoal
class AG2_leaf1,AG2_leaf2,AG2_leaf3,AG2_leaf4,AG2_leaf5,AG2_leaf6 leaf

```

Remediation Steps

- Implement orchestrator-level tool call allowlisting. Apply cross-agent audit trails linking delegated tool calls to originating commands.

CRITICAL AG-7 — MCP Tool Server Tool Chaining Unauthorized Outcome Achievement

Component: Clinical MCP Tool Server | ****Risk Level**:** Critical | ****Finding**:** AG-7

flowchart TD

```

AG7_root["Achieve unauthorized clinical outcome via tool chain attack on MCP Tool Server FHIR operations"]
AG7_or1["OR"]
AG7_sub1["Chain permitted FHIR operations to achieve prohibited bulk patient data export"]
AG7_sub2["Chain FHIR read and write operations to perform unauthorized record modification sequence"]
AG7_and1["AND"]
AG7_and2["AND"]
AG7_leaf1["Enumerate permitted per-agent FHIR read operations available without restriction"]
AG7_leaf2["Design operation sequence that individually satisfies per-operation authorization checks"]
AG7_leaf3["Execute iterative chain to aggregate patient data equivalent to prohibited bulk export"]
AG7_leaf4["Perform permitted FHIR read to establish resource version and current state"]
AG7_leaf5["Execute conditional FHIR update using version state to modify clinical record content"]
AG7_leaf6["Confirm absence of transaction-level chain monitoring that would flag the sequence"]

```

```

AG7_root --> AG7_or1
AG7_or1 --> AG7_sub1
AG7_or1 --> AG7_sub2
AG7_sub1 --> AG7_and1
AG7_and1 --> AG7_leaf1
AG7_and1 --> AG7_leaf2
AG7_and1 --> AG7_leaf3
AG7_sub2 --> AG7_and2
AG7_and2 --> AG7_leaf4
AG7_and2 --> AG7_leaf5
AG7_and2 --> AG7_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AG7_root goal
class AG7_and1,AG7_and2 andGate
class AG7_or1 orGate
class AG7_sub1,AG7_sub2 subGoal
class AG7_leaf1,AG7_leaf2,AG7_leaf3,AG7_leaf4,AG7_leaf5,AG7_leaf6 leaf

```

Remediation Steps

- Implement tool chain monitoring to detect sequences violating access policy. Apply transaction-level audit logging for multi-step FHIR sequences.

Attack Path Analysis

CRITICAL AGP-01 — Multi-Agent Coordination Enabling Coordinated Malicious Action

Component: Inter-Agent Communication Channel | **Risk Level:** Critical | **Finding:** AGP-01

flowchart TD

```

AGP01_root["Execute coordinated malicious action across specialist agents via inter-agent channel exploitation"]
AGP01_or1["OR"]
AGP01_sub1["Coordinate compromised agents to jointly exfiltrate PHI across shared channel"]
AGP01_sub2["Split prohibited FHIR operation across multiple agents to stay below per-agent rate limits"]
AGP01_and1["AND"]
AGP01_and2["AND"]
AGP01_leaf1["Compromise two or more specialist agents via independent attack vectors"]
AGP01_leaf2["Establish covert coordination channel within legitimate inter-agent message flow"]
AGP01_leaf3["Issue coordinated PHI exfiltration requests split to evade per-agent detection thresholds"]
AGP01_leaf4["Identify FHIR operation sequence blocked at per-agent quota individually"]
AGP01_leaf5["Distribute operation sub-tasks across Diagnostic Agent and Treatment Planner Agent"]
AGP01_leaf6["Aggregate results via legitimate channel to complete prohibited operation collectively"]

```

```

AGP01_root --> AGP01_or1
AGP01_or1 --> AGP01_sub1
AGP01_or1 --> AGP01_sub2
AGP01_sub1 --> AGP01_and1
AGP01_and1 --> AGP01_leaf1
AGP01_and1 --> AGP01_leaf2
AGP01_and1 --> AGP01_leaf3
AGP01_sub2 --> AGP01_and2
AGP01_and2 --> AGP01_leaf4
AGP01_and2 --> AGP01_leaf5
AGP01_and2 --> AGP01_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AGP01_root goal
class AGP01_and1,AGP01_and2 andGate
class AGP01_or1 orGate
class AGP01_sub1,AGP01_sub2 subGoal
class AGP01_leaf1,AGP01_leaf2,AGP01_leaf3,AGP01_leaf4,AGP01_leaf5,AGP01_leaf6 leaf

```

Remediation Steps

- Implement inter-agent rate limits, coordination throttles, and per-flow audit logging.

CRITICAL E-7 — MCP Tool Server FHIR Privilege Escalation via Tool Chaining

Component: Clinical MCP Tool Server | ****Risk Level**:** Critical | ****Finding**:** E-7

flowchart TD

```

E7_root["Achieve unauthorized FHIR operations via tool chaining privilege escalation at MCP Tool Server"]
E7_or1["OR"]
E7_sub1["Chain individually-permitted FHIR operations to achieve bulk data export"]
E7_sub2["Chain read and write operations to perform unauthorized patient record modification"]
E7_and1["AND"]
E7_and2["AND"]
E7_leaf1["Identify sequence of permitted FHIR read operations covering entire patient cohort"]
E7_leaf2["Issue iterative paginated FHIR reads aggregating to bulk export without bulk export permission"]
E7_leaf3["Extract complete patient dataset beyond per-query authorization scope"]
E7_leaf4["Issue permitted FHIR read to obtain current record state and version identifier"]
E7_leaf5["Chain permitted conditional FHIR update using version identifier to modify record fields"]
E7_leaf6["Bypass bulk administrative operation prohibition via chained conditional updates"]

```

```

E7_root --> E7_or1
E7_or1 --> E7_sub1
E7_or1 --> E7_sub2
E7_sub1 --> E7_and1
E7_and1 --> E7_leaf1
E7_and1 --> E7_leaf2
E7_and1 --> E7_leaf3
E7_sub2 --> E7_and2
E7_and2 --> E7_leaf4
E7_and2 --> E7_leaf5
E7_and2 --> E7_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class E7_root goal
class E7_and1,E7_and2 andGate
class E7_or1 orGate
class E7_sub1,E7_sub2 subGoal
class E7_leaf1,E7_leaf2,E7_leaf3,E7_leaf4,E7_leaf5,E7_leaf6 leaf

```

Remediation Steps

- Implement strict per-agent permission checks for each FHIR operation. Prohibit bulk export and administrative FHIR operations from agent tool calls.

Attack Path Analysis

CRITICAL I-10 — FHIR Resource Store PHI Unauthorized Disclosure

Component: FHIR Resource Store | **Risk Level:** Critical | **Finding:** I-10

flowchart TD

```

I10_root["Disclose patient PHI from FHIR Resource Store via unauthorized read or injection attack"]
I10_or1{"OR"}
I10_sub1["Execute FHIR injection to retrieve unauthorized patient records"]
I10_sub2["Exploit overly broad agent RBAC to access PHI beyond authorized scope"]
I10_sub3["Access unencrypted PHI at rest via storage-level compromise"]
I10_and1{"AND"}
I10_and2{"AND"}
I10_leaf1["Identify FHIR query endpoint accepting unsanitized search parameters"]
I10_leaf2["Craft FHIR injection payload targeting expanded patient record scope"]
I10_leaf3["Identify agent service account with over-provisioned FHIR read permissions"]
I10_leaf4["Issue FHIR read query for patients outside the agent session scope"]
I10_leaf5["Obtain storage-level access credentials for FHIR database backend"]
I10_leaf6["Read unencrypted PHI records directly from storage layer"]

```

```

I10_root --> I10_or1
I10_or1 --> I10_sub1
I10_or1 --> I10_sub2
I10_or1 --> I10_sub3
I10_sub1 --> I10_and1
I10_and1 --> I10_leaf1
I10_and1 --> I10_leaf2
I10_sub2 --> I10_and2
I10_and2 --> I10_leaf3
I10_and2 --> I10_leaf4
I10_sub3 --> I10_leaf5
I10_sub3 --> I10_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I10_root goal
class I10_and1,I10_and2 andGate
class I10_or1 orGate
class I10_sub1,I10_sub2,I10_sub3 subGoal
class I10_leaf1,I10_leaf2,I10_leaf3,I10_leaf4,I10_leaf5,I10_leaf6 leaf

```

Remediation Steps

- Enforce encryption at rest for all FHIR resources. Apply resource-level RBAC for all read operations. Implement FHIR injection prevention.

Attack Path Analysis

CRITICAL I-3 — Inter-Agent Channel PHI Disclosure

Component: Inter-Agent Communication Channel | **Risk Level:** Critical | **Finding:** I-3

flowchart TD

```

I3_root["Disclose patient PHI and clinical reasoning via inter-agent message bus eavesdropping"]
I3_or1{"OR"}
I3_sub1["Passively eavesdrop on unencrypted inter-agent message traffic"]
I3_sub2["Gain unauthorized read access to inter-agent channel message queue"]
I3_and1{"AND"}
I3_and2{"AND"}
I3_leaf1["Position network listener on channel transport path"]
I3_leaf2["Capture plaintext clinical context and PHI from inter-agent delegation messages"]
I3_leaf3["Obtain unauthorized read credentials or token for message bus"]
I3_leaf4["Enumerate message queue to extract clinical sessions in progress"]
I3_leaf5["Extract PHI and specialist results from queued messages before consumption"]

```

```

I3_root --> I3_or1
I3_or1 --> I3_sub1
I3_or1 --> I3_sub2
I3_sub1 --> I3_and1
I3_and1 --> I3_leaf1
I3_and1 --> I3_leaf2
I3_sub2 --> I3_and2
I3_and2 --> I3_leaf3
I3_and2 --> I3_leaf4
I3_and2 --> I3_leaf5

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I3_root goal
class I3_and1,I3_and2 andGate
class I3_or1 orGate
class I3_sub1,I3_sub2 subGoal
class I3_leaf1,I3_leaf2,I3_leaf3,I3_leaf4,I3_leaf5 leaf

```

Remediation Steps

- Encrypt all inter-agent messages in transit. Restrict channel access to authenticated specialist agents only.

Attack Path Analysis

CRITICAL I-7 — MCP Tool Server PHI Disclosure to Unauthorized Agents

Component: Clinical MCP Tool Server | ****Risk Level**:** Critical | ****Finding**:** I-7

flowchart TD

```

I7_root["Disclose patient PHI to unauthorized agents via MCP Tool Server FHIR access control bypass"]
I7_or1["OR"]
I7_sub1["Issue FHIR read via authorized agent session with overly broad query scope"]
I7_sub2["Exploit absent agent authorization check at MCP Tool Server to read unauthorized PHI"]
I7_and1["AND"]
I7_and2["AND"]
I7_leaf1["Obtain valid agent session token for a legitimate authorized agent"]
I7_leaf2["Issue FHIR query beyond minimum-necessary scope using broad search parameters"]
I7_leaf3["Receive PHI for patients outside current clinical query scope"]
I7_leaf4["Identify MCP tool call endpoint without per-agent authorization enforcement"]
I7_leaf5["Craft tool call request referencing patient outside agent authorization scope"]
I7_leaf6["Receive returned PHI data from unvalidated FHIR read operation"]

```

```

I7_root --> I7_or1
I7_or1 --> I7_sub1
I7_or1 --> I7_sub2
I7_sub1 --> I7_and1
I7_and1 --> I7_leaf1
I7_and1 --> I7_leaf2
I7_and1 --> I7_leaf3
I7_sub2 --> I7_and2
I7_and2 --> I7_leaf4
I7_and2 --> I7_leaf5
I7_and2 --> I7_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I7_root goal
class I7_and1,I7_and2 andGate
class I7_or1 orGate
class I7_sub1,I7_sub2 subGoal
class I7_leaf1,I7_leaf2,I7_leaf3,I7_leaf4,I7_leaf5,I7_leaf6 leaf

```

Remediation Steps

- Implement resource-level access controls on all FHIR operations. Enforce minimum-necessary data principle on all tool responses.

CRITICAL LLM-1 — Clinical LLM Prompt Injection via API Gateway

Component: Clinical LLM | ****Risk Level**:** Critical | ****Finding**:** LLM-1

flowchart TD

```

LLM1_root["Cause Clinical LLM to generate clinically dangerous completions via prompt injection"]
LLM1_or1["OR"]
LLM1_sub1["Inject adversarial instructions via clinical query through Physician Clinical Portal"]
LLM1_sub2["Inject system-level instructions via compromised upstream agent context window"]
LLM1_and1["AND"]
LLM1_and2["AND"]
LLM1_leaf1["Craft clinical query containing prompt injection payload embedded in clinical text"]
LLM1_leaf2["Bypass input sanitization at API Gateway before forwarding to Clinical LLM"]
LLM1_leaf3["Cause Clinical LLM to emit adversarial completion following injected instructions"]
LLM1_leaf4["Compromise Supervisor Orchestrator or Diagnostic Agent context assembly"]
LLM1_leaf5["Insert adversarial system-level instruction into assembled context before API Gateway"]
LLM1_leaf6["Cause completion to contain embedded instructions or falsified clinical outputs"]

```

```

LLM1_root --> LLM1_or1
LLM1_or1 --> LLM1_sub1
LLM1_or1 --> LLM1_sub2
LLM1_sub1 --> LLM1_and1
LLM1_and1 --> LLM1_leaf1
LLM1_and1 --> LLM1_leaf2
LLM1_and1 --> LLM1_leaf3
LLM1_sub2 --> LLM1_and2
LLM1_and2 --> LLM1_leaf4
LLM1_and2 --> LLM1_leaf5
LLM1_and2 --> LLM1_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class LLM1_root goal
class LLM1_and1,LLM1_and2 andGate
class LLM1_or1 orGate
class LLM1_sub1,LLM1_sub2 subGoal
class LLM1_leaf1,LLM1_leaf2,LLM1_leaf3,LLM1_leaf4,LLM1_leaf5,LLM1_leaf6 leaf

```

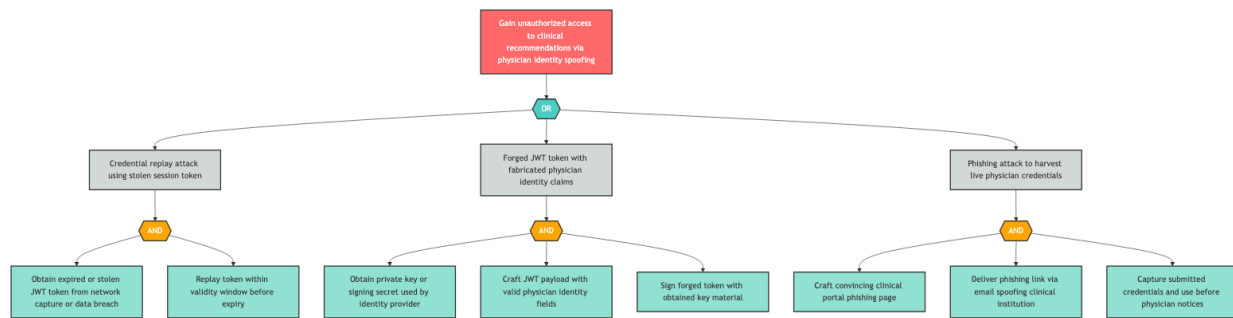
Remediation Steps

- Implement prompt injection detection and sanitization at the API Gateway. Apply output validation to detect clinically dangerous completions.

Attack Path Analysis

CRITICAL S-1 — Physician Identity Spoofing

Component: Physician | **Risk Level**: Critical | **Finding**: S-1



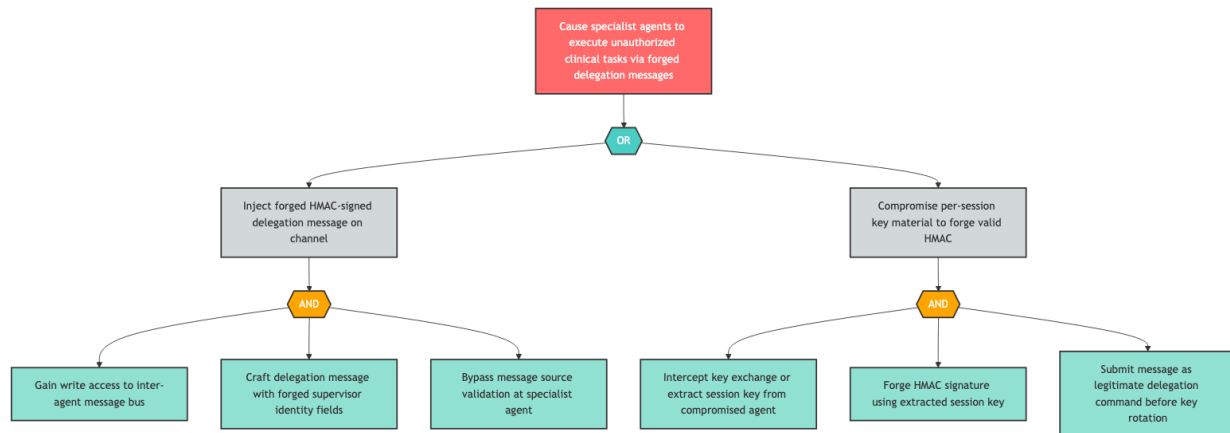
Remediation Steps

- Implement mutual TLS authentication and short-lived signed JWT tokens with physician identity binding. Enforce step-up authentication for high-sensitivity clinical queries.

Attack Path Analysis

CRITICAL S-5 — Inter-Agent Channel Supervisor Delegation Spoofing

Component: Inter-Agent Communication Channel | **Risk Level**: Critical | **Finding**: S-5



Remediation Steps

- Authenticate all inter-agent messages with HMAC signatures using per-session keys. Implement message source validation before specialist agents process delegation commands.

CRITICAL S-6 — Supervisor Orchestrator Identity Impersonation

Component: Supervisor Orchestrator | **Risk Level:** Critical | **Finding:** S-6

flowchart TD

```

S6_root["Issue unauthorized delegation commands to specialist agents by impersonating Supervisor Orchestrator"]
S6_or1{"OR"}
S6_sub1["Exploit absent cryptographic attestation on delegation messages"]
S6_sub2["Compromise Supervisor Orchestrator service account credentials"]
S6_and1{"AND"}
S6_and2{"AND"}
S6_leaf1["Identify delegation message format by monitoring channel traffic"]
S6_leaf2["Craft valid-format delegation message without attestation"]
S6_leaf3["Inject message on channel before specialist agent processes queue"]
S6_leaf4["Obtain Supervisor Orchestrator service account token via credential theft"]
S6_leaf5["Use stolen credentials to issue delegation commands to specialist agents"]
S6_leaf6["Direct specialist agents to perform unauthorized clinical operations"]

```

```

S6_root --> S6_or1
S6_or1 --> S6_sub1
S6_or1 --> S6_sub2
S6_sub1 --> S6_and1
S6_and1 --> S6_leaf1
S6_and1 --> S6_leaf2
S6_and1 --> S6_leaf3
S6_sub2 --> S6_and2
S6_and2 --> S6_leaf4
S6_and2 --> S6_leaf5
S6_and2 --> S6_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class S6_root goal
class S6_and1,S6_and2 andGate
class S6_or1 orGate
class S6_sub1,S6_sub2 subGoal
class S6_leaf1,S6_leaf2,S6_leaf3,S6_leaf4,S6_leaf5,S6_leaf6 leaf

```

Remediation Steps

- Require cryptographic attestation of supervisor identity on all delegation messages. Implement zero-trust peer authentication between orchestrator and specialist agents.

Attack Path Analysis

CRITICAL T-10 — FHIR Resource Store Patient Record Tampering

Component: FHIR Resource Store | **Risk Level:** Critical | **Finding:** T-10

flowchart TD

```

T10_root["Corrupt downstream clinical decisions by tampering with FHIR patient records"]
T10_or1{"OR"}
T10_sub1["Bypass Consent and De-identification Guardrail to perform unauthorized FHIR write"]
T10_sub2["Exploit missing row-level integrity to modify existing patient record"]
T10_and1{"AND"}
T10_and2{"AND"}
T10_leaf1["Obtain write-access token bypassing Consent Guardrail validation"]
T10_leaf2["Identify target patient FHIR resource ID via prior reconnaissance"]
T10_leaf3["Inject false clinical observations or medication records into patient resource"]
T10_leaf4["Locate FHIR resource without row-level integrity checksum enforcement"]
T10_leaf5["Construct FHIR update payload with adversarially crafted clinical values"]
T10_leaf6["Submit update via direct FHIR store access bypassing audit controls"]

```

```

T10_root --> T10_or1
T10_or1 --> T10_sub1
T10_or1 --> T10_sub2
T10_sub1 --> T10_and1
T10_and1 --> T10_leaf1
T10_and1 --> T10_leaf2
T10_and1 --> T10_leaf3
T10_sub2 --> T10_and2
T10_and2 --> T10_leaf4
T10_and2 --> T10_leaf5
T10_and2 --> T10_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class T10_root goal
class T10_and1,T10_and2 andGate
class T10_or1 orGate
class T10_sub1,T10_sub2 subGoal
class T10_leaf1,T10_leaf2,T10_leaf3,T10_leaf4,T10_leaf5,T10_leaf6 leaf

```

Remediation Steps

- Implement row-level integrity checksums on FHIR resources. Enforce write access via the Consent and De-identification Guardrail only. Audit all write operations.

Attack Path Analysis

CRITICAL T-11 — RAG Corpus Adversarial Embedding Poisoning

Component: Clinical Guideline RAG Corpus | **Risk Level:** Critical | **Finding:** T-11

flowchart TD

```

T11_root["Cause Diagnostic Agent to retrieve adversarial clinical guidance via RAG corpus poisoning"]
T11_or1["OR"]
T11_sub1["Inject adversarial document directly into corpus indexing pipeline"]
T11_sub2["Manipulate vector embeddings to bias semantic retrieval results"]
T11_and1["AND"]
T11_and2["AND"]
T11_leaf1["Obtain write access to corpus document ingestion endpoint"]
T11_leaf2["Craft guideline document that appears legitimate but encodes adversarial clinical content"]
T11_leaf3["Inject document before provenance verification step in indexing pipeline"]
T11_leaf4["Access vector store index with write permissions"]
T11_leaf5["Craft adversarial embedding that appears near trusted guideline queries"]
T11_leaf6["Replace or insert embedding to bias retrieval toward attacker-preferred outputs"]

```

```

T11_root --> T11_or1
T11_or1 --> T11_sub1
T11_or1 --> T11_sub2
T11_sub1 --> T11_and1
T11_and1 --> T11_leaf1
T11_and1 --> T11_leaf2
T11_and1 --> T11_leaf3
T11_sub2 --> T11_and2
T11_and2 --> T11_leaf4
T11_and2 --> T11_leaf5
T11_and2 --> T11_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class T11_root goal
class T11_and1,T11_and2 andGate
class T11_or1 orGate
class T11_sub1,T11_sub2 subGoal
class T11_leaf1,T11_leaf2,T11_leaf3,T11_leaf4,T11_leaf5,T11_leaf6 leaf

```

Remediation Steps

- Implement provenance verification for all corpus documents before indexing. Deploy adversarial embedding detection and monitor retrieval patterns.

Attack Path Analysis

CRITICAL T-16 — Outcomes Telemetry Learning Loop Poisoning

Component: Outcomes Telemetry and Physician Override Audit Store | **Risk Level:** Critical | **Finding:** T-16

flowchart TD

```

T16_root["Cause Clinical LLM model drift toward attacker-preferred outputs via telemetry store poisoning"]
T16_or1{"OR"}
T16_sub1["Inject false physician-override signals into Outcomes Telemetry store"]
T16_sub2["Corrupt existing physician override records to flip endorsement signals"]
T16_and1{"AND"}
T16_and2{"AND"}
T16_leaf1["Obtain write access to Outcomes Telemetry store without physician identity verification"]
T16_leaf2["Identify high-risk recommendation categories to target for systematic drift"]
T16_leaf3["Inject adversarial override records indicating false physician approval across multiple sessions"]
T16_leaf4["Identify existing override records in store without write-access restriction"]
T16_leaf5["Modify endorsement fields to reverse physician rejection signals to approvals"]
T16_leaf6["Wait for next scheduled learning loop re-training cycle to incorporate poisoned signals"]

```

```

T16_root --> T16_or1
T16_or1 --> T16_sub1
T16_or1 --> T16_sub2
T16_sub1 --> T16_and1
T16_and1 --> T16_leaf1
T16_and1 --> T16_leaf2
T16_and1 --> T16_leaf3
T16_sub2 --> T16_and2
T16_and2 --> T16_leaf4
T16_and2 --> T16_leaf5
T16_and2 --> T16_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class T16_root goal
class T16_and1,T16_and2 andGate
class T16_or1 orGate
class T16_sub1,T16_sub2 subGoal
class T16_leaf1,T16_leaf2,T16_leaf3,T16_leaf4,T16_leaf5,T16_leaf6 leaf

```

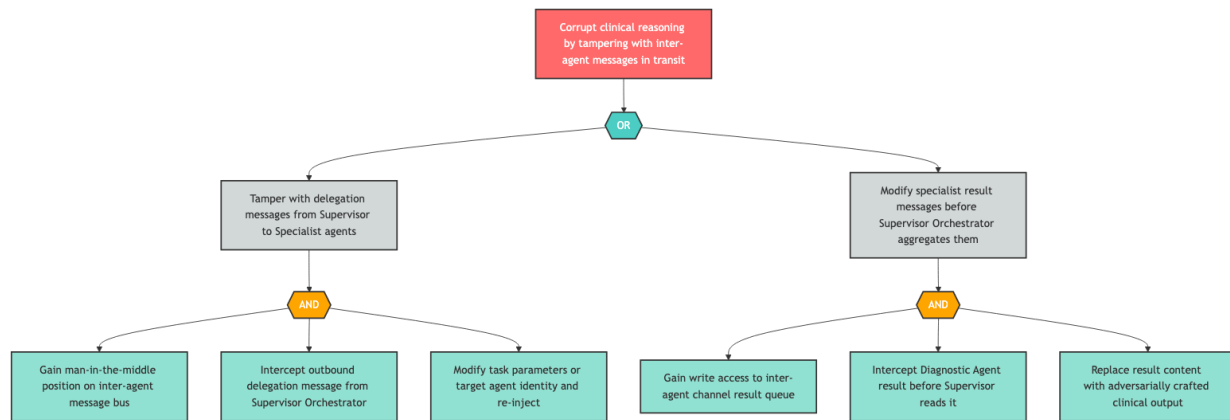
Remediation Steps

- Implement provenance attestation on all physician-override records. Apply behavioral baselining to detect drift after re-training. Restrict write access to verified physician identity tokens.

Attack Path Analysis

CRITICAL T-3 — Inter-Agent Channel Message Tampering

Component: Inter-Agent Communication Channel | **Risk Level**: Critical | **Finding**: T-3



Remediation Steps

- Implement message-level integrity (HMAC or digital signatures) on all inter-agent messages. Use tamper-evident logging for all channel activity.

Attack Path Analysis

CRITICAL T-7 — Clinical MCP Tool Server FHIR Tampering

Component: Clinical MCP Tool Server | **Risk Level:** Critical | **Finding:** T-7

flowchart TD

```

T7_root["Tamper with FHIR operations via compromised MCP Tool Server to modify patient records"]
T7_or1{"OR"}
T7_sub1["Compromise MCP Tool Server process to intercept FHIR operations"]
T7_sub2["Exploit unsigned FHIR operation requests to inject unauthorized writes"]
T7_and1{"AND"}
T7_and2{"AND"}
T7_leaf1["Gain code execution on MCP Tool Server via vulnerability exploitation"]
T7_leaf2["Intercept agent tool call before FHIR Resource Store execution"]
T7_leaf3["Modify FHIR resource payload to inject false clinical data"]
T7_leaf4["Identify FHIR write endpoint reachable without signed operation request"]
T7_leaf5["Craft unauthorized FHIR PUT or PATCH operation targeting patient record"]
T7_leaf6["Submit operation before integrity checksums are applied"]

```

```

T7_root --> T7_or1
T7_or1 --> T7_sub1
T7_or1 --> T7_sub2
T7_sub1 --> T7_and1
T7_and1 --> T7_leaf1
T7_and1 --> T7_leaf2
T7_and1 --> T7_leaf3
T7_sub2 --> T7_and2
T7_and2 --> T7_leaf4
T7_and2 --> T7_leaf5
T7_and2 --> T7_leaf6

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef andGate fill:#ffa500,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef subGoal fill:#d5dbdb,stroke:#333,stroke-width:2px,color:#333
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class T7_root goal
class T7_and1,T7_and2 andGate
class T7_or1 orGate
class T7_sub1,T7_sub2 subGoal
class T7_leaf1,T7_leaf2,T7_leaf3,T7_leaf4,T7_leaf5,T7_leaf6 leaf

```

Remediation Steps

- Enforce signed FHIR operation requests from authorized agents only. Implement FHIR resource integrity checksums and audit all write operations.

Attack Path Analysis

HIGH AG-3 — Diagnostic Agent Unauthorized FHIR Write Autonomy

Component: Diagnostic Agent | **Risk Level:** High | **Finding:** AG-3

flowchart TD

```

    AG3_root["Persist unauthorized clinical data to patient FHIR records via Diagnostic Agent autonomous FHIR write"]
    AG3_or1["OR"]
    AG3_leaf1["Compromise or manipulate Diagnostic Agent to trigger unauthorized FHIR write without physician approval gate"]
    AG3_leaf2["Exploit absent write-access restrictions to issue FHIR write for resource types beyond authorized scope"]
    AG3_leaf3["Persist erroneous diagnostic output directly to patient record via autonomous agent action"]
  
```

```

    AG3_root --> AG3_or1
    AG3_or1 --> AG3_leaf1
    AG3_or1 --> AG3_leaf2
    AG3_or1 --> AG3_leaf3
  
```

```

    classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
    classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
    classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
  
```

```

    class AG3_root goal
    class AG3_or1 orGate
    class AG3_leaf1,AG3_leaf2,AG3_leaf3 leaf
  
```

Remediation Steps

- Restrict Diagnostic Agent FHIR write access. Apply mandatory physician approval for FHIR write operations.

Attack Path Analysis

HIGH AG-4 — Diagnostic Agent MCP Tool Server Abuse

Component: Diagnostic Agent | ****Risk Level**:** High | ****Finding**:** AG-4

flowchart TD

```

AG4_root["Perform unauthorized FHIR operations via Diagnostic Agent MCP Tool Server abuse"]
AG4_or1{{"OR"}}
AG4_leaf1["Compromise Diagnostic Agent to issue bulk FHIR read operations beyond per-session token scope"]
AG4_leaf2["Exploit absent operation-level authorization to perform unauthorized FHIR write via MCP tool call"]
AG4_leaf3["Issue malicious FHIR operations using legitimate agent session token with over-provisioned permissions"]

```

```

AG4_root --> AG4_or1
AG4_or1 --> AG4_leaf1
AG4_or1 --> AG4_leaf2
AG4_or1 --> AG4_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AG4_root goal
class AG4_or1 orGate
class AG4_leaf1,AG4_leaf2,AG4_leaf3 leaf

```

Remediation Steps

- Implement operation-level authorization checks in MCP Tool Server.

HIGH AG-5 — Treatment Planner Agent Autonomous Literature Incorporation Without Validation

Component: Treatment Planner Agent | **Risk Level:** High | **Finding:** AG-5

flowchart TD

AG5_root["Deliver dangerous treatment recommendations via Treatment Planner Agent autonomous literature incorporation"]

AG5_or1{"OR"}

AG5_leaf1["Inject adversarial content into Medical Literature Vector Index upstream of retrieval"]

AG5_leaf2["Exploit absent mandatory evidence validation gate to incorporate retrieved adversarial literature"]

AG5_leaf3["Bypass physician review gate for high-consequence treatment plans generated autonomously"]

AG5_root --> AG5_or1

AG5_or1 --> AG5_leaf1

AG5_or1 --> AG5_leaf2

AG5_or1 --> AG5_leaf3

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff

classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff

classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

class AG5_root goal

class AG5_or1 orGate

class AG5_leaf1,AG5_leaf2,AG5_leaf3 leaf

Remediation Steps

- Implement mandatory evidence validation before incorporating retrieved literature.

Attack Path Analysis

HIGH AG-6 — Treatment Planner Agent MCP Tool Server FHIR Abuse

Component: Treatment Planner Agent | **Risk Level:** High | **Finding:** AG-6

flowchart TD

```

AG6_root["Perform unauthorized FHIR operations via Treatment Planner Agent MCP Tool Server abuse"]
AG6_or1{"OR"}
AG6_leaf1["Compromise Treatment Planner Agent to issue FHIR write with false treatment prescription data"]
AG6_leaf2["Exploit absent patient-scope restrictions to access FHIR records for unauthorized patients"]
AG6_leaf3["Use over-provisioned resource-type permissions to write treatment data outside authorized FHIR scope"]

```

```

AG6_root --> AG6_or1
AG6_or1 --> AG6_leaf1
AG6_or1 --> AG6_leaf2
AG6_or1 --> AG6_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AG6_root goal
class AG6_or1 orGate
class AG6_leaf1,AG6_leaf2,AG6_leaf3 leaf

```

Remediation Steps

- Enforce patient-scope and resource-type restrictions on all Treatment Planner Agent MCP tool calls.

Attack Path Analysis

HIGH AG-8 — Inter-Agent Channel Resource Exhaustion via Compromised Agent Flood

Component: Inter-Agent Communication Channel | **Risk Level:** High | **Finding:** AG-8

flowchart TD

```

AG8_root["Disrupt multi-agent clinical coordination via compromised agent channel flooding"]
AG8_or1{"OR"}
AG8_leaf1["Compromise agent to generate high-volume delegation messages exceeding channel capacity"]
AG8_leaf2["Exploit absent per-agent message rate limits to sustain channel flood from compromised agent"]
AG8_leaf3["Cause specialist agents to drop legitimate coordination tasks due to message queue saturation"]

```

```

AG8_root --> AG8_or1
AG8_or1 --> AG8_leaf1
AG8_or1 --> AG8_leaf2
AG8_or1 --> AG8_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AG8_root goal
class AG8_or1 orGate
class AG8_leaf1,AG8_leaf2,AG8_leaf3 leaf

```

Remediation Steps

- Implement per-agent message rate limits on the inter-agent channel.

Attack Path Analysis

HIGH AGP-02 — Outcomes Telemetry Persistent-State Temporal Attack

Component: Outcomes Telemetry and Physician Override Audit Store | ****Risk Level**:** High | ****Finding**:** AGP-02

flowchart TD

```

AGP02_root["Achieve delayed model drift via gradual Outcomes Telemetry corruption below detection thresholds"]
AGP02_or1["OR"]
AGP02_leaf1["Inject small volume of adversarial override signals per session staying below anomaly detection threshold"]
AGP02_leaf2["Accumulate injected signals across multiple sessions until aggregate corrupts learning loop re-training"]
AGP02_leaf3["Exploit absent memory-write audit trails to inject without provenance attestation triggering alert"]

```

```

AGP02_root --> AGP02_or1
AGP02_or1 --> AGP02_leaf1
AGP02_or1 --> AGP02_leaf2
AGP02_or1 --> AGP02_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class AGP02_root goal
class AGP02_or1 orGate
class AGP02_leaf1,AGP02_leaf2,AGP02_leaf3 leaf

```

Remediation Steps

- Implement training-data provenance attestation, memory-write audit trails, and periodic behavioral baselining against pre-training snapshots.

Attack Path Analysis

HIGH AGP-03 — Supervisor Orchestrator Multi-Agent Cascading Delegation Emergent Behavior

Component: Supervisor Orchestrator | **Risk Level:** High | **Finding:** AGP-03

flowchart TD

AGP03_root["Trigger emergent multi-agent failure cascade via Supervisor Orchestrator cascading delegation manipulation"]

AGP03_or1["OR"]

AGP03_leaf1["Introduce malformed specialist agent output that causes Supervisor to issue amplified downstream delegation"]

AGP03_leaf2["Exploit absent fail-safe shutdown circuits to allow cascade to propagate across all specialist agents"]

AGP03_leaf3["Trigger feedback amplification loop where each delegated result causes larger follow-on delegation"]

AGP03_root --> AGP03_or1

AGP03_or1 --> AGP03_leaf1

AGP03_or1 --> AGP03_leaf2

AGP03_or1 --> AGP03_leaf3

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff

classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff

classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

class AGP03_root goal

class AGP03_or1 orGate

class AGP03_leaf1,AGP03_leaf2,AGP03_leaf3 leaf

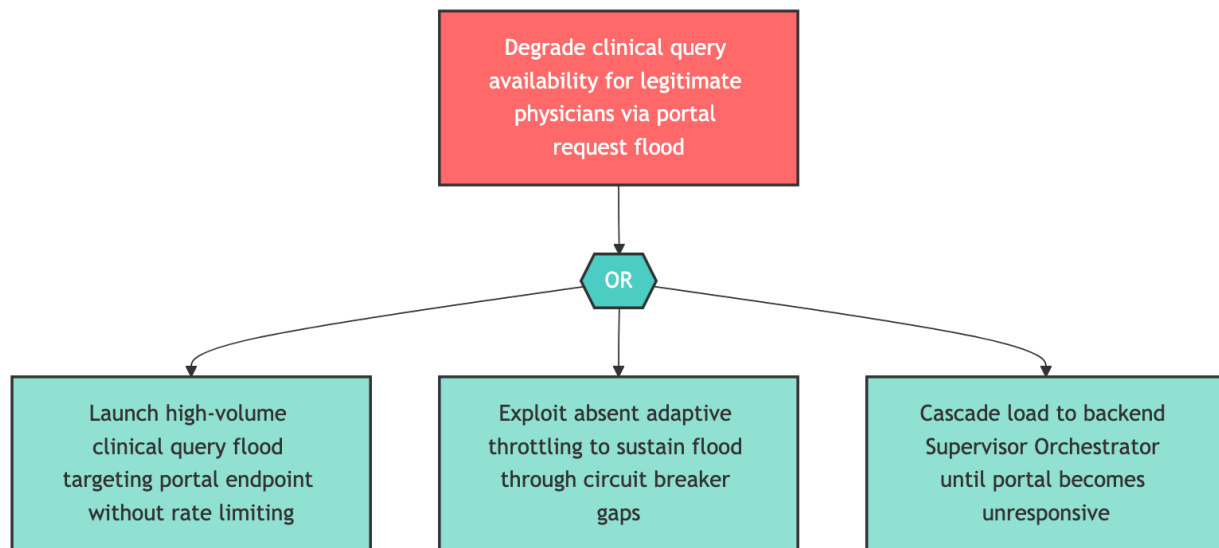
Remediation Steps

- Implement fail-safe shutdown circuits, bounded action scopes per agent, and behavioral baselining of the collective agent system.

Attack Path Analysis

HIGH D-1 — Physician Clinical Portal Clinical Query Flood

Component: Physician Clinical Portal | **Risk Level**: High | **Finding**: D-1

**Remediation Steps**

- Implement rate limiting on clinical query submission. Apply adaptive throttling.

Attack Path Analysis

HIGH D-10 — FHIR Resource Store Query Flood

Component: FHIR Resource Store | **Risk Level:** High | **Finding:** D-10

flowchart TD

```

D10_root["Degrade FHIR patient record availability via resource-exhausting query flood"]
D10_or1{"OR"}
D10_leaf1["Issue high-complexity FHIR queries exceeding resource store compute limits without rate throttling"]
D10_leaf2["Launch FHIR write flood saturating storage I/O and blocking legitimate read operations"]
D10_leaf3["Coordinate multi-agent flood using compromised agents to overcome per-component quotas"]

```

```
D10_root --> D10_or1
```

```
D10_or1 --> D10_leaf1
```

```
D10_or1 --> D10_leaf2
```

```
D10_or1 --> D10_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
```

```
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
```

```
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class D10_root goal
```

```
class D10_or1 orGate
```

```
class D10_leaf1,D10_leaf2,D10_leaf3 leaf
```

Remediation Steps

- Implement query complexity limits and rate throttling on FHIR operations.

HIGH D-13 — Model Inference API Gateway Request Flood

Component: Model Inference API Gateway | **Risk Level:** High | **Finding:** D-13

flowchart TD

```
D13_root["Deny all agent access to foundation model inference via API Gateway request saturation"]
D13_or1{"OR"}
D13_leaf1["Launch high-volume inference request flood targeting gateway without rate quotas"]
D13_leaf2["Exploit absent adaptive load balancing to saturate all gateway processing threads"]
D13_leaf3["Cause backend model circuit breakers to trip blocking all legitimate inference requests"]
```

```
D13_root --> D13_or1
D13_or1 --> D13_leaf1
D13_or1 --> D13_leaf2
D13_or1 --> D13_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class D13_root goal
class D13_or1 orGate
class D13_leaf1,D13_leaf2,D13_leaf3 leaf
```

Remediation Steps

- Implement rate limiting and request quotas at the gateway. Apply adaptive load balancing.

Attack Path Analysis

HIGH D-3 — Inter-Agent Channel Delegation Message Flood

Component: Inter-Agent Communication Channel | **Risk Level:** High | **Finding:** D-3

flowchart TD

```

    D3_root["Disrupt multi-agent clinical coordination by flooding inter-agent channel with spurious delegation messages"]
    D3_or1{"OR"}
    D3_leaf1["Generate high-volume spurious delegation messages targeting inter-agent channel without per-agent rate controls"]
    D3_leaf2["Bypass message origin validation to inject flood traffic from attacker-controlled source"]
    D3_leaf3["Sustain flood until channel queue depth saturates and legitimate task messages are dropped"]

    D3_root --> D3_or1
    D3_or1 --> D3_leaf1
    D3_or1 --> D3_leaf2
    D3_or1 --> D3_leaf3
  
```

```

    D3_root --> D3_or1
    D3_or1 --> D3_leaf1
    D3_or1 --> D3_leaf2
    D3_or1 --> D3_leaf3
  
```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
  
```

```

class D3_root goal
class D3_or1 orGate
class D3_leaf1,D3_leaf2,D3_leaf3 leaf
  
```

Remediation Steps

- Implement channel capacity limits with per-agent message rate controls.

Attack Path Analysis

HIGH D-4 — Supervisor Orchestrator Resource Exhaustion via Task Result Flood

Component: Supervisor Orchestrator | **Risk Level:** High | **Finding:** D-4

flowchart TD

```

D4_root["Exhaust Supervisor Orchestrator resources via specialist agent task result flood"]
D4_or1{"OR"}
D4_leaf1["Compromise specialist agent to generate high-volume error responses to Supervisor Orchestrator"]
D4_leaf2["Exploit absent per-agent response rate limits at orchestrator to sustain flood"]
D4_leaf3["Cause Supervisor Orchestrator resource exhaustion rendering it unable to coordinate clinical queries"]

```

```

D4_root --> D4_or1
D4_or1 --> D4_leaf1
D4_or1 --> D4_leaf2
D4_or1 --> D4_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class D4_root goal
class D4_or1 orGate
class D4_leaf1,D4_leaf2,D4_leaf3 leaf

```

Remediation Steps

- Implement circuit breakers on specialist agent result processing. Apply per-agent response rate limits.

Attack Path Analysis

HIGH D-5 — Diagnostic Agent Resource Exhaustion via Tool Call Flood**Component:** Diagnostic Agent | **Risk Level:** High | **Finding:** D-5

flowchart TD

```

D5_root["Disrupt Diagnostic Agent availability via tool call flood or guideline retrieval storm"]
D5_or1{"OR"}
D5_leaf1["Launch tool call flood targeting Diagnostic Agent without per-session rate limits"]
D5_leaf2["Issue high-volume guideline retrieval requests exhausting RAG corpus query capacity"]
D5_leaf3["Sustain resource exhaustion until Diagnostic Agent drops legitimate clinical query processing"]

```

```

D5_root --> D5_or1
D5_or1 --> D5_leaf1
D5_or1 --> D5_leaf2
D5_or1 --> D5_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class D5_root goal
class D5_or1 orGate
class D5_leaf1,D5_leaf2,D5_leaf3 leaf

```

Remediation Steps

- Implement tool call rate limits per clinical session. Apply circuit breakers on guideline retrieval.

Attack Path Analysis

HIGH D-7 — Clinical MCP Tool Server JSON-RPC Flood

Component: Clinical MCP Tool Server | **Risk Level:** High | **Finding:** D-7

flowchart TD

```
D7_root["Exhaust MCP Tool Server resources via JSON-RPC tool call flood denying access to legitimate agents"]
D7_or1{"OR"}
D7_leaf1["Compromise agent to generate high-volume JSON-RPC tool calls without per-agent rate limits"]
D7_leaf2["Issue excessive FHIR operation requests exhausting tool server processing capacity"]
D7_leaf3["Sustain flood using multiple compromised agents to overcome per-agent quotas via coordination"]
```

```
D7_root --> D7_or1
D7_or1 --> D7_leaf1
D7_or1 --> D7_leaf2
D7_or1 --> D7_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class D7_root goal
class D7_or1 orGate
class D7_leaf1,D7_leaf2,D7_leaf3 leaf
```

Remediation Steps

- Implement per-agent rate limits on MCP tool calls. Apply FHIR operation quotas.

HIGH D-8 — Clinical LLM Inference Capacity Exhaustion**Component:** Clinical LLM | **Risk Level:** High | **Finding:** D-8

flowchart TD

```

D8_root["Exhaust Clinical LLM inference capacity via large prompt flood through API Gateway"]
D8_or1{"OR"}
D8_leaf1["Generate high-volume large prompt requests via API Gateway without per-session rate limiting"]
D8_leaf2["Craft maximally-large prompts consuming disproportionate inference compute per request"]
D8_leaf3["Sustain flood until inference queue saturates and legitimate clinical queries time out"]

```

```

D8_root --> D8_or1
D8_or1 --> D8_leaf1
D8_or1 --> D8_leaf2
D8_or1 --> D8_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class D8_root goal
class D8_or1 orGate
class D8_leaf1,D8_leaf2,D8_leaf3 leaf

```

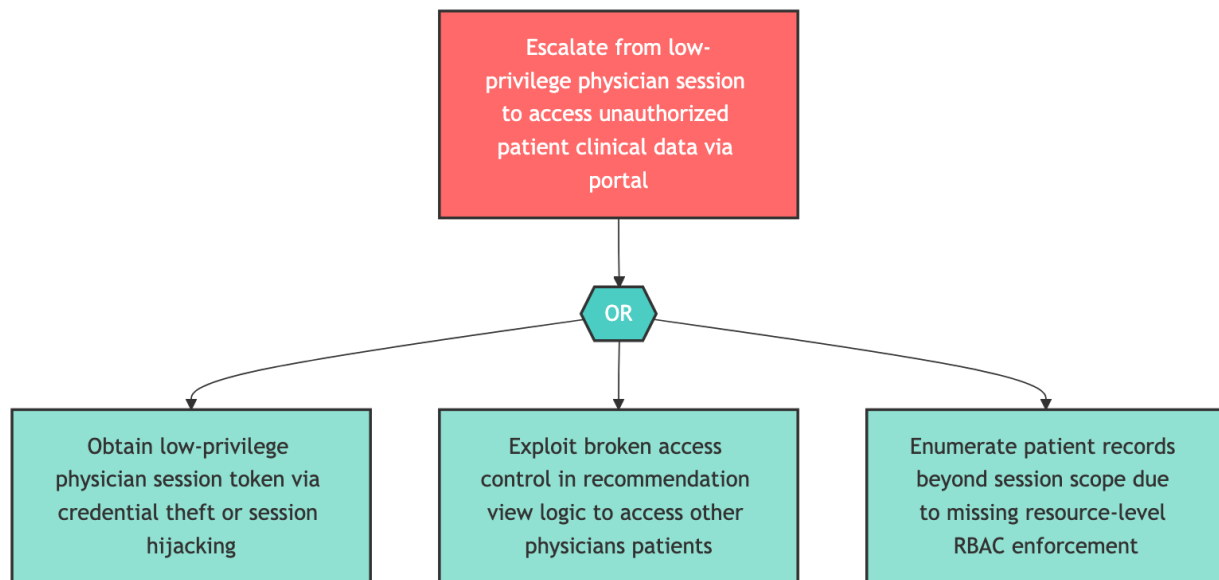
Remediation Steps

- Implement inference request rate limiting at the API Gateway per authenticated session.

Attack Path Analysis

HIGH E-1 — Physician Clinical Portal Privilege Escalation

Component: Physician Clinical Portal | **Risk Level**: High | **Finding**: E-1

**Remediation Steps**

- Implement strict session isolation and resource-level RBAC enforcement.

Attack Path Analysis

HIGH E-2 — Patient Summary Generator Unauthorized Patient Access

Component: Patient Summary Generator | **Risk Level:** High | **Finding:** E-2

flowchart TD

```

E2_root["Access unauthorized patient records via Patient Summary Generator scope escalation"]
E2_or1["OR"]
E2_leaf1["Exploit absent identity-scope validation to request summary for unauthorized patient ID"]
E2_leaf2["Enumerate patient scope through summary generation requests using guessed patient identifiers"]
E2_leaf3["Access patient data beyond current authorization scope via missing Supervisor Orchestrator scope enforcement"]

```

```

E2_root --> E2_or1
E2_or1 --> E2_leaf1
E2_or1 --> E2_leaf2
E2_or1 --> E2_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class E2_root goal
class E2_or1 orGate
class E2_leaf1,E2_leaf2,E2_leaf3 leaf

```

Remediation Steps

- Validate requesting identity against authorized patient scope before generating summaries.

Attack Path Analysis

HIGH E-3 — Inter-Agent Channel Privilege Escalation to Supervisor Authority

Component: Inter-Agent Communication Channel | **Risk Level:** High | **Finding:** E-3

flowchart TD

```
E3_root["Issue supervisor-level unauthorized delegation commands by escalating inter-agent channel access"]
E3_or1["OR"]
E3_leaf1["Exploit absent role-based message authorization on inter-agent channel"]
E3_leaf2["Inject delegation message with elevated authority level before specialist agent authority check"]
E3_leaf3["Cause specialist agent to execute unauthorized clinical operation via forged supervisor authority"]
```

```
E3_root --> E3_or1
E3_or1 --> E3_leaf1
E3_or1 --> E3_leaf2
E3_or1 --> E3_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class E3_root goal
class E3_or1 orGate
class E3_leaf1,E3_leaf2,E3_leaf3 leaf
```

Remediation Steps

- Implement role-based message authorization on the inter-agent channel.

HIGH E-4 — Supervisor Orchestrator RBAC Bypass and Permission Escalation

Component: Supervisor Orchestrator | **Risk Level:** High | **Finding:** E-4

flowchart TD

```
E4_root["Bypass HIPAA RBAC controls or escalate specialist agent permissions via Supervisor Orchestrator compromise"]
E4_or1{{"OR"}}
E4_leaf1["Compromise Supervisor Orchestrator service account to bypass external RBAC validation calls"]
E4_leaf2["Modify orchestrator logic to skip HIPAA Policy Engine compliance check before patient data access"]
E4_leaf3["Issue delegation command granting specialist agent permissions exceeding authorized scope"]
```

```
E4_root --> E4_or1
E4_or1 --> E4_leaf1
E4_or1 --> E4_leaf2
E4_or1 --> E4_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class E4_root goal
class E4_or1 orGate
class E4_leaf1,E4_leaf2,E4_leaf3 leaf
```

Remediation Steps

- Enforce external RBAC validation for all orchestrator actions affecting patient data.

Attack Path Analysis

HIGH E-5 — Diagnostic Agent FHIR Access Scope Escalation

Component: Diagnostic Agent | **Risk Level:** High | **Finding:** E-5

flowchart TD

```

E5_root["Access patient records outside authorized scope via Diagnostic Agent FHIR permission escalation"]
E5_or1["OR"]
E5_leaf1["Compromise Diagnostic Agent to issue FHIR queries beyond current patient scope"]
E5_leaf2["Exploit absent resource-level FHIR access scoping to enumerate unauthorized patient records"]
E5_leaf3["Use over-permissive per-session access token to access FHIR resources outside clinical query scope"]

```

```

E5_root --> E5_or1
E5_or1 --> E5_leaf1
E5_or1 --> E5_leaf2
E5_or1 --> E5_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class E5_root goal
class E5_or1 orGate
class E5_leaf1,E5_leaf2,E5_leaf3 leaf

```

Remediation Steps

- Enforce resource-level FHIR access scoping for Diagnostic Agent operations.

Attack Path Analysis

HIGH E-6 — Treatment Planner Agent FHIR Access Escalation

Component: Treatment Planner Agent | **Risk Level:** High | **Finding:** E-6

flowchart TD

```
E6_root["Access unauthorized FHIR patient records via Treatment Planner Agent scope escalation"]
E6_or1{"OR"}
E6_leaf1["Compromise Treatment Planner Agent to issue FHIR operations beyond current patient scope"]
E6_leaf2["Exploit absent per-session FHIR access scoping to access unauthorized patient records"]
E6_leaf3["Use over-permissive MCP Tool Server resource access to retrieve records outside authorized scope"]
```

```
E6_root --> E6_or1
E6_or1 --> E6_leaf1
E6_or1 --> E6_leaf2
E6_or1 --> E6_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class E6_root goal
class E6_or1 orGate
class E6_leaf1,E6_leaf2,E6_leaf3 leaf
```

Remediation Steps

- Apply per-session FHIR access scoping for Treatment Planner Agent tool calls.

Attack Path Analysis

HIGH E-8 — Clinical LLM Prompt Injection Privilege Escalation

Component: Clinical LLM | **Risk Level:** High | **Finding:** E-8

flowchart TD

```

E8_root["Cause Supervisor Orchestrator to execute elevated-privilege commands via Clinical LLM prompt injection"]
E8_or1{"OR"}
E8_leaf1["Craft clinical query containing prompt injection payload encoding system command instructions"]
E8_leaf2["Bypass prompt injection detection at API Gateway to deliver adversarial instruction to Clinical LLM"]
E8_leaf3["Cause LLM completion containing system command pattern to be interpreted as trusted orchestrator instruction"]

```

```

E8_root --> E8_or1
E8_or1 --> E8_leaf1
E8_or1 --> E8_leaf2
E8_or1 --> E8_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class E8_root goal
class E8_or1 orGate
class E8_leaf1,E8_leaf2,E8_leaf3 leaf

```

Remediation Steps

- Implement prompt injection detection at the API Gateway. Apply output filtering.

Attack Path Analysis

HIGH I-1 — Physician Clinical Portal PHI Disclosure

Component: Physician Clinical Portal | **Risk Level:** High | **Finding:** I-1

flowchart TD

```
I1_root["Disclose patient PHI via Physician Clinical Portal through misconfiguration or access control bypass"]
I1_or1{"OR"}
I1_leaf1["Exploit insecure TLS configuration to intercept clinical recommendation traffic"]
I1_leaf2["Trigger verbose error responses exposing PHI-containing stack traces or debug output"]
I1_leaf3["Access recommendation view for unauthorized patient via missing field-level access control"]
```

```
I1_root --> I1_or1
I1_or1 --> I1_leaf1
I1_or1 --> I1_leaf2
I1_or1 --> I1_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class I1_root goal
class I1_or1 orGate
class I1_leaf1,I1_leaf2,I1_leaf3 leaf
```

Remediation Steps

- Enforce TLS 1.3 minimum. Sanitize all error messages. Implement field-level access control.

Attack Path Analysis

HIGH I-14 — EHR Ingestion Queue Patient Record Disclosure

Component: EHR Ingestion Queue | **Risk Level:** High | **Finding:** I-14

flowchart TD

```
I14_root["Disclose patient EHR records from ingestion queue via insufficient access control"]
I14_or1{"OR"}
I14_leaf1["Obtain unauthorized read access to EHR Ingestion Queue via overly permissive queue ACL"]
I14_leaf2["Intercept unencrypted EHR event messages in queue transport layer"]
I14_leaf3["Read queued patient records before normalization and FHIR ingestion consumes them"]
```

```
I14_root --> I14_or1
I14_or1 --> I14_leaf1
I14_or1 --> I14_leaf2
I14_or1 --> I14_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class I14_root goal
class I14_or1 orGate
class I14_leaf1,I14_leaf2,I14_leaf3 leaf
```

Remediation Steps

- Encrypt all queued messages. Restrict queue read access to authorized consumers only.

Attack Path Analysis

HIGH I-15 — Clinical Audit Log Unauthorized Read Access

Component: Clinical Audit Log | **Risk Level:** High | **Finding:** I-15

flowchart TD

```
I15_root["Disclose clinical decision trails and PHI via unauthorized Clinical Audit Log read access"]
I15_or1{"OR"}
I15_leaf1["Obtain over-privileged service account with read access to audit log storage"]
I15_leaf2["Exploit absent read-access controls to enumerate clinical session decision records"]
I15_leaf3["Extract agent decision patterns and PHI-containing reasoning from audit log entries"]
```

```
I15_root --> I15_or1
I15_or1 --> I15_leaf1
I15_or1 --> I15_leaf2
I15_or1 --> I15_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class I15_root goal
class I15_or1 orGate
class I15_leaf1,I15_leaf2,I15_leaf3 leaf
```

Remediation Steps

- Restrict audit log read access to authorized compliance personnel only. Encrypt audit log storage.

Attack Path Analysis

HIGH I-16 — Outcomes Telemetry Store Clinical Pattern Disclosure

Component: Outcomes Telemetry and Physician Override Audit Store | **Risk Level:** High | **Finding:** I-16

flowchart TD

```

I16_root["Disclose sensitive clinical patterns or re-identify patients via Outcomes Telemetry store access"]
I16_or1{"OR"}
I16_leaf1["Obtain unauthorized read access to Outcomes Telemetry store"]
I16_leaf2["Extract physician override patterns correlated with specific patient presentation types"]
I16_leaf3["Use telemetry signals to re-identify de-identified patients in model training data"]

```

```

I16_root --> I16_or1
I16_or1 --> I16_leaf1
I16_or1 --> I16_leaf2
I16_or1 --> I16_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I16_root goal
class I16_or1 orGate
class I16_leaf1,I16_leaf2,I16_leaf3 leaf

```

Remediation Steps

- Restrict access to Outcomes Telemetry. Apply re-identification risk assessment before model updates.

Attack Path Analysis

HIGH I-2 — Patient Summary Unauthorized PHI Disclosure

Component: Patient Summary Generator | **Risk Level:** High | **Finding:** I-2

flowchart TD

```

I2_root["Disclose PHI beyond authorized scope via Patient Summary Generator delivery failure"]
I2_or1{"OR"}
I2_leaf1["Exploit absent patient identity verification to request summary for unauthorized patient"]
I2_leaf2["Trigger summary generation including out-of-scope sensitive clinical details via crafted request"]
I2_leaf3["Intercept summary delivery to wrong patient due to missing recipient identity binding"]

```

```

I2_root --> I2_or1
I2_or1 --> I2_leaf1
I2_or1 --> I2_leaf2
I2_or1 --> I2_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I2_root goal
class I2_or1 orGate
class I2_leaf1,I2_leaf2,I2_leaf3 leaf

```

Remediation Steps

- Implement patient identity verification before summary delivery. Apply disclosure-scope filtering.

Attack Path Analysis

HIGH I-4 — Supervisor Orchestrator Aggregated Clinical Context Exposure

Component: Supervisor Orchestrator | **Risk Level:** High | **Finding:** I-4

flowchart TD

```

I4_root["Disclose aggregated patient PHI and clinical reasoning via Supervisor Orchestrator compromise"]
I4_or1["OR"]
I4_leaf1["Compromise Supervisor Orchestrator process to read assembled multi-component clinical context"]
I4_leaf2["Extract PHI-containing context windows assembled from FHIR data and specialist results"]
I4_leaf3["Exploit missing memory isolation to access patient data from adjacent clinical sessions"]

I4_root --> I4_or1
I4_or1 --> I4_leaf1
I4_or1 --> I4_leaf2
I4_or1 --> I4_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I4_root goal
class I4_or1 orGate
class I4_leaf1,I4_leaf2,I4_leaf3 leaf

```

Remediation Steps

- Implement minimal-exposure context windows. Sanitize aggregated context before logging.

Attack Path Analysis

HIGH I-5 — Diagnostic Agent Patient Context Disclosure

Component: Diagnostic Agent | **Risk Level:** High | **Finding:** I-5

flowchart TD

```
I5_root["Disclose patient PHI via Diagnostic Agent tool call parameter leakage or session isolation failure"]
I5_or1{"OR"}
I5_leaf1["Trigger verbose tool call error response exposing patient context in error message"]
I5_leaf2["Exploit missing session isolation to access patient data from concurrent clinical queries"]
I5_leaf3["Read PHI exposed in unfiltered tool call parameters logged without sanitization"]
```

```
I5_root --> I5_or1
I5_or1 --> I5_leaf1
I5_or1 --> I5_leaf2
I5_or1 --> I5_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class I5_root goal
class I5_or1 orGate
class I5_leaf1,I5_leaf2,I5_leaf3 leaf
```

Remediation Steps

- Implement session isolation for each clinical query. Sanitize all tool call parameters and error responses.

Attack Path Analysis

HIGH I-6 — Treatment Planner Agent Patient Data Disclosure

Component: Treatment Planner Agent | **Risk Level:** High | **Finding:** I-6

flowchart TD

```
I6_root["Disclose patient data via Treatment Planner Agent session isolation failure or error response leakage"]
I6_or1{"OR"}
I6_leaf1["Exploit missing session isolation to access patient context from concurrent treatment planning task"]
I6_leaf2["Trigger unfiltered error response exposing retrieved literature result containing patient-specific context"]
I6_leaf3["Read PHI leaked through unfiltered treatment plan output before output filtering applied"]
```

```
I6_root --> I6_or1
I6_or1 --> I6_leaf1
I6_or1 --> I6_leaf2
I6_or1 --> I6_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class I6_root goal
class I6_or1 orGate
class I6_leaf1,I6_leaf2,I6_leaf3 leaf
```

Remediation Steps

- Implement session isolation for each treatment planning task. Apply output filtering.

Attack Path Analysis

HIGH I-8 — Clinical LLM Training Data PHI Memorization

Component: Clinical LLM | **Risk Level:** High | **Finding:** I-8

flowchart TD

```

I8_root["Extract patient PHI from Clinical LLM training data via completion-based memorization attack"]
I8_or1{"OR"}
I8_leaf1["Craft targeted query designed to trigger memorized patient-specific clinical training data"]
I8_leaf2["Issue systematic extraction queries to identify PHI-containing completions via API Gateway"]
I8_leaf3["Collect PHI surfaced in completion responses lacking differential privacy protection"]

```

```

I8_root --> I8_or1
I8_or1 --> I8_leaf1
I8_or1 --> I8_leaf2
I8_or1 --> I8_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I8_root goal
class I8_or1 orGate
class I8_leaf1,I8_leaf2,I8_leaf3 leaf

```

Remediation Steps

- Apply differential privacy during model training. Implement output monitoring for PHI pattern detection.

HIGH I-9 — Risk Stratification Model Membership Inference Attack

Component: Risk Stratification Model | **Risk Level:** High | **Finding:** I-9

flowchart TD

```

I9_root["Determine fine-tuning training set membership to identify patients via Risk Stratification Model inference attack"]
I9_or1{"OR"}
I9_leaf1["Craft patient record queries matching suspected training samples and observe confidence scores"]
I9_leaf2["Compare model output confidence differentials between training and non-training patient presentations"]
I9_leaf3["Exploit overfitted model responses revealing individual patient characteristics from training data"]

```

```

I9_root --> I9_or1
I9_or1 --> I9_leaf1
I9_or1 --> I9_leaf2
I9_or1 --> I9_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class I9_root goal
class I9_or1 orGate
class I9_leaf1,I9_leaf2,I9_leaf3 leaf

```

Remediation Steps

- Apply differential privacy during fine-tuning. Implement model output monitoring.

Attack Path Analysis

HIGH LLM-2 — Clinical LLM Training Data Poisoning via Learning Loop

Component: Clinical LLM | **Risk Level:** High | **Finding:** LLM-2

flowchart TD

LLM2_root["Cause Clinical LLM systematic output bias via training data poisoning through Outcomes Telemetry learning loop"]

LLM2_or1["OR"]

LLM2_leaf1["Inject adversarial physician-override signals into Outcomes Telemetry to corrupt learning loop feedback"]

LLM2_leaf2["Tamper with fine-tuning dataset before learning loop re-training cycle to embed adversarial patterns"]

LLM2_leaf3["Exploit absent behavioral baselining to deploy poisoned model without drift detection triggering"]

LLM2_root --> LLM2_or1

LLM2_or1 --> LLM2_leaf1

LLM2_or1 --> LLM2_leaf2

LLM2_or1 --> LLM2_leaf3

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff

classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff

classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

class LLM2_root goal

class LLM2_or1 orGate

class LLM2_leaf1,LLM2_leaf2,LLM2_leaf3 leaf

Remediation Steps

- Implement training data provenance attestation. Apply behavioral baselining to detect post-training output drift.

HIGH LLM-4 — Risk Stratification Model Adversarial Input Manipulation

Component: Risk Stratification Model | **Risk Level:** High | **Finding:** LLM-4

flowchart TD

```

LLM4_root["Cause incorrect clinical triage via adversarial patient record inputs to Risk Stratification Model"]
LLM4_or1{"OR"}
LLM4_leaf1["Craft adversarial patient record with modified feature values triggering model risk score manipulation"]
LLM4_leaf2["Inject modified patient EHR data upstream to cause adversarial features to reach model at inference time"]
LLM4_leaf3["Exploit absent ensemble validation to deliver manipulated risk score into clinical decision workflow"]

```

```

LLM4_root --> LLM4_or1
LLM4_or1 --> LLM4_leaf1
LLM4_or1 --> LLM4_leaf2
LLM4_or1 --> LLM4_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class LLM4_root goal
class LLM4_or1 orGate
class LLM4_leaf1,LLM4_leaf2,LLM4_leaf3 leaf

```

Remediation Steps

- Implement input validation and anomaly detection for adversarial patient record patterns.

Attack Path Analysis

HIGH LLM-5 — Risk Stratification Model Fine-Tuning Dataset Poisoning

Component: Risk Stratification Model | **Risk Level:** High | **Finding:** LLM-5

flowchart TD

```

    LLM5_root["Cause systematic high-risk patient misclassification via Risk Stratification Model fine-tuning dataset poisoning"]
    LLM5_or1["OR"]
    LLM5_leaf1["Gain write access to fine-tuning dataset and inject adversarially mislabeled high-risk patient samples"]
    LLM5_leaf2["Exploit absent dataset integrity verification to inject poisoned samples before training run"]
    LLM5_leaf3["Wait for model re-training cycle to incorporate poisoned labels causing systematic classification drift"]
  
```

LLM5_root --> LLM5_or1

LLM5_or1 --> LLM5_leaf1

LLM5_or1 --> LLM5_leaf2

LLM5_or1 --> LLM5_leaf3

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
```

```
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
```

```
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class LLM5_root goal
```

```
class LLM5_or1 orGate
```

```
class LLM5_leaf1,LLM5_leaf2,LLM5_leaf3 leaf
```

Remediation Steps

- Implement fine-tuning dataset integrity verification. Apply behavioral testing against known high-risk cases after model updates.

Attack Path Analysis

HIGH LLM-6 — Risk Stratification Model Membership Inference Privacy Attack

Component: Risk Stratification Model | **Risk Level:** High | **Finding:** LLM-6

flowchart TD

```

LLM6_root["Determine patient training set membership via membership inference attack on Risk Stratification Model"]
LLM6_or1["OR"]
LLM6_leaf1["Issue systematic inference queries for suspected training set patient records via API Gateway"]
LLM6_leaf2["Measure model confidence differentials to distinguish training members from non-members"]
LLM6_leaf3["Exploit absent differential privacy to extract definitive membership signals from model output patterns"]

```

```

LLM6_root --> LLM6_or1
LLM6_or1 --> LLM6_leaf1
LLM6_or1 --> LLM6_leaf2
LLM6_or1 --> LLM6_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class LLM6_root goal
class LLM6_or1 orGate
class LLM6_leaf1,LLM6_leaf2,LLM6_leaf3 leaf

```

Remediation Steps

- Apply differential privacy during model fine-tuning. Implement query auditing to detect membership inference patterns.

Attack Path Analysis

HIGH R-5 — Inter-Agent Channel Repudiation of Delegation Messages

Component: Inter-Agent Communication Channel | **Risk Level:** High | **Finding:** R-5

flowchart TD

```
R5_root["Enable agent repudiation of clinical coordination actions via insufficient delegation message logging"]
R5_or1["OR"]
R5_leaf1["Exploit absent per-message cryptographic receipts to deny issuing delegation command"]
R5_leaf2["Delete or tamper with inter-agent message logs before forensic review"]
R5_leaf3["Deny specialist result submission when no non-repudiable record exists in Clinical Audit Log"]
```

```
R5_root --> R5_or1
R5_or1 --> R5_leaf1
R5_or1 --> R5_leaf2
R5_or1 --> R5_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class R5_root goal
class R5_or1 orGate
class R5_leaf1,R5_leaf2,R5_leaf3 leaf
```

Remediation Steps

- Enforce tamper-evident inter-agent message logging with per-message cryptographic receipts.

HIGH R-6 — Supervisor Orchestrator Delegation Record Repudiation

Component: Supervisor Orchestrator | **Risk Level:** High | **Finding:** R-6

flowchart TD

```
R6_root["Enable Supervisor Orchestrator to deny clinical delegation decisions via insufficient audit logging"]
R6_or1["OR"]
R6_leaf1["Exploit absent mandatory pre-action audit logging to issue delegation without recorded evidence"]
R6_leaf2["Tamper with existing orchestration audit records before post-incident review"]
R6_leaf3["Deny aggregation of specific specialist result when no cryptographic receipt links result to action"]
```

```
R6_root --> R6_or1
R6_or1 --> R6_leaf1
R6_or1 --> R6_leaf2
R6_or1 --> R6_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class R6_root goal
class R6_or1 orGate
class R6_leaf1,R6_leaf2,R6_leaf3 leaf
```

Remediation Steps

- Implement mandatory pre-action audit logging for all orchestration decisions.

HIGH R-9 — MCP Tool Server FHIR Operation Repudiation

Component: Clinical MCP Tool Server | **Risk Level:** High | **Finding:** R-9

flowchart TD

```
R9_root["Enable denial of patient record modifications via absent MCP Tool Server FHIR operation audit logging"]
R9_or1{"OR"}
R9_leaf1["Issue FHIR write operation without requesting agent identity being logged"]
R9_leaf2["Tamper with MCP audit log to remove evidence of unauthorized FHIR modification"]
R9_leaf3["Deny tool call execution when no non-repudiable record links operation to requesting agent"]
```

```
R9_root --> R9_or1
R9_or1 --> R9_leaf1
R9_or1 --> R9_leaf2
R9_or1 --> R9_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class R9_root goal
class R9_or1 orGate
class R9_leaf1,R9_leaf2,R9_leaf3 leaf
```

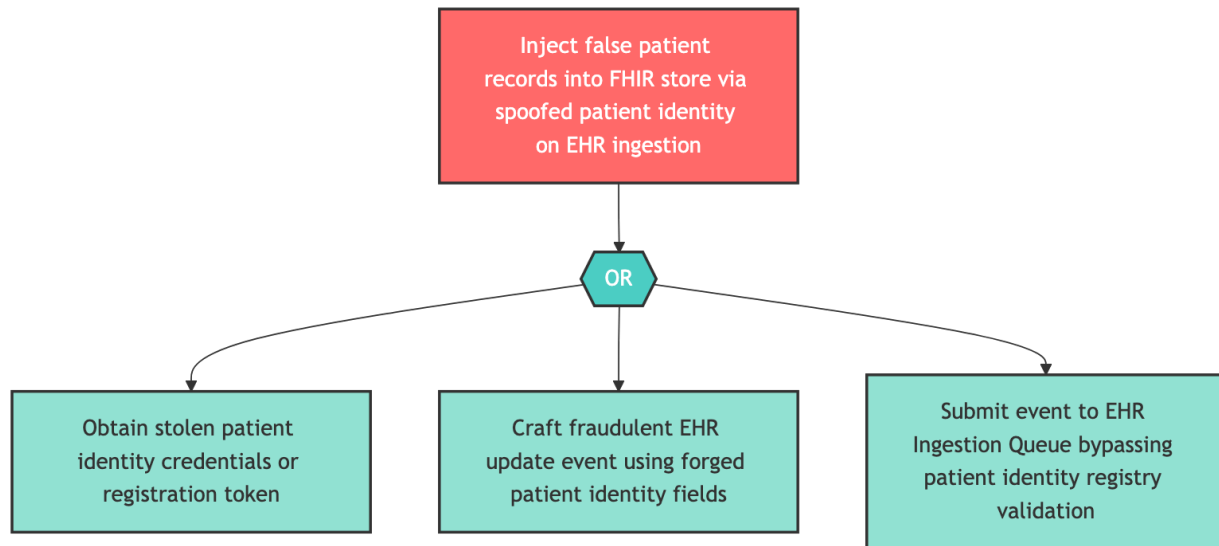
Remediation Steps

- Implement mandatory audit logging of all MCP tool calls with requesting agent identity.

Attack Path Analysis

HIGH S-2 — Patient Identity Spoofing for EHR Injection

Component: Patient | **Risk Level**: High | **Finding**: S-2

**Remediation Steps**

- Validate EHR update events against authoritative patient identity registry. Use cryptographic patient identity tokens.

Attack Path Analysis

HIGH S-3 — Physician Clinical Portal Spoofing

Component: Physician Clinical Portal | **Risk Level:** High | **Finding:** S-3

flowchart TD

```
S3_root["Intercept clinical recommendations and PHI via spoofed Physician Clinical Portal"]
S3_or1["OR"]
S3_leaf1["Set up rogue portal endpoint with forged server certificate or DNS redirect"]
S3_leaf2["Intercept Supervisor Orchestrator response lacking signed response token validation"]
S3_leaf3["Deliver intercepted PHI-containing recommendation to attacker-controlled storage"]
```

```
S3_root --> S3_or1
S3_or1 --> S3_leaf1
S3_or1 --> S3_leaf2
S3_or1 --> S3_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class S3_root goal
class S3_or1 orGate
class S3_leaf1,S3_leaf2,S3_leaf3 leaf
```

Remediation Steps

- Enforce server certificate pinning and signed response tokens.

Attack Path Analysis

HIGH S-7 — Diagnostic Agent Identity Spoofing

Component: Diagnostic Agent | **Risk Level:** High | **Finding:** S-7

flowchart TD

```

S7_root["Inject fraudulent diagnostic results into multi-agent pipeline via Diagnostic Agent identity spoofing"]
S7_or1["OR"]
S7_leaf1["Obtain or forge Diagnostic Agent identity key for inter-agent result signing"]
S7_leaf2["Craft fraudulent diagnostic result message with spoofed agent identity fields"]
S7_leaf3["Inject forged result into Inter-Agent Communication Channel before origin validation"]

```

```

S7_root --> S7_or1
S7_or1 --> S7_leaf1
S7_or1 --> S7_leaf2
S7_or1 --> S7_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class S7_root goal
class S7_or1 orGate
class S7_leaf1,S7_leaf2,S7_leaf3 leaf

```

Remediation Steps

- Sign all inter-agent result messages with agent-specific identity keys.

Attack Path Analysis

HIGH S-8 — Treatment Planner Agent Identity Spoofing

Component: Treatment Planner Agent | **Risk Level:** High | **Finding:** S-8

flowchart TD

```
S8_root["Inject malicious treatment plans into clinical pipeline via Treatment Planner Agent identity spoofing"]
S8_or1{"OR"}
S8_leaf1["Obtain or forge Treatment Planner Agent identity key for treatment plan signing"]
S8_leaf2["Craft adversarial treatment plan message with spoofed agent identity fields"]
S8_leaf3["Deliver forged treatment plan to Supervisor Orchestrator before origin verification"]
```

```
S8_root --> S8_or1
S8_or1 --> S8_leaf1
S8_or1 --> S8_leaf2
S8_or1 --> S8_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class S8_root goal
class S8_or1 orGate
class S8_leaf1,S8_leaf2,S8_leaf3 leaf
```

Remediation Steps

- Sign all treatment plan outputs with agent-specific identity keys.

Attack Path Analysis

HIGH S-9 — Clinical MCP Tool Server Spoofing

Component: Clinical MCP Tool Server | **Risk Level:** High | **Finding:** S-9

flowchart TD

```
S9_root["Return malicious FHIR tool results to specialist agents via spoofed MCP Tool Server"]
S9_or1["OR"]
S9_leaf1["Intercept tool call from agent and respond with rogue server lacking identity token"]
S9_leaf2["Compromise MCP Tool Server DNS resolution to redirect tool calls to attacker-controlled endpoint"]
S9_leaf3["Return adversarially crafted FHIR data to agent before response integrity check"]
```

```
S9_root --> S9_or1
S9_or1 --> S9_leaf1
S9_or1 --> S9_leaf2
S9_or1 --> S9_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class S9_root goal
class S9_or1 orGate
class S9_leaf1,S9_leaf2,S9_leaf3 leaf
```

Remediation Steps

- Authenticate MCP Tool Server responses. Implement response integrity checks.

HIGH T-1 — Clinical Recommendation Response Tampering in Transit

Component: Physician Clinical Portal | **Risk Level:** High | **Finding:** T-1

flowchart TD

```
T1_root["Alter clinical recommendations displayed to physician via in-transit tampering"]
T1_or1["OR"]
T1_leaf1["Position man-in-the-middle between Supervisor Orchestrator and Physician Clinical Portal"]
T1_leaf2["Intercept unsigned recommendation response and modify clinical content"]
T1_leaf3["Forward tampered recommendation to portal for display to physician"]
```

```
T1_root --> T1_or1
T1_or1 --> T1_leaf1
T1_or1 --> T1_leaf2
T1_or1 --> T1_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T1_root goal
class T1_or1 orGate
class T1_leaf1,T1_leaf2,T1_leaf3 leaf
```

Remediation Steps

- Implement end-to-end message signing for recommendation responses.

HIGH T-12 — Medical Literature Vector Index Embedding Poisoning

Component: Medical Literature Vector Index | **Risk Level:** High | **Finding:** T-12

flowchart TD

```
T12_root["Corrupt Treatment Planner Agent literature retrieval via adversarial embedding injection in vector index"]
T12_or1["OR"]
T12_leaf1["Gain write access to Medical Literature Vector Index and inject adversarial embeddings"]
T12_leaf2["Craft embedding vectors that appear near legitimate treatment query embeddings"]
T12_leaf3["Cause Treatment Planner Agent to retrieve and incorporate adversarial literature"]
```

```
T12_root --> T12_or1
T12_or1 --> T12_leaf1
T12_or1 --> T12_leaf2
T12_or1 --> T12_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T12_root goal
class T12_or1 orGate
class T12_leaf1,T12_leaf2,T12_leaf3 leaf
```

Remediation Steps

- Implement document provenance attestation before indexing. Apply anomaly detection on retrieval patterns.

Attack Path Analysis

HIGH T-14 — EHR Ingestion Queue Event Tampering

Component: EHR Ingestion Queue | **Risk Level:** High | **Finding:** T-14

flowchart TD

```
T14_root["Inject false patient data into FHIR store via EHR Ingestion Queue event tampering"]
T14_or1{"OR"}
T14_leaf1["Gain write access to ingestion queue and modify enqueued EHR event payload"]
T14_leaf2["Exploit absent message integrity signatures to tamper with event fields in transit"]
T14_leaf3["Cause false patient record to propagate into FHIR Resource Store via normalization process"]
```

```
T14_root --> T14_or1
T14_or1 --> T14_leaf1
T14_or1 --> T14_leaf2
T14_or1 --> T14_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T14_root goal
class T14_or1 orGate
class T14_leaf1,T14_leaf2,T14_leaf3 leaf
```

Remediation Steps

- Implement message integrity signatures on all enqueued EHR events. Validate event integrity at dequeue.

HIGH T-15 — Clinical Audit Log Tampering**Component:** Clinical Audit Log | **Risk Level:** High | **Finding:** T-15

flowchart TD

```

T15_root["Cover tracks for unauthorized actions by tampering with Clinical Audit Log decision entries"]
T15_or1["OR"]
T15_leaf1["Obtain write credentials to Clinical Audit Log storage without per-write integrity receipts"]
T15_leaf2["Delete or modify existing decision log entries to remove evidence of unauthorized actions"]
T15_leaf3["Inject false audit entries creating misleading evidence trail for forensic investigators"]

```

```

T15_root --> T15_or1
T15_or1 --> T15_leaf1
T15_or1 --> T15_leaf2
T15_or1 --> T15_leaf3

```

```

classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333

```

```

class T15_root goal
class T15_or1 orGate
class T15_leaf1,T15_leaf2,T15_leaf3 leaf

```

Remediation Steps

- Implement append-only audit log storage with cryptographic chaining.

HIGH T-2 — Patient Summary Tampering

Component: Patient Summary Generator | **Risk Level:** High | **Finding:** T-2

flowchart TD

```
T2_root["Inject dangerous clinical guidance into patient communications via summary tampering"]
T2_or1{"OR"}
T2_leaf1["Gain access to summary generation pipeline and modify summary content before delivery"]
T2_leaf2["Intercept summary in transit between generator and patient endpoint"]
T2_leaf3["Modify summary payload to include false clinical instructions or contraindicated guidance"]
```

```
T2_root --> T2_or1
T2_or1 --> T2_leaf1
T2_or1 --> T2_leaf2
T2_or1 --> T2_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T2_root goal
class T2_or1 orGate
class T2_leaf1,T2_leaf2,T2_leaf3 leaf
```

Remediation Steps

- Implement integrity verification of summary content before delivery.

Attack Path Analysis

HIGH T-4 — Supervisor Orchestrator Delegation Logic Tampering

Component: Supervisor Orchestrator | **Risk Level:** High | **Finding:** T-4

flowchart TD

```
T4_root["Corrupt clinical outputs by tampering with Supervisor Orchestrator delegation logic"]
T4_or1{{"OR"}}
T4_leaf1["Compromise Supervisor Orchestrator process and modify delegation routing logic"]
T4_leaf2["Inject adversarial configuration that routes tasks to attacker-controlled agent implementations"]
T4_leaf3["Corrupt aggregation logic to modify specialist results before returning recommendation"]
```

```
T4_root --> T4_or1
T4_or1 --> T4_leaf1
T4_or1 --> T4_leaf2
T4_or1 --> T4_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T4_root goal
class T4_or1 orGate
class T4_leaf1,T4_leaf2,T4_leaf3 leaf
```

Remediation Steps

- Implement immutable audit logging of all orchestration decisions. Use runtime integrity monitoring.

HIGH T-5 — Diagnostic Agent Tool Call Tampering

Component: Diagnostic Agent | **Risk Level:** High | **Finding:** T-5

flowchart TD

```
T5_root["Corrupt Diagnostic Agent tool operations via tool call request tampering"]
T5_or1{"OR"}
T5_leaf1["Intercept Diagnostic Agent outbound tool call and modify FHIR operation parameters"]
T5_leaf2["Compromise agent process to inject adversarial inputs into guideline retrieval query"]
T5_leaf3["Bypass tool call schema validation at MCP Tool Server to execute unauthorized FHIR write"]
```

```
T5_root --> T5_or1
T5_or1 --> T5_leaf1
T5_or1 --> T5_leaf2
T5_or1 --> T5_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T5_root goal
class T5_or1 orGate
class T5_leaf1,T5_leaf2,T5_leaf3 leaf
```

Remediation Steps

- Validate and sanitize all outgoing tool call parameters. Implement allowlist-based tool call schemas.

Attack Path Analysis

HIGH T-6 — Treatment Planner Agent Input Tampering

Component: Treatment Planner Agent | **Risk Level:** High | **Finding:** T-6

flowchart TD

```
T6_root["Corrupt treatment plan generation via Treatment Planner Agent input tampering"]
T6_or1{"OR"}
T6_leaf1["Intercept literature retrieval query and inject adversarial search parameters"]
T6_leaf2["Compromise agent process to modify tool call payload before MCP Tool Server execution"]
T6_leaf3["Bypass schema-enforced tool call validation to execute unauthorized FHIR operations"]
```

```
T6_root --> T6_or1
T6_or1 --> T6_leaf1
T6_or1 --> T6_leaf2
T6_or1 --> T6_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T6_root goal
class T6_or1 orGate
class T6_leaf1,T6_leaf2,T6_leaf3 leaf
```

Remediation Steps

- Apply strict input validation to all retrieval queries. Implement schema-enforced tool call validation.

Attack Path Analysis

HIGH T-8 — Clinical LLM Prompt Input Tampering

Component: Clinical LLM | **Risk Level:** High | **Finding:** T-8

flowchart TD

```
T8_root["Corrupt Clinical LLM reasoning completions via adversarial prompt input tampering at API Gateway"]
T8_or1{"OR"}
T8_leaf1["Compromise API Gateway to intercept and modify prompt before forwarding to Clinical LLM"]
T8_leaf2["Exploit absent prompt input validation to inject adversarial tokens into assembled context"]
T8_leaf3["Modify prompt content to cause Clinical LLM to produce clinically dangerous reasoning output"]
```

```
T8_root --> T8_or1
T8_or1 --> T8_leaf1
T8_or1 --> T8_leaf2
T8_or1 --> T8_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

```
class T8_root goal
class T8_or1 orGate
class T8_leaf1,T8_leaf2,T8_leaf3 leaf
```

Remediation Steps

- Implement prompt input validation and sanitization at the API Gateway. Log all prompt inputs.

HIGH T-9 — Risk Stratification Model Fine-Tuning Data Tampering

Component: Risk Stratification Model | **Risk Level:** High | **Finding:** T-9

flowchart TD

```
T9_root["Cause biased clinical risk scores via Risk Stratification Model fine-tuning data tampering"]
T9_or1["OR"]
T9_leaf1["Gain write access to fine-tuning training dataset and inject adversarially labeled samples"]
T9_leaf2["Tamper with inference inputs to model by intercepting API Gateway forwarding path"]
T9_leaf3["Corrupt training labels for high-risk patient samples to cause systematic misclassification"]
```

```
T9_root --> T9_or1
T9_or1 --> T9_leaf1
T9_or1 --> T9_leaf2
T9_or1 --> T9_leaf3
```

```
classDef goal fill:#ff6b6b,stroke:#333,stroke-width:2px,color:#fff
classDef orGate fill:#4ecdc4,stroke:#333,stroke-width:2px,color:#fff
classDef leaf fill:#95e1d3,stroke:#333,stroke-width:2px,color:#333
```

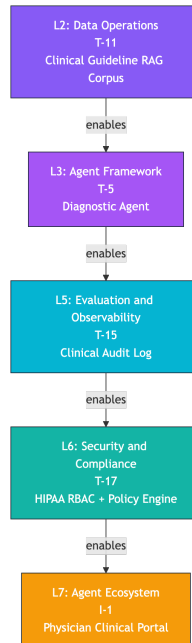
```
class T9_root goal
class T9_or1 orGate
class T9_leaf1,T9_leaf2,T9_leaf3 leaf
```

Remediation Steps

- Implement training data provenance attestation. Validate all inference inputs against canonical schema.

Cross-Layer Attack Chain Analysis

Cross-Layer Attack Chain Analysis

CRITICAL CHAIN-001 L2 → L3 → L5 → L6 → L7 **RAG Corpus Poisoning to False Clinical Recommendation via Agent Hijack**


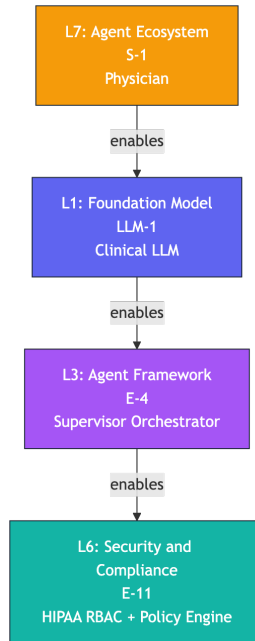
Attack Progression

An adversary initiates the chain by injecting adversarially crafted embeddings into the Clinical Guideline RAG Corpus (L2 — Data Operations). This poisoning attack corrupts the retrieval index with malicious clinical guidance documents that appear legitimate but encode attacker-preferred diagnostic recommendations. The RAG corpus lies upstream of all Diagnostic Agent guideline lookups and is unauthenticated for provenance at the embedding level. The corrupted corpus triggers manipulation of Diagnostic Agent (L3 — Agent Framework) tool call behavior. When the Diagnostic Agent issues a guideline retrieval query, the poisoned corpus surfaces adversarial guidance, which the agent incorporates into its tool call parameters and specialist diagnostic outputs forwarded through the Inter-Agent Communication Channel. The agent's decision-making is subverted without any individual component being overtly compromised. The compromised diagnostic output enables Clinical Audit Log (L5 — Evaluation and Observability) tampering. An attacker aware of the attack progression covers tracks by suppressing or modifying the Diagnostic Agent's decision log entries before they propagate to the Outcomes Telemetry store, eliminating the forensic trail of the poisoning event. The audit trail suppression enables HIPAA RBAC + Policy Engine (L6 — Security and Compliance) policy tampering. Without a complete audit trail, anomalous access patterns associated with the attack are not flagged, allowing the attacker to modify RBAC policies to grant elevated access to the compromised clinical workflow. Finally, the compounded upstream manipulations manifest as false clinical recommendation disclosure at the Physician Clinical Portal (L7 — Agent Ecosystem) — a physician receives a recommendation grounded in adversarial guidelines, presented with full apparent clinical authority.

Remediating T-15 (Clinical Audit Log tampering — the intermediate cascade at L5) would disconnect the upstream diagnostic chain from the downstream security control bypass, as the audit suppression is the structural link enabling the L6 RBAC manipulation.

Impacted Findings: T-11, T-5, T-15, T-17, I-1

Cross-Layer Attack Chain Analysis

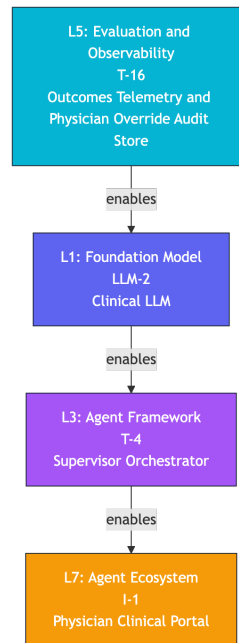
CRITICAL CHAIN-002 L7 → L1 → L3 → L6 **Prompt Injection to Orchestrator
Privilege Escalation via Foundation Model**


Attack Progression

The chain initiates at the Agent Ecosystem boundary (L7) where an attacker spoofs a legitimate physician identity to gain authenticated access to the Physician Clinical Portal. The spoofed session carries valid-appearing credentials that bypass initial authentication gates, establishing a foothold in the clinical query pipeline under a trusted physician identity. The spoofed physician session shifts the attack surface to the Foundation Model layer (L1), where the attacker crafts malicious clinical queries containing adversarial prompt injection payloads embedded within the apparent clinical question. When forwarded through the API Gateway to the Clinical LLM, the injected instructions direct the model to emit completions containing embedded system commands or escalated instruction patterns that the Supervisor Orchestrator's prompt parser may interpret as trusted control signals. The manipulated LLM completion enables Supervisor Orchestrator privilege escalation (L3 — Agent Framework). The orchestrator, receiving a completion that appears to originate from the trusted Clinical LLM inference endpoint, may execute embedded instructions that bypass its own RBAC compliance check logic, effectively granting the attacker's session elevated orchestration authority — including the ability to issue delegation commands beyond the spoofed physician's authorized scope. The orchestrator privilege escalation manifests as HIPAA RBAC + Policy Engine administrative compromise (L6 — Security and Compliance), where the now-escalated orchestrator session is used to modify RBAC policies or exploit the policy engine's trust in the orchestrator service account, creating durable unauthorized access. Remediating LLM-1 (prompt injection at L1 — the first intermediate cascade) breaks the chain by preventing the foundation model layer from converting the spoofed credential into an escalation payload.

Impacted Findings: S-1, LLM-1, E-4, E-11

Cross-Layer Attack Chain Analysis

CRITICAL CHAIN-003 L5 → L1 → L3 → L7 **Outcomes Telemetry Tampering to Model Drift via Learning Loop**


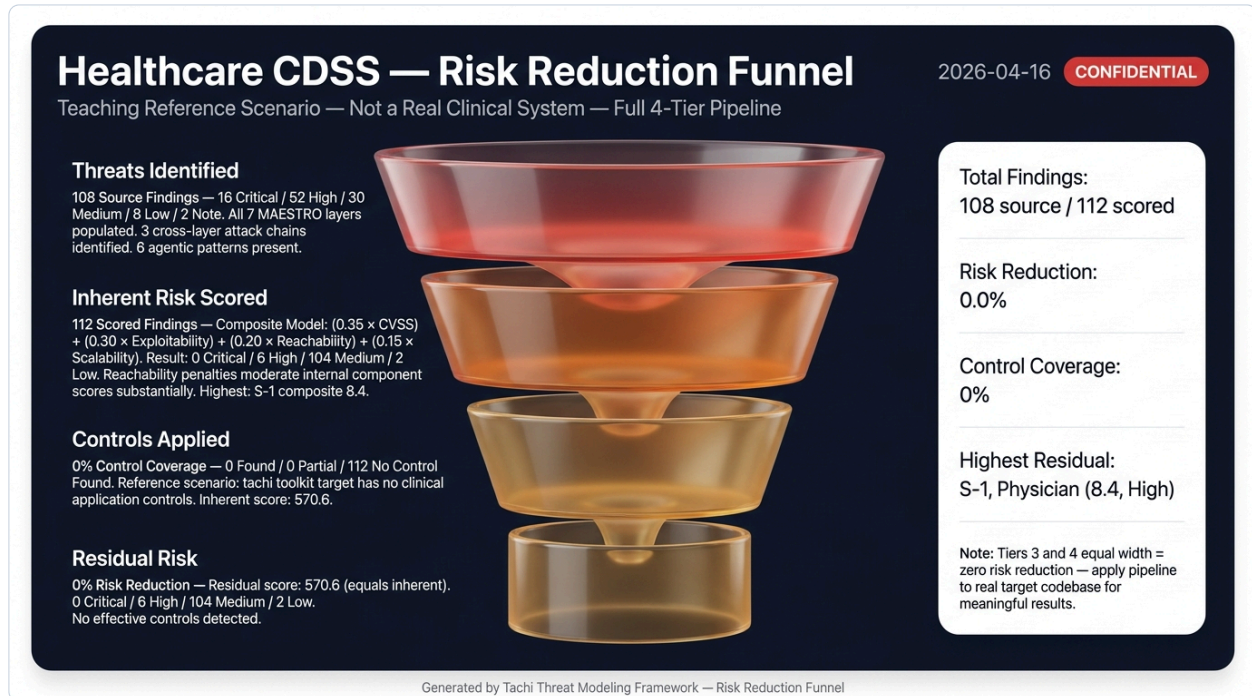
Attack Progression

The attack initiates at the Evaluation and Observability layer (L5) by tampering with the Outcomes Telemetry and Physician Override Audit Store. An adversary with write access to this store injects adversarially crafted physician-override signals — false feedback indicating that certain high-risk clinical recommendations were endorsed by physicians when they were not. This telemetry store is the primary feedback channel for the long-running learning loop that drives continual model re-training. The corrupted telemetry triggers data poisoning of the Clinical LLM (L1 — Foundation Model) during the next scheduled learning loop re-training cycle. The adversarial physician-override signals are incorporated as positive training examples, causing the model to drift toward systematically producing the attacker's preferred clinical outputs for specific patient presentations — a temporal attack that may not surface until weeks after the initial telemetry injection. The model drift enables Supervisor Orchestrator tampering (L3 — Agent Framework), where the corrupted Clinical LLM now returns biased completions that cause the orchestrator's aggregation logic to synthesize clinical recommendations that favor the attacker's preferred outcomes. The orchestrator's delegation decisions are themselves corrupted because the foundation model completion that informs them has been systematically shifted. The compounded corruption manifests as false clinical recommendation disclosure at the Physician Clinical Portal (L7 — Agent Ecosystem), where physicians receive systematically biased recommendations for specific patient cohorts — recommendations grounded in adversarially shifted model behavior that is indistinguishable from legitimate clinical AI output. Remediating T-16 (Outcomes Telemetry tampering at L5 — the initial

exploit) prevents the adversarial signals from ever reaching the learning loop, breaking the entire chain at its source before the model layer is affected.

Impacted Findings: T-16, LLM-2, T-4, I-1

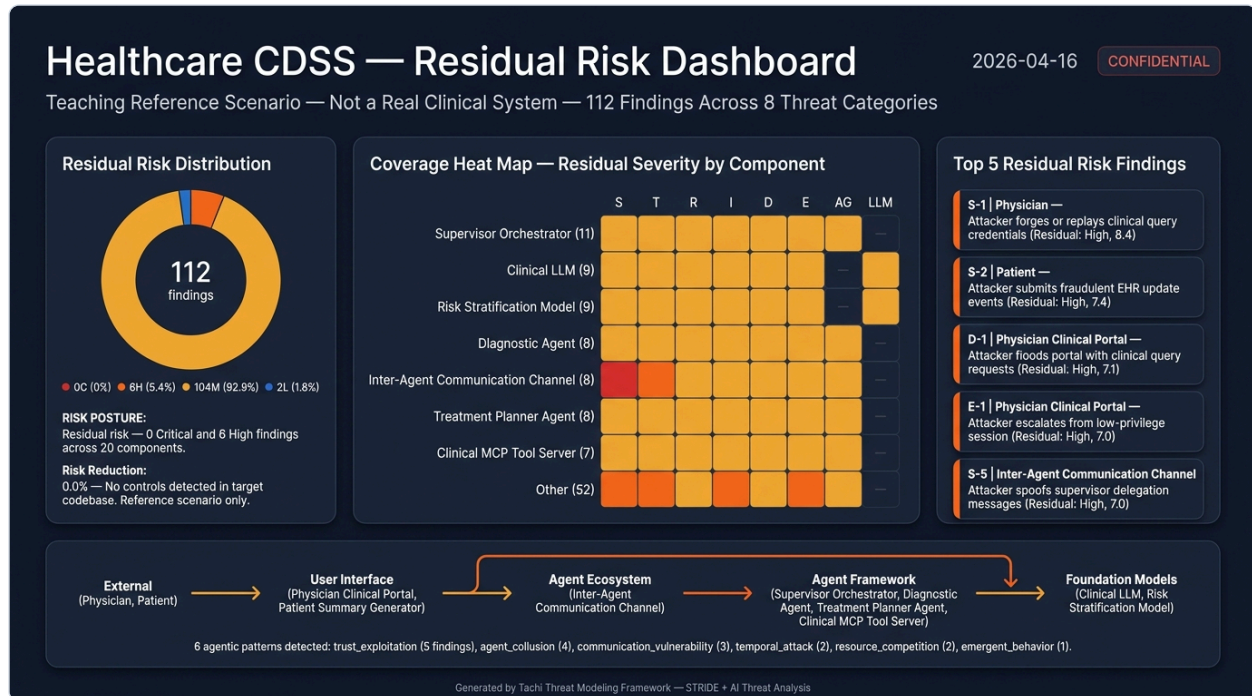
Risk Reduction Funnel



The Risk Reduction Funnel illustrates how the overall risk profile transforms through each stage of the assessment pipeline. The top tier shows all threats identified during the initial STRIDE and AI-specific threat analysis. The second tier reflects severity recalibration after quantitative scoring, where composite scores incorporating CVSS, exploitability, scalability, and reachability may shift initial severity ratings.

The third tier shows the impact of compensating controls detected in the codebase — existing mitigations that reduce effective risk. The bottom tier presents the final residual risk posture, representing the organization's actual exposure after accounting for all identified defenses. The sidebar provides key metrics at a glance, including the total risk reduction percentage, control coverage rate, and the highest-residual-risk finding requiring priority attention.

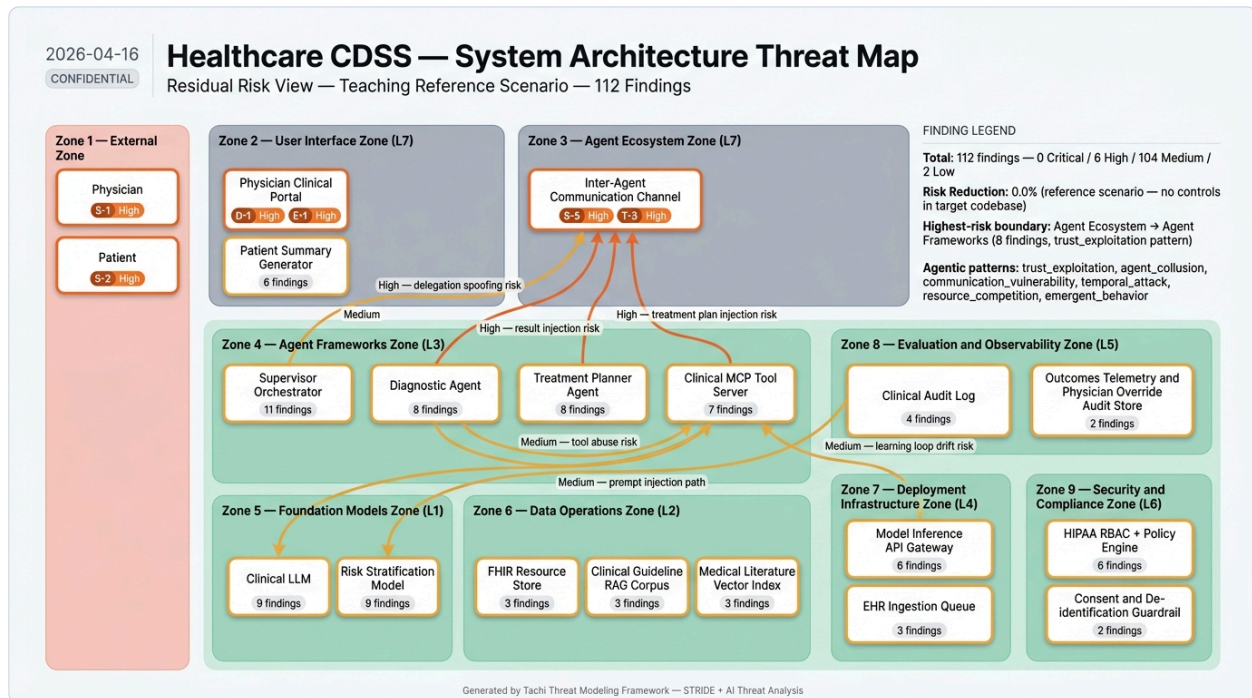
Risk Summary Dashboard



The Risk Summary Dashboard consolidates assessment results into three complementary views. The left panel displays the residual risk distribution across severity levels, showing how findings are distributed after compensating controls are applied.

The center panel presents a component-by-threat-category heat map, where each cell indicates the highest residual severity for that intersection of system component and STRIDE or AI threat category. This enables rapid identification of which components carry the highest concentration of risk. The right panel highlights the top findings by residual risk score, listing the specific threats that require the most immediate attention with their affected components and residual scores.

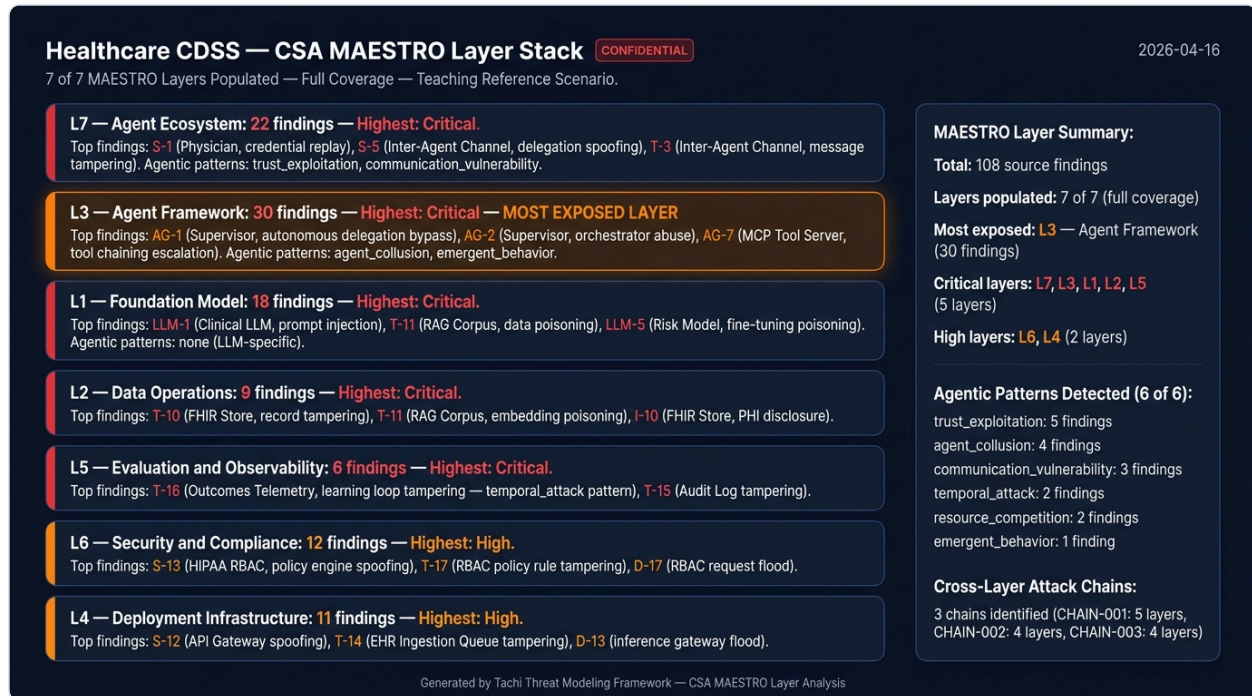
System Architecture



The System Architecture diagram maps identified threats directly onto the assessed system's component topology. Components are grouped within their trust boundaries — external/untrusted, application layer, and infrastructure/platform zones — with color coding reflecting the concentration and severity of findings at each location.

Threat badges on each component show the specific threat identifiers and their severity classifications. Data flow arrows illustrate the assessed communication paths between components, with trust boundary crossings highlighted as key attack surface areas where threats are most likely to be exploited. This spatial view complements the tabular findings detail by showing how threats cluster around specific architectural chokepoints.

MAESTRO Layer Risk Distribution



The MAESTRO Layer Risk Distribution diagram maps identified threats onto the seven-layer CSA MAESTRO framework for agentic AI systems. Each horizontal band represents an architectural layer from Foundation Model (L1) through Agent Ecosystem (L7), showing the finding count and highest severity at each layer. The most-exposed layer is visually highlighted.

This view enables security leaders to quickly identify which architectural layers of the AI stack carry the most risk exposure and prioritize remediation efforts accordingly.

MAESTRO Component-Layer Heatmap



The MAESTRO Component-Layer Heatmap provides a granular view of how threats intersect specific system components with MAESTRO architectural layers. Each cell represents the highest-severity finding at the intersection of a component (row) and a MAESTRO layer (column).

This cross-tabulation identifies specific component-layer hotspots that require targeted remediation, complementing the aggregate layer view in the MAESTRO Stack diagram.

MAESTRO Layer Analysis

The following findings are grouped by their CSA MAESTRO framework architectural layer, providing a layer-oriented view of the threat landscape. Each layer represents a distinct level of the agentic AI system stack, from Foundation Model (L1) through Agent Ecosystem (L7). Findings within each layer are sorted by severity.

L1: Findings

L2: Findings

L3: Findings

L4: Findings

L5: Findings

L6: Findings

L7: Findings

L1 — Foundation Model (18 findings)

ID	Component	Severity	Threat
LLM-1	Clinical LLM	CRITICAL	An attacker may inject adversarial prompts into the clinical context window passed to the Clinical LLM via the API Gateway, causing the model to generate harmful, false, or clinically dangerous completions that the Supervisor Orchestrator incorporates into clinical recommendations.
T-8	Clinical LLM	HIGH	An attacker may tamper with the Clinical LLM prompt inputs forwarded by the API Gateway, injecting adversarial tokens that corrupt the clinical reasoning completion.
T-9	Risk Stratification Model	HIGH	An attacker may tamper with fine-tuning data or inference inputs to the Risk Stratification Model, causing systematically biased risk scores that lead to incorrect clinical decisions.
I-8	Clinical LLM	HIGH	The Clinical LLM may memorize and surface sensitive training data including patient records in its completions, disclosing PHI to agents that did not have authorization to access it.
I-9	Risk Stratification Model	HIGH	The Risk Stratification Model may leak patient cohort data from its fine-tuning training set through membership inference attacks or through overfitted responses that reveal individual patient characteristics.
D-8	Clinical LLM	HIGH	An attacker may exhaust Clinical LLM inference capacity through large prompt floods via the API Gateway, preventing legitimate clinical reasoning requests from being served.

E-8	Clinical LLM	HIGH	An attacker may exploit prompt injection in the Clinical LLM to gain elevated reasoning authority, causing the model to output instructions that the Supervisor Orchestrator interprets as authorized system commands with elevated privilege.
LLM-2	Clinical LLM	HIGH	An adversary may poison the training data or fine-tuning feedback incorporated into the Clinical LLM via the Outcomes Telemetry learning loop, causing the model to produce systematically biased or manipulated clinical completions after re-training.
LLM-4	Risk Stratification Model	HIGH	An attacker may craft adversarial patient record inputs passed to the Risk Stratification Model to generate manipulated risk scores, causing incorrect clinical triage and resource allocation decisions.
LLM-5	Risk Stratification Model	HIGH	An adversary may poison the supervised fine-tuning dataset used to train the Risk Stratification Model, embedding adversarial patterns that cause the model to systematically misclassify high-risk patients as low-risk after re-training.
LLM-6	Risk Stratification Model	HIGH	An adversary may conduct membership inference attacks against the Risk Stratification Model to determine which patients were included in the fine-tuning dataset, violating patient privacy even when the model is deployed without direct data access.
S-10	Clinical LLM	MEDIUM	An attacker may spoof Clinical LLM completion responses by intercepting the API Gateway channel, returning fabricated clinical reasoning outputs.
S-11	Risk Stratification Model	MEDIUM	An attacker may spoof Risk Stratification Model outputs to inject false risk stratification results, causing the Diagnostic Agent to base decisions on falsified patient risk levels.
R-10	Clinical LLM	MEDIUM	The Clinical LLM may fail to maintain non-repudiable logs of which prompts were submitted and which completions were returned, making it impossible to audit the basis of clinical reasoning outputs.
R-11	Risk Stratification Model	MEDIUM	The Risk Stratification Model may fail to maintain non-repudiable records of which patient inputs produced which risk scores, preventing audit of risk stratification decisions.
D-9	Risk Stratification Model	MEDIUM	An attacker may target the Risk Stratification Model with high-volume risk inference requests, saturating the model's inference capacity and degrading diagnostic availability.
E-9	Risk Stratification Model	MEDIUM	An attacker may manipulate Risk Stratification Model inputs to produce falsely elevated risk scores that trigger automated escalation workflows, gaining access to high-privilege clinical interventions.
LLM-3	Clinical LLM	LOW	An adversary may extract the Clinical LLM's learned clinical knowledge through repeated targeted queries via the API Gateway, enabling model theft or reconstruction of proprietary medical AI capabilities.

L2 — Data Operations (9 findings)

ID	Component	Severity	Threat
T-10	FHIR Resource Store	CRITICAL	An attacker with access to the FHIR Resource Store may tamper with patient records, injecting false clinical data that corrupts all downstream clinical decision processes.
T-11	Clinical Guideline RAG Corpus	CRITICAL	An attacker may poison the Clinical Guideline RAG Corpus by injecting adversarially crafted guideline embeddings,

			causing the RAG retrieval to surface malicious clinical guidance to the Diagnostic Agent.
I-10	FHIR Resource Store	CRITICAL	Patient PHI stored in the FHIR Resource Store may be disclosed through unauthorized read operations by agents with overly broad access, SQL/FHIR injection attacks, or missing PHI encryption at rest.
T-12	Medical Literature Vector Index	HIGH	An attacker may inject malicious vector embeddings into the Medical Literature Vector Index, causing Treatment Planner Agent to retrieve and incorporate adversarial literature recommendations.
D-10	FHIR Resource Store	HIGH	An attacker may execute resource-exhausting FHIR queries or write floods against the FHIR Resource Store, degrading availability for all components dependent on patient record retrieval.
I-11	Clinical Guideline RAG Corpus	LOW	The Clinical Guideline RAG Corpus may inadvertently index sensitive patient data if clinical guidelines incorporate patient examples, disclosing this data through semantic retrieval to the Diagnostic Agent.
I-12	Medical Literature Vector Index	LOW	The Medical Literature Vector Index may expose sensitive research data or cross-contaminate patient-specific retrieval results if insufficient session isolation is implemented.
D-11	Clinical Guideline RAG Corpus	LOW	An attacker may issue retrieval floods against the Clinical Guideline RAG Corpus, saturating retrieval capacity and preventing the Diagnostic Agent from accessing clinical guidelines.
D-12	Medical Literature Vector Index	LOW	An attacker may flood the Medical Literature Vector Index with excessive retrieval queries, degrading vector search availability for the Treatment Planner Agent.

L3 — Agent Framework (31 findings)

ID	Component	Severity	Threat
S-6	Supervisor Orchestrator	CRITICAL	An attacker may impersonate the Supervisor Orchestrator to issue unauthorized delegation commands to specialist agents, bypassing orchestration controls and routing fabricated clinical tasks.
T-7	Clinical MCP Tool Server	CRITICAL	An attacker who compromises the Clinical MCP Tool Server may tamper with FHIR read/write operations, modifying patient records without authorization or returning corrupted data to agents.
I-7	Clinical MCP Tool Server	CRITICAL	The Clinical MCP Tool Server may expose PHI from FHIR read operations to unauthorized agents through insufficient access controls on tool results, or through overly broad FHIR queries returning more data than requested.
E-7	Clinical MCP Tool Server	CRITICAL	A compromised agent may exploit the Clinical MCP Tool Server to escalate FHIR access beyond the calling agent's authorized scope, performing privileged FHIR operations (e.g., bulk data export, schema modifications) not authorized for the requesting agent.
AG-1	Supervisor Orchestrator	CRITICAL	The Supervisor Orchestrator may autonomously execute consequential clinical delegation commands without adequate human oversight, routing clinical tasks based on AI-generated orchestration logic that bypasses physician review or RBAC compliance checks.
AG-2	Supervisor Orchestrator	CRITICAL	A compromised Supervisor Orchestrator may abuse its privileged position as the delegation authority to issue

			unauthorized tool calls or FHIR operations through specialist agents, circumventing per-agent access controls by delegating to agents with broader permissions.
AG-7	Clinical MCP Tool Server	CRITICAL	A malicious or compromised agent may exploit the Clinical MCP Tool Server to perform privilege escalation via tool chaining — executing a sequence of individually-permitted FHIR operations that collectively achieves an unauthorized outcome (e.g., bulk patient data export or unauthorized record modification).
S-7	Diagnostic Agent	HIGH	An attacker may spoof the Diagnostic Agent's identity to inject fraudulent diagnostic results into the Inter-Agent Communication Channel, polluting the treatment planning process.
S-8	Treatment Planner Agent	HIGH	An attacker may spoof Treatment Planner Agent responses to inject malicious treatment plans into the inter-agent coordination flow.
S-9	Clinical MCP Tool Server	HIGH	An attacker may spoof the Clinical MCP Tool Server to return malicious tool results to Diagnostic Agent or Treatment Planner Agent, corrupting clinical decision inputs.
T-4	Supervisor Orchestrator	HIGH	An attacker who compromises the Supervisor Orchestrator may tamper with the delegation logic, routing clinical tasks to adversary-controlled specialist implementations or corrupting aggregated outputs before returning them to the portal.
T-5	Diagnostic Agent	HIGH	An attacker may tamper with the Diagnostic Agent's tool call requests to Clinical MCP Tool Server, injecting malicious FHIR operations or corrupting guideline retrieval queries.
T-6	Treatment Planner Agent	HIGH	An attacker may tamper with the Treatment Planner Agent's literature retrieval queries or tool calls, injecting adversarially crafted inputs that corrupt treatment plan generation.
R-6	Supervisor Orchestrator	HIGH	The Supervisor Orchestrator may fail to maintain non-repudiable records of which delegation commands it issued and which specialist results it aggregated, making agent accountability impossible.
R-9	Clinical MCP Tool Server	HIGH	The Clinical MCP Tool Server may fail to maintain non-repudiable records of which FHIR operations were executed in response to agent tool calls, making it impossible to trace patient record modifications to their source.
I-4	Supervisor Orchestrator	HIGH	The Supervisor Orchestrator aggregates sensitive patient data from FHIR, specialist results, and model outputs. A compromise may expose this aggregated clinical context, which is more sensitive than any individual component's data.
I-5	Diagnostic Agent	HIGH	The Diagnostic Agent may expose sensitive patient context retrieved from Clinical Guideline RAG Corpus and risk stratification results through tool call parameters, error responses, or insufficient isolation between patient sessions.
I-6	Treatment Planner Agent	HIGH	The Treatment Planner Agent may disclose sensitive patient data retrieved from the Medical Literature Vector Index through insufficient session isolation or unfiltered error responses.
D-4	Supervisor Orchestrator	HIGH	An attacker who compromises one specialist agent may flood the Supervisor Orchestrator with high-volume task results or error responses, causing resource exhaustion that renders the orchestrator unable to coordinate legitimate clinical queries.
D-5	Diagnostic Agent	HIGH	An attacker may target the Diagnostic Agent with resource-exhausting tool call floods or retrieval storms against the

			Clinical Guideline RAG Corpus, disrupting diagnostic capabilities for legitimate clinical queries.
D-7	Clinical MCP Tool Server	HIGH	An attacker who compromises an agent may flood the Clinical MCP Tool Server with excessive JSON-RPC tool calls or FHIR operations, exhausting server resources and denying tool access to legitimate agents.
E-4	Supervisor Orchestrator	HIGH	A compromised Supervisor Orchestrator may escalate its own privilege to bypass RBAC checks enforced by the HIPAA Policy Engine, or grant escalated permissions to specialist agents beyond their authorized scope.
E-5	Diagnostic Agent	HIGH	A compromised Diagnostic Agent may escalate beyond its authorized scope by issuing FHIR operations that exceed its data access permissions via the Clinical MCP Tool Server, accessing patient records outside the current clinical query.
E-6	Treatment Planner Agent	HIGH	A compromised Treatment Planner Agent may escalate its access to FHIR resources beyond the current patient's authorized scope through the Clinical MCP Tool Server.
AG-3	Diagnostic Agent	HIGH	The Diagnostic Agent may autonomously execute FHIR write operations via the Clinical MCP Tool Server beyond its authorized clinical scope, persisting adversarial or erroneous diagnostic data to patient records without physician authorization.
AG-4	Diagnostic Agent	HIGH	A compromised Diagnostic Agent may abuse the Clinical MCP Tool Server as a tool abuse vector, issuing malicious FHIR operations (bulk reads, unauthorized writes) that exceed the agent's authorized scope.
AG-5	Treatment Planner Agent	HIGH	The Treatment Planner Agent may autonomously incorporate adversarially retrieved medical literature into treatment plans without human validation, resulting in dangerous or contraindicated treatment recommendations delivered to physicians.
AG-6	Treatment Planner Agent	HIGH	A compromised Treatment Planner Agent may abuse the Clinical MCP Tool Server to perform unauthorized FHIR operations, writing false treatment prescriptions or accessing patient records outside the current patient scope.
R-7	Diagnostic Agent	MEDIUM	The Diagnostic Agent may deny issuing specific tool calls to the Clinical MCP Tool Server or deny the guideline retrieval queries it submitted, preventing investigation of erroneous diagnoses.
R-8	Treatment Planner Agent	MEDIUM	The Treatment Planner Agent may deny issuing specific literature retrieval queries or tool calls that contributed to harmful treatment plans, obstructing clinical accountability.
D-6	Treatment Planner Agent	MEDIUM	An attacker may exhaust Treatment Planner Agent resources through oversized literature retrieval queries or excessive tool call sequences, disrupting treatment planning for legitimate patients.

L4 — Deployment Infrastructure (9 findings)

ID	Component	Severity	Threat
T-14	EHR Ingestion Queue	HIGH	An attacker may tamper with EHR update events in the ingestion queue before normalization, injecting false patient data that propagates into the FHIR Resource Store.
I-14	EHR Ingestion Queue	HIGH	Patient EHR update events in the ingestion queue may be disclosed through insufficient queue access controls, allowing unauthorized parties to read enqueued patient records.

D-13	Model Inference API Gateway	HIGH	An attacker may saturate the Model Inference API Gateway through request floods, denying inference access to all agents dependent on foundation model capabilities.
S-12	Model Inference API Gateway	MEDIUM	An attacker may spoof the Model Inference API Gateway to intercept inference requests and return fabricated completions, bypassing the real foundation models.
T-13	Model Inference API Gateway	MEDIUM	An attacker may tamper with the Model Inference API Gateway configuration, rerouting inference requests to adversary-controlled model endpoints or modifying prompts before forwarding.
R-12	Model Inference API Gateway	MEDIUM	The Model Inference API Gateway may fail to maintain non-repudiable records of all inference requests forwarded to foundation models, making it impossible to reconstruct the chain of clinical AI decisions.
I-13	Model Inference API Gateway	MEDIUM	The Model Inference API Gateway may expose inference request logs containing patient PHI or clinical context through insufficient log access controls or log retention policies.
D-14	EHR Ingestion Queue	MEDIUM	An attacker may flood the EHR Ingestion Queue with malformed or oversized EHR events, causing queue saturation and blocking legitimate patient record ingestion.
E-10	Model Inference API Gateway	MEDIUM	An attacker who compromises the Model Inference API Gateway may escalate to access inference endpoints for models not authorized for the requesting agent, circumventing model-level access controls.

L5 — Evaluation and Observability (6 findings)

ID	Component	Severity	Threat
T-16	Outcomes Telemetry and Physician Override Audit Store	CRITICAL	An attacker may tamper with the Outcomes Telemetry and Physician Override Audit Store, injecting adversarial physician-override signals that corrupt the learning loop re-training process and cause model drift toward attacker-preferred outputs.
T-15	Clinical Audit Log	HIGH	An attacker who gains write access to the Clinical Audit Log may tamper with decision log entries, covering tracks for unauthorized actions or injecting false audit evidence.
I-15	Clinical Audit Log	HIGH	The Clinical Audit Log accumulates highly sensitive clinical decision trails. Unauthorized read access could disclose PHI, clinical reasoning, and agent decision patterns to adversaries.
I-16	Outcomes Telemetry and Physician Override Audit Store	HIGH	Physician override telemetry may contain implicit patient data. Unauthorized access to the Outcomes Telemetry store could disclose sensitive clinical patterns or be used for re-identification of de-identified training data.
D-15	Clinical Audit Log	MEDIUM	An attacker may flood the Clinical Audit Log with excessive log entries, causing disk exhaustion that prevents legitimate audit log writes and destroys accountability coverage.
D-16	Outcomes Telemetry and Physician Override Audit Store	MEDIUM	An attacker may flood the Outcomes Telemetry store with spurious override signals, degrading the learning loop's ability to incorporate legitimate physician feedback and corrupting model re-training.

L6 — Security and Compliance (11 findings)

ID	Component	Severity	Threat
S-13	HIPAA RBAC + Policy Engine	MEDIUM	An attacker may spoof the HIPAA RBAC + Policy Engine to issue false access-grant decisions to the Physician Clinical Portal, enabling unauthorized clinical data access.
S-14	Consent and De-identification Guardrail	MEDIUM	An attacker may spoof the Consent and De-identification Guardrail response, returning raw PHI to components that expected de-identified data, bypassing consent enforcement.
T-17	HIPAA RBAC + Policy Engine	MEDIUM	An attacker may tamper with RBAC policy rules in the policy engine, granting unauthorized access to clinical data or escalating privileges for compromised accounts.
T-18	Consent and De-identification Guardrail	MEDIUM	An attacker may tamper with the de-identification guardrail configuration, disabling or weakening de-identification rules to expose raw PHI to downstream components.
R-13	HIPAA RBAC + Policy Engine	MEDIUM	The HIPAA RBAC + Policy Engine may fail to maintain non-repudiable records of all access decisions, preventing post-incident review of which access grants were issued to which entities.
I-18	Consent and De-identification Guardrail	MEDIUM	The Consent and De-identification Guardrail may disclose raw PHI through implementation flaws in the de-identification process, or expose de-identification rule logic that enables re-identification attacks.
D-17	HIPAA RBAC + Policy Engine	MEDIUM	An attacker may flood the HIPAA RBAC + Policy Engine with access decision requests, causing policy engine unavailability and potentially blocking all clinical data access during the outage.
D-18	Consent and De-identification Guardrail	MEDIUM	An attacker may flood the Consent and De-identification Guardrail with PHI processing requests, saturating de-identification capacity and blocking access to patient records for legitimate clinical workflows.
E-11	HIPAA RBAC + Policy Engine	MEDIUM	An attacker who exploits a vulnerability in the HIPAA RBAC + Policy Engine may escalate to administrative access, modifying policy rules to grant themselves or other entities unauthorized clinical data access.
E-12	Consent and De-identification Guardrail	MEDIUM	An attacker who compromises the Consent and De-identification Guardrail may escalate to bypass consent enforcement, accessing raw PHI without the patient's consent for unauthorized clinical or research purposes.
I-17	HIPAA RBAC + Policy Engine	LOW	The HIPAA RBAC + Policy Engine may leak access control policies through detailed error messages or API responses, enabling attackers to enumerate permissions and plan privilege escalation.

L7 — Agent Ecosystem (23 findings)

ID	Component	Severity	Threat
S-1	Physician	CRITICAL	An attacker may impersonate a legitimate physician by replaying or forging clinical query credentials, gaining unauthorized access to clinical recommendation views and patient data.
S-5	Inter-Agent Communication Channel	CRITICAL	An attacker who gains access to the inter-agent message bus may spoof supervisor delegation messages, causing specialist agents to act on forged orchestration commands.
T-3	Inter-Agent Communication Channel	CRITICAL	An attacker with access to the inter-agent message bus may tamper with delegation messages or specialist results in

			transit, corrupting clinical reasoning across the multi-agent pipeline.
I-3	Inter-Agent Communication Channel	CRITICAL	Sensitive clinical context including patient PHI and clinical reasoning may be disclosed through the inter-agent message bus if messages are transmitted without encryption or if channel access is insufficiently restricted.
S-2	Patient	HIGH	An attacker may submit fraudulent EHR update events by spoofing a patient identity, injecting false patient records into the ingestion pipeline.
S-3	Physician Clinical Portal	HIGH	An attacker may spoof the Physician Clinical Portal to intercept clinical recommendation responses from the Supervisor Orchestrator, receiving sensitive patient data intended for legitimate physicians.
T-1	Physician Clinical Portal	HIGH	An attacker may tamper with clinical recommendation responses in transit between Supervisor Orchestrator and the Physician Clinical Portal, altering displayed recommendations without physician awareness.
T-2	Patient Summary Generator	HIGH	An attacker with access to the summary generation pipeline may tamper with patient-facing summaries, injecting dangerous or false clinical guidance into patient communications.
R-5	Inter-Agent Communication Channel	HIGH	The Inter-Agent Communication Channel may fail to provide non-repudiable records of all delegation messages and specialist results, allowing agents to deny actions taken during the coordination flow.
I-1	Physician Clinical Portal	HIGH	Sensitive clinical recommendation data including patient PHI may be disclosed through the Physician Clinical Portal via insecure HTTPS configuration, excessive error messages, or missing access controls on recommendation views.
I-2	Patient Summary Generator	HIGH	Patient-facing summaries may inadvertently include sensitive clinical details beyond the authorized disclosure scope, or may be delivered to wrong patients due to missing identity validation.
D-1	Physician Clinical Portal	HIGH	An attacker may flood the Physician Clinical Portal with clinical query requests, degrading availability for legitimate physicians during critical clinical decision periods.
D-3	Inter-Agent Communication Channel	HIGH	An attacker may flood the Inter-Agent Communication Channel with spurious delegation messages, starving legitimate specialist agent task processing and disrupting the multi-agent coordination flow.
E-1	Physician Clinical Portal	HIGH	An attacker who gains access to a low-privilege physician session may escalate to access clinical data belonging to other physicians or patients by exploiting broken access controls in the portal's recommendation view logic.
E-2	Patient Summary Generator	HIGH	An attacker may exploit the Patient Summary Generator to request summaries for patients other than the authorized recipient, escalating access to unauthorized patient records.
E-3	Inter-Agent Communication Channel	HIGH	An attacker who compromises the Inter-Agent Communication Channel may escalate channel access to issue supervisor-level delegation commands to specialist agents, bypassing the Supervisor Orchestrator's authority and performing unauthorized clinical operations.
AG-8	Inter-Agent Communication Channel	HIGH	A compromised or rogue agent may abuse the Inter-Agent Communication Channel to flood specialist agents with excessive delegation messages, executing a resource exhaustion attack that disrupts multi-agent coordination across all clinical sessions.

S-4	Patient Summary Generator	MEDIUM	An attacker may spoof the Patient Summary Generator endpoint to intercept patient-facing summaries containing sensitive clinical recommendations.
R-1	Physician	MEDIUM	A physician may deny issuing a clinical query or claim that a recommendation view they acted upon was different from what the system recorded, creating liability disputes.
R-3	Physician Clinical Portal	MEDIUM	The Physician Clinical Portal may fail to provide non-repudiable records of which clinical recommendations were displayed to a physician, making it impossible to reconstruct the basis for a physician's clinical decision.
D-2	Patient Summary Generator	MEDIUM	An attacker may flood the Patient Summary Generator with spurious summary requests, degrading availability for legitimate patient summary delivery.
R-2	Patient	LOW	A patient may deny submitting EHR update events that were used as the basis for clinical decisions, complicating audit trails.
R-4	Patient Summary Generator	LOW	The Patient Summary Generator may fail to maintain non-repudiable records of summaries delivered to patients, creating gaps in clinical accountability.

107 findings across 7 MAESTRO layers | Sorted by severity (critical first)

Detailed Findings

Findings Detail — Residual Risk

Findings Detail — Residual Risk

HIGH S-1

Physician

Attacker replays or forges clinical query credentials

Implement multi-factor authentication (MFA) and credential replay protection for the physician authentication endpoint. Deploy a short-lived JWT or OAuth 2.0 token scheme with cryptographic binding to session context. Add token replay detection using a nonce or jti claim validated against a server-side token store.

Residual: 8.4 | Control: No Control Found

HIGH S-2

Patient

Attacker submits fraudulent EHR update events

Implement patient identity verification with signed event envelopes on the EHR ingestion endpoint. Each incoming EHR update event should carry a verifiable patient identity token (e.g., SMART on FHIR patient context) and a message authentication code preventing tampering. Deploy input schema validation to reject malformed or unexpected event structures.

Residual: 7.4 | Control: No Control Found

HIGH D-1

Physician Clinical Portal

Attacker floods portal with clinical query requests

Implement request rate limiting on the physician clinical portal API endpoints. Configure a per-IP and per-session rate limiter with thresholds calibrated to expected clinical usage patterns. Add a circuit breaker wrapping the downstream CDSS orchestration layer to prevent cascade failures under load.

Residual: 7.1 | Control: No Control Found

HIGH E-1

Physician Clinical Portal

Attacker escalates from low-privilege session

Implement role-based access control (RBAC) enforcing per-physician data scope on all portal data retrieval endpoints. Add resource ownership validation that prevents horizontal privilege escalation to other physicians' or patients' data. Every data fetch endpoint must assert that the requesting session's physician ID matches the requested resource scope.

Residual: 7.0 | Control: No Control Found

HIGH S-5

Inter-Agent Communication Channel

Attacker spoofs supervisor delegation messages

Implement message authentication on the inter-agent communication channel. Each delegation message must carry a cryptographic signature from the originating supervisor agent, verified by the receiving specialist agent before execution. Use a shared asymmetric key infrastructure where the supervisor holds the private signing key and specialist agents hold the corresponding verification key.

Residual: 7.0 | Control: No Control Found

HIGH T-3

Inter-Agent Communication Channel

Attacker tampers with delegation messages in transit

Implement message integrity protection on all inter-agent delegation messages and specialist results. Encrypt the message bus channel using TLS with mutual authentication, and add per-message HMAC integrity tokens that detect tampering in transit. Log all message integrity failures to the clinical audit log.

Residual: 7.0 | Control: No Control Found

MEDIUM AG-8

Inter-Agent Communication Channel

Compromised agent abuses inter-agent channel

Implement per-agent message quotas and channel-level rate limiting to prevent resource exhaustion by a compromised agent. Each agent instance should have a configurable message-per-second budget on the inter-agent bus. Deploy a circuit breaker that isolates an agent flooding the channel, preventing cascade to downstream specialist agents.

Residual: 6.8 | Control: No Control Found

MEDIUM D-3

Inter-Agent Communication Channel

Delegation message flood starves specialist agents

Implement channel-level message rate limiting and backpressure on the inter-agent delegation bus. Set maximum delegation message ingestion rates and queue depth limits. Add message priority queuing so clinical-critical delegation messages are processed ahead of non-urgent agent coordination traffic.

Residual: 6.8 | Control: No Control Found

MEDIUM E-2

Patient Summary Generator

Attacker exploits summary generator for unauthorized patients

Implement patient-scope authorization on the Patient Summary Generator. All summary requests must be validated against the requesting session's authorized patient list. Add an ABAC policy check verifying that the requestor has an active care relationship with the requested patient before generating the summary.

Residual: 6.8 | Control: No Control Found

MEDIUM AGP-01

Inter-Agent Communication Channel

Multi-agent coordination creates potential for coordinated action

Implement behavioral monitoring for coordinated agent activity patterns. Deploy a cross-agent telemetry aggregator that detects statistical anomalies in multi-agent coordination (synchronized message timing, unusual delegation fan-out, correlated output deviations across specialist agents). Trigger human-in-the-loop review when collusion indicators are detected.

Residual: 6.7 | Control: No Control Found

MEDIUM E-8

Clinical LLM

Prompt injection causes elevated reasoning authority

Implement prompt input validation and output sanitization for the Clinical LLM inference endpoint. Add a prompt injection detection layer that scans input for known injection patterns before forwarding to the model. Enforce strict output schema validation to detect anomalous reasoning responses that deviate from expected clinical recommendation formats.

Residual: 6.6 | Control: No Control Found

MEDIUM E-3

Inter-Agent Communication Channel

Compromised channel escalates to supervisor-level authority

Implement least-privilege access controls on the inter-agent communication channel. Each agent should only be able to send message types appropriate to its role (specialist agents cannot send delegation messages; only the supervisor can initiate delegation). Enforce role-based message type restrictions at the bus level.

Residual: 6.6 | Control: No Control Found

MEDIUM T-8

Clinical LLM

Attacker tampers with prompt inputs forwarded by API Gateway

Implement request signing and integrity verification on prompts forwarded by the Model Inference API Gateway to the Clinical LLM. The gateway must attest that the prompt content has not been modified in transit from the originating agent. Add an HMAC on each prompt payload that the LLM endpoint verifies before processing.

Residual: 6.5 | Control: No Control Found

MEDIUM I-3

Inter-Agent Communication Channel

PHI disclosed through unencrypted inter-agent channel

Implement end-to-end encryption on the inter-agent communication channel for all messages containing PHI. Enforce TLS 1.3 on the transport layer and add application-layer field-level encryption for patient identifiers and clinical data payloads within delegation messages.

Residual: 6.4 | Control: No Control Found

MEDIUM E-7

Clinical MCP Tool Server

Compromised agent escalates to unauthorized FHIR operations

Implement tool-call authorization on the Clinical MCP Tool Server. All FHIR tool operations must be authorized against the requesting agent's permitted tool scope. Add a policy engine that validates tool call intent (operation type, resource type, patient scope) against the agent's declared role before executing.

Residual: 6.4 | Control: No Control Found

MEDIUM S-6

Supervisor Orchestrator

Attacker impersonates Supervisor Orchestrator

Implement cryptographic identity verification for the Supervisor Orchestrator. The orchestrator must present a verifiable identity credential (signed JWT or mutual TLS certificate) when establishing connections with specialist agents and when receiving connections from external components. Specialist agents must verify orchestrator identity before accepting delegation messages.

Residual: 6.4 | Control: No Control Found

MEDIUM D-13

Model Inference API Gateway

Request floods saturate inference gateway

Implement request rate limiting and adaptive throttling on the Model Inference API Gateway. Configure per-caller rate limits, total inference concurrency caps, and request queue depth limits. Add a circuit breaker that drops non-urgent inference requests when the gateway approaches capacity saturation.

Residual: 6.2 | Control: No Control Found

MEDIUM AG-7

Clinical MCP Tool Server

Tool chaining achieves unauthorized FHIR output

|

Residual: 6.2 | Control: No Control Found

MEDIUM T-7

Clinical MCP Tool Server

Compromised MCP Tool Server tampers with FHIR operations

|

Residual: 6.2 | Control: No Control Found

MEDIUM **D-2**

Patient Summary Generator

Spurious summary requests flood Patient Summary Generator

I

Residual: 6.2 | Control: No Control Found

MEDIUM **AG-2**

Supervisor Orchestrator

Compromised orchestrator abuses delegation authority

I Implement delegation authority limits on the Supervisor Orchestrator. The orchestrator's delegation permissions should be defined at deployment time and enforced at runtime — the orchestrator cannot grant capabilities it does not possess. Add a human-in-the-loop checkpoint for high-impact clinical delegations (e.g., treatment recommendations above a risk threshold).

Residual: 6.1 | Control: No Control Found

MEDIUM **D-17**

HIPAA RBAC + Policy Engine

RBAC request flood causes policy engine unavailability

I

Residual: 6.1 | Control: No Control Found

MEDIUM **I-1**

Physician Clinical Portal

PHI disclosed via insecure HTTPS config or error messages

I Enforce HTTPS with HSTS on the Physician Clinical Portal and configure Content Security Policy to prevent information leakage through error responses. Implement generic error handling that does not expose PHI or stack traces. Add X-Content-Type-Options, X-Frame-Options, and Referrer-Policy headers.

Residual: 6.1 | Control: No Control Found

MEDIUM **LLM-4**

Risk Stratification Model

Adversarial patient records manipulate risk scores

I Implement adversarial input detection for the Risk Stratification Model. Add a pre-inference validation layer that checks incoming patient record feature vectors for statistical anomalies indicative of adversarial perturbation. Log detected anomalies and route suspicious inputs for human review rather than automated risk stratification.

Residual: 6.1 | Control: No Control Found

MEDIUM T-10

FHIR Resource Store

Attacker tampers with patient records

Implement write integrity controls on the FHIR Resource Store. All patient record write operations must be authorized via the RBAC policy engine and logged to the immutable clinical audit log. Add optimistic locking (ETag/version-based) on FHIR resources to detect concurrent modification attacks.

Residual: 6.1 | Control: No Control Found

MEDIUM T-11

Clinical Guideline RAG Corpus

Attacker poisons RAG corpus adversarially

Implement content integrity verification for the Clinical Guideline RAG Corpus. All documents added to the corpus must be cryptographically hashed on ingestion and periodically re-verified. Add provenance metadata tracking source, timestamp, and ingestion authority for each document chunk. Deploy anomaly detection on embedding distributions to detect injected adversarial content.

Residual: 5.5 | Control: No Control Found

MEDIUM LLM-5

Risk Stratification Model

Fine-tuning poisoning

|

Residual: 5.5 | Control: No Control Found

MEDIUM T-16

Outcomes Telemetry and Physician Override Audit Store

Attacker injects adversarial override signals

|

Residual: 5.5 | Control: No Control Found

MEDIUM T-17

HIPAA RBAC + Policy Engine

Attacker tampers with RBAC policy rules

Implement change control and integrity verification for RBAC policy rules. All policy changes must be authorized through a workflow requiring approval from an authorized administrator, logged to an immutable audit log, and cryptographically signed. Deploy policy version control with rollback capability.

Residual: 5.5 | Control: No Control Found

MEDIUM E-11

HIPAA RBAC + Policy Engine

Attacker exploits RBAC vulnerability to admin escalation

Harden the HIPAA RBAC Policy Engine against privilege escalation by implementing strict separation of duties: no single role should be able to both modify policies and hold admin-level permissions. Add immutable policy evaluation logging and enforce defense-in-depth with secondary authorization checks on sensitive operations.

Residual: 5.5 | Control: No Control Found

MEDIUM E-12

Consent and De-identification Guardrail

Attacker bypasses consent enforcement

Implement multi-layer consent enforcement with a defense-in-depth approach. The guardrail should not be a single bypass-able gate. Add secondary consent verification at the data layer and implement tamper-evident consent records that are cryptographically linked to the patient identity.

Residual: 5.5 | Control: No Control Found

MEDIUM T-2

Patient Summary Generator

Attacker tampers with patient-facing summaries

I

Residual: 5.5 | Control: No Control Found

MEDIUM T-13

Model Inference API Gateway

Attacker tampers with API Gateway configuration

I

Residual: 5.5 | Control: No Control Found

MEDIUM S-3

Physician Clinical Portal

Attacker spoofs portal to intercept clinical data

I

Residual: 5.6 | Control: No Control Found

MEDIUM T-5

Diagnostic Agent

Attacker tampers with Diagnostic Agent tool calls

I

Residual: 5.6 | Control: No Control Found

MEDIUM	T-6	Treatment Planner Agent
Attacker tampers with Treatment Planner Agent		
█		
Residual: 5.6 Control: No Control Found		
MEDIUM	AG-5	Treatment Planner Agent
Treatment Planner Agent incorporates adversarial context		
█		
Residual: 5.6 Control: No Control Found		
MEDIUM	E-10	Model Inference API Gateway
Compromised API Gateway escalates to access inference models		
█		
Residual: 5.6 Control: No Control Found		
MEDIUM	S-7	Diagnostic Agent
Attacker spoofs Diagnostic Agent to inject false findings		
█		
Residual: 5.9 Control: No Control Found		
MEDIUM	S-8	Treatment Planner Agent
Attacker spoofs Treatment Planner Agent responses		
█		
Residual: 5.9 Control: No Control Found		
MEDIUM	S-9	Clinical MCP Tool Server
Attacker spoofs MCP Tool Server to return malicious data		
█		
Residual: 5.9 Control: No Control Found		

MEDIUM E-5	Diagnostic Agent
Compromised Diagnostic Agent escalates to unauthorized operations	
Residual: 5.9 Control: No Control Found	
MEDIUM E-6	Treatment Planner Agent
Compromised Treatment Planner Agent escalates privileges	
Residual: 5.9 Control: No Control Found	
MEDIUM R-1	Physician
Physician denies issuing clinical query	
Implement immutable audit logging for all physician clinical queries. Each query must be logged with a cryptographically non-repudiable record including physician identity (authenticated session token hash), query parameters, timestamp, and response identifiers. Store audit logs in an append-only log store that cannot be modified by the physician or clinical portal application.	
Residual: 5.9 Control: No Control Found	
MEDIUM R-2	Patient
Patient denies submitting EHR update events	
Residual: 5.9 Control: No Control Found	
MEDIUM AG-3	Diagnostic Agent
Diagnostic Agent autonomously executes unauthorized actions	
Residual: 5.8 Control: No Control Found	
MEDIUM E-4	Supervisor Orchestrator
Compromised orchestrator escalates to bypass delegation	
Residual: 5.8 Control: No Control Found	

MEDIUM	E-9	Risk Stratification Model
Adversarially manipulated risk scores trigger unintended actions		
Residual: 5.8 Control: No Control Found		
MEDIUM	T-4	Supervisor Orchestrator
Compromised orchestrator tampers with delegation		
Residual: 5.8 Control: No Control Found		
MEDIUM	I-2	Patient Summary Generator
Patient summaries include unauthorized PHI		
Residual: 5.8 Control: No Control Found		
MEDIUM	AGP-03	Supervisor Orchestrator
Multi-agent cascading delegation exhibits emergent behavior		
Implement delegation depth limits and cycle detection on the Supervisor Orchestrator to prevent emergent cascading delegation behaviors. Set a maximum delegation depth (e.g., 3 hops) and enforce it at runtime. Add monitoring for unexpected delegation fan-out patterns that may indicate emergent coordination.		
Residual: 5.7 Control: No Control Found		
MEDIUM	AG-4	Diagnostic Agent
Compromised Diagnostic Agent abuses MCP Tool Server		
Residual: 5.7 Control: No Control Found		
MEDIUM	AG-6	Treatment Planner Agent
Compromised Treatment Planner Agent abuses MCP Tool Server		
Residual: 5.7 Control: No Control Found		

MEDIUM D-8

Clinical LLM

Large prompt floods exhaust Clinical LLM inference capacity

■

Residual: 5.7 | Control: No Control Found

MEDIUM R-5

Inter-Agent Communication Channel

Channel fails non-repudiable records of delegation

■

Implement non-repudiable message logging for all inter-agent delegation messages. Each delegation and response must be logged with the sending agent's cryptographic signature in an append-only audit log. The log must be independent of the agent bus so that a compromised channel cannot erase its own audit trail.

Residual: 5.7 | Control: No Control Found

MEDIUM AG-1

Supervisor Orchestrator

Autonomous delegation bypasses human oversight

■

Residual: 5.0 | Control: No Control Found

MEDIUM R-6

Supervisor Orchestrator

Orchestrator fails non-repudiable records of decisions

■

Residual: 5.0 | Control: No Control Found

MEDIUM I-10

FHIR Resource Store

Patient PHI disclosed via unauthorized FHIR query

■

Residual: 5.4 | Control: No Control Found

MEDIUM D-4

Supervisor Orchestrator

High-volume task result flood causes orchestrator failure

■

Residual: 5.4 | Control: No Control Found

MEDIUM	D-5	Diagnostic Agent
Tool call floods disrupt Diagnostic Agent		
■		
Residual: 5.4 Control: No Control Found		
MEDIUM	D-7	Clinical MCP Tool Server
Excessive JSON-RPC calls exhaust MCP server resources		
■		
Residual: 5.4 Control: No Control Found		
MEDIUM	D-10	FHIR Resource Store
FHIR query floods degrade patient record availability		
■		
Residual: 5.4 Control: No Control Found		
MEDIUM	S-4	Patient Summary Generator
Attacker spoofs Patient Summary Generator		
■		
Residual: 5.3 Control: No Control Found		
MEDIUM	AGP-02	Outcomes Telemetry and Physician Override Audit Store
Persistent-state learning loop enables temporal attack		
■ Implement temporal integrity controls on the learning loop feedback pathway. Validate that override signals in the telemetry store are consistent with contemporaneous clinical events (timestamp validation, signal provenance verification). Add rate limiting on override signal ingestion to prevent flooding the learning loop with adversarial signals.		
Residual: 5.3 Control: No Control Found		
MEDIUM	I-7	Clinical MCP Tool Server
PHI exposed to unauthorized agents via MCP		
■		
Residual: 5.3 Control: No Control Found		

MEDIUM	LLM-1	Clinical LLM
Clinical LLM PHI exposure		
Residual: 5.3 Control: No Control Found		
MEDIUM	T-12	Medical Literature Vector Index
Attacker injects malicious vector embeddings		
Residual: 5.3 Control: No Control Found		
MEDIUM	T-14	EHR Ingestion Queue
Attacker tampers with EHR events in ingestion queue		
Residual: 5.3 Control: No Control Found		
MEDIUM	T-1	Physician Clinical Portal
Attacker tampers with clinical recommendations		
Residual: 5.2 Control: No Control Found		
MEDIUM	D-15	Clinical Audit Log
Excessive log entries cause disk exhaustion		
Residual: 5.2 Control: No Control Found		
MEDIUM	D-18	Consent and De-identification Guardrail
PHI processing flood saturates de-id capacity		
Residual: 5.2 Control: No Control Found		

MEDIUM	I-8	Clinical LLM
Clinical LLM surfaces PHI from training data		
■		
Residual: 5.1 Control: No Control Found		
MEDIUM	I-9	Risk Stratification Model
Risk model leaks patient cohort data		
■		
Residual: 5.1 Control: No Control Found		
MEDIUM	LLM-6	Risk Stratification Model
Membership inference attack violates patient privacy		
■		
Residual: 5.1 Control: No Control Found		
MEDIUM	I-5	Diagnostic Agent
Diagnostic Agent exposes patient context		
■		
Residual: 4.9 Control: No Control Found		
MEDIUM	I-6	Treatment Planner Agent
Treatment Planner Agent discloses patient data		
■		
Residual: 4.9 Control: No Control Found		
MEDIUM	I-14	EHR Ingestion Queue
EHR update events in queue disclosed		
■		
Residual: 4.9 Control: No Control Found		

MEDIUM	I-15	Clinical Audit Log
Unauthorized audit log read discloses sensitive data		
■		
Residual: 4.9 Control: No Control Found		
MEDIUM	I-16	Outcomes Telemetry and Physician Override Audit Store
Telemetry access discloses clinical patterns		
■		
Residual: 4.9 Control: No Control Found		
MEDIUM	R-3	Physician Clinical Portal
Portal fails non-repudiable recommendation records		
■		
Residual: 4.8 Control: No Control Found		
MEDIUM	R-4	Patient Summary Generator
Summary Generator fails non-repudiable records		
■		
Residual: 4.8 Control: No Control Found		
MEDIUM	R-9	Clinical MCP Tool Server
MCP Tool Server fails non-repudiable FHIR records		
■		
Residual: 4.8 Control: No Control Found		
MEDIUM	T-15	Clinical Audit Log
Attacker tampers with audit log entries		
■		
Residual: 4.8 Control: No Control Found		

MEDIUM I-17

HIPAA RBAC + Policy Engine

RBAC engine leaks access control policies

I

Residual: 4.8 | Control: No Control Found

MEDIUM LLM-3

Clinical LLM

Adversary extracts Clinical LLM knowledge

I

Residual: 4.8 | Control: No Control Found

MEDIUM D-16

Outcomes Telemetry and Physician Override Audit Store

Spurious override signals degrade learning loop

I

Residual: 4.7 | Control: No Control Found

MEDIUM LLM-2

Clinical LLM

Adversary poisons training data via learning loop

I

Residual: 4.7 | Control: No Control Found

MEDIUM R-13

HIPAA RBAC + Policy Engine

RBAC engine fails non-repudiable access decisions

I

Residual: 4.7 | Control: No Control Found

MEDIUM D-9

Risk Stratification Model

High-volume risk inference requests saturate model

I

Residual: 4.6 | Control: No Control Found

MEDIUM	D-6	Treatment Planner Agent
Oversized retrieval queries exhaust Treatment Planner		
■		
Residual: 4.6 Control: No Control Found		
MEDIUM	D-11	Clinical Guideline RAG Corpus
Retrieval floods saturate RAG Corpus capacity		
■		
Residual: 4.6 Control: No Control Found		
MEDIUM	D-12	Medical Literature Vector Index
Excessive retrieval queries degrade Vector Index		
■		
Residual: 4.6 Control: No Control Found		
MEDIUM	D-14	EHR Ingestion Queue
Malformed EHR events cause queue saturation		
■		
Residual: 4.6 Control: No Control Found		
MEDIUM	I-4	Supervisor Orchestrator
Compromise exposes aggregated sensitive patient data		
■		
Residual: 4.3 Control: No Control Found		
MEDIUM	I-13	Model Inference API Gateway
API Gateway exposes inference request logs		
■		
Residual: 4.2 Control: No Control Found		

MEDIUM	S-14	Consent and De-identification Guardrail
Attacker spoofs guardrail returning raw PHI		
█		
Residual: 4.2 Control: No Control Found		
MEDIUM	T-9	Risk Stratification Model
Attacker tampers with fine-tuning data		
█		
Residual: 4.2 Control: No Control Found		
MEDIUM	I-18	Consent and De-identification Guardrail
Guardrail discloses raw PHI through de-identification failure		
█		
Residual: 4.5 Control: No Control Found		
MEDIUM	S-10	Clinical LLM
Attacker spoofs Clinical LLM completion responses		
█		
Residual: 4.5 Control: No Control Found		
MEDIUM	S-11	Risk Stratification Model
Attacker spoofs Risk Stratification Model output		
█		
Residual: 4.5 Control: No Control Found		
MEDIUM	S-12	Model Inference API Gateway
Attacker spoofs API Gateway to return fabricated responses		
█		
Residual: 4.5 Control: No Control Found		

MEDIUM	S-13	HIPAA RBAC + Policy Engine
Attacker spoofs RBAC engine to issue false authorization		
█		
Residual: 4.5 Control: No Control Found		
MEDIUM	T-18	Consent and De-identification Guardrail
Attacker tampers with de-identification configuration		
█		
Residual: 4.5 Control: No Control Found		
MEDIUM	R-7	Diagnostic Agent
Diagnostic Agent denies issuing tool calls		
█		
Residual: 4.1 Control: No Control Found		
MEDIUM	R-8	Treatment Planner Agent
Treatment Planner Agent denies tool calls		
█		
Residual: 4.1 Control: No Control Found		
MEDIUM	R-10	Clinical LLM
Clinical LLM fails non-repudiable prompt-completion records		
█		
Residual: 4.1 Control: No Control Found		
MEDIUM	R-11	Risk Stratification Model
Risk model fails non-repudiable inference records		
█		
Residual: 4.1 Control: No Control Found		

MEDIUM R-12

Model Inference API Gateway

API Gateway fails non-repudiable inference records

I

Residual: 4.1 | Control: No Control Found

LOW I-11

Clinical Guideline RAG Corpus

RAG Corpus inadvertently indexes patient data

I Implement PHI detection and prevention controls on the RAG corpus ingestion pipeline. Screen all documents before indexing to detect and redact any incidentally included patient data. Add an automated PHI scanner (NER-based) as a pre-ingestion gate.

Residual: 3.7 | Control: No Control Found

LOW I-12

Medical Literature Vector Index

Vector Index exposes research data

I Implement access controls and namespace isolation on the Medical Literature Vector Index. Research literature should be stored in a separate namespace from patient-adjacent data. Add read authorization checks on vector search queries to prevent cross-namespace data leakage.

Residual: 3.7 | Control: No Control Found

110 findings | Sorted by residual severity (critical first)

Coverage Attestation — OWASP LLM Top 10

Covered: 14 / 60 = 23.33% · **Partial:** 0 · **Gap:** 46

Covered (14)

✓ A01 ✓ A02 ✓ A03 ✓ A04 ✓ A07 ✓ A09 ✓ ASI01 ✓ ASI06 ✓ LLM01 ✓ LLM05 ✓ LLM06
✓ ML01 ✓ ML02 ✓ ML04

Partial (0)

No partial items on this framework.

Gap (46)

✗ A05 ✗ A06 ✗ A08 ✗ A10 ✗ API1 ✗ API10 ✗ API2 ✗ API3 ✗ API4 ✗ API5 ✗ API6 ✗ API7
✗ API8 ✗ API9 ✗ ASI02 ✗ ASI03 ✗ ASI04 ✗ ASI05 ✗ ASI07 ✗ ASI08 ✗ ASI09 ✗ ASI10 ✗ LLM02
✗ LLM03 ✗ LLM04 ✗ LLM07 ✗ LLM08 ✗ LLM09 ✗ LLM10 ✗ M1 ✗ M10 ✗ M2 ✗ M3 ✗ M4 ✗ M5
✗ M6 ✗ M7 ✗ M8 ✗ M9 ✗ ML03 ✗ ML05 ✗ ML06 ✗ ML07 ✗ ML08 ✗ ML09 ✗ ML10

Coverage Attestation — MITRE ATT&CK

Covered: 0 / 701 = 0.00% · **Partial:** 0 · **Gap:** 323

Covered (0)

No covered items on this framework.

Partial (0)

No partial items on this framework.

Gap (323)

X T1003 X T1003.001 X T1003.002 X T1003.003 X T1003.004 X T1003.005 X T1003.006 X T1003.007
 X T1003.008 X T1037 X T1037.001 X T1037.002 X T1037.003 X T1037.004 X T1037.005 X T1040 X T1047
 X T1053 X T1053.002 X T1053.003 X T1053.005 X T1053.006 X T1053.007 X T1055 X T1055.001
 X T1055.002 X T1055.003 X T1055.004 X T1055.005 X T1055.008 X T1055.009 X T1055.011 X T1055.012
 X T1055.013 X T1055.014 X T1055.015 X T1056 X T1056.001 X T1056.002 X T1056.003 X T1056.004
 X T1059 X T1059.001 X T1059.002 X T1059.003 X T1059.004 X T1059.005 X T1059.006 X T1059.007
 X T1059.008 X T1059.009 X T1059.010 X T1059.011 X T1059.012 X T1059.013 X T1068 X T1072 X T1078
 X T1078.001 X T1078.002 X T1078.003 X T1091 X T1098 X T1098.001 X T1098.002 X T1098.003
 X T1098.004 X T1098.005 X T1098.006 X T1098.007 X T1106 X T1110 X T1110.001 X T1110.002
 X T1110.003 X T1110.004 X T1111 X T1112 X T1127 X T1127.001 X T1127.002 X T1127.003 X T1129
 X T1133 X T1134 X T1134.001 X T1134.002 X T1134.003 X T1134.004 X T1134.005 X T1136 X T1136.001
 X T1136.002 X T1136.003 X T1137 X T1137.001 X T1137.002 X T1137.003 X T1137.004 X T1137.005
 X T1137.006 X T1176 X T1176.001 X T1176.002 X T1187 X T1189 X T1190 X T1195 X T1195.001
 X T1195.002 X T1195.003 X T1197 X T1199 X T1200 X T1203 X T1204 X T1204.001 X T1204.002
 X T1204.003 X T1204.004 X T1204.005 X T1205 X T1205.001 X T1205.002 X T1212 X T1484 X T1484.001
 X T1484.002 X T1505 X T1505.001 X T1505.002 X T1505.003 X T1505.004 X T1505.005 X T1505.006
 X T1525 X T1528 X T1539 X T1542 X T1542.001 X T1542.002 X T1542.003 X T1542.004 X T1542.005
 X T1543 X T1543.001 X T1543.002 X T1543.003 X T1543.004 X T1543.005 X T1546 X T1546.001
 X T1546.002 X T1546.003 X T1546.004 X T1546.005 X T1546.006 X T1546.007 X T1546.008 X T1546.009
 X T1546.010 X T1546.011 X T1546.012 X T1546.013 X T1546.014 X T1546.015 X T1546.016 X T1546.017
 X T1546.018 X T1547 X T1547.001 X T1547.002 X T1547.003 X T1547.004 X T1547.005 X T1547.006
 X T1547.007 X T1547.008 X T1547.009 X T1547.010 X T1547.012 X T1547.013 X T1547.014 X T1547.015
 X T1548 X T1548.001 X T1548.002 X T1548.003 X T1548.004 X T1548.005 X T1548.006 X T1552
 X T1552.001 X T1552.002 X T1552.003 X T1552.004 X T1552.005 X T1552.006 X T1552.007 X T1552.008
 X T1554 X T1555 X T1555.001 X T1555.002 X T1555.003 X T1555.004 X T1555.005 X T1555.006 X T1556
 X T1556.001 X T1556.002 X T1556.003 X T1556.004 X T1556.005 X T1556.006 X T1556.007 X T1556.008

X T1556.009 X T1557 X T1557.001 X T1557.002 X T1557.003 X T1557.004 X T1558 X T1558.001
X T1558.002 X T1558.003 X T1558.004 X T1558.005 X T1559 X T1559.001 X T1559.002 X T1559.003
X T1566 X T1566.001 X T1566.002 X T1566.003 X T1566.004 X T1569 X T1569.001 X T1569.002
X T1569.003 X T1574 X T1574.001 X T1574.004 X T1574.005 X T1574.006 X T1574.007 X T1574.008
X T1574.009 X T1574.010 X T1574.011 X T1574.012 X T1574.013 X T1574.014 X T1583 X T1583.001
X T1583.002 X T1583.003 X T1583.004 X T1583.005 X T1583.006 X T1583.007 X T1583.008 X T1584
X T1584.001 X T1584.002 X T1584.003 X T1584.004 X T1584.005 X T1584.006 X T1584.007 X T1584.008
X T1585 X T1585.001 X T1585.002 X T1585.003 X T1586 X T1586.001 X T1586.002 X T1586.003 X T1587
X T1587.001 X T1587.002 X T1587.003 X T1587.004 X T1588 X T1588.001 X T1588.002 X T1588.003
X T1588.004 X T1588.005 X T1588.006 X T1588.007 X T1606 X T1606.001 X T1606.002 X T1608
X T1608.001 X T1608.002 X T1608.003 X T1608.004 X T1608.005 X T1608.006 X T1609 X T1610 X T1611
X T1621 X T1648 X T1649 X T1650 X T1651 X T1653 X T1659 X T1668 X T1669 X T1671 X T1674
X T1675 X T1677 X T1683 X T1683.001 X T1683.002

Coverage Attestation — MITRE ATLAS

Covered: 0 / 36 = 0.00% · **Partial:** 0 · **Gap:** 36

Covered (0)

No covered items on this framework.

Partial (0)

No partial items on this framework.

Gap (36)

✗ AML.T0000 ✗ AML.T0001 ✗ AML.T0002 ✗ AML.T0003 ✗ AML.T0004 ✗ AML.T0005 ✗ AML.T0007
✗ AML.T0010 ✗ AML.T0011 ✗ AML.T0012 ✗ AML.T0013 ✗ AML.T0014 ✗ AML.T0015 ✗ AML.T0016
✗ AML.T0018 ✗ AML.T0019 ✗ AML.T0020 ✗ AML.T0024 ✗ AML.T0025 ✗ AML.T0029 ✗ AML.T0031
✗ AML.T0034 ✗ AML.T0035 ✗ AML.T0037 ✗ AML.T0040 ✗ AML.T0042 ✗ AML.T0043 ✗ AML.T0048
✗ AML.T0051 ✗ AML.T0054 ✗ AML.T0057 ✗ AML.T0058 ✗ AML.T0059 ✗ AML.T0060 ✗ AML.T0061
✗ AML.T0062

Coverage Attestation — NIST AI RMF

Covered: 0 / 72 = 0.00% · **Partial:** 0 · **Gap:** 72

Covered (0)

No covered items on this framework.

Partial (0)

No partial items on this framework.

Gap (72)

✗ GOVERN 1.1 ✗ GOVERN 1.2 ✗ GOVERN 1.3 ✗ GOVERN 1.4 ✗ GOVERN 1.5 ✗ GOVERN 1.6
 ✗ GOVERN 1.7 ✗ GOVERN 2.1 ✗ GOVERN 2.2 ✗ GOVERN 2.3 ✗ GOVERN 3.1 ✗ GOVERN 3.2
 ✗ GOVERN 4.1 ✗ GOVERN 4.2 ✗ GOVERN 4.3 ✗ GOVERN 5.1 ✗ GOVERN 5.2 ✗ GOVERN 6.1
 ✗ GOVERN 6.2 ✗ MANAGE 1.1 ✗ MANAGE 1.2 ✗ MANAGE 1.3 ✗ MANAGE 1.4 ✗ MANAGE 2.1
 ✗ MANAGE 2.2 ✗ MANAGE 2.3 ✗ MANAGE 2.4 ✗ MANAGE 3.1 ✗ MANAGE 3.2 ✗ MANAGE 4.1
 ✗ MANAGE 4.2 ✗ MANAGE 4.3 ✗ MAP 1.1 ✗ MAP 1.2 ✗ MAP 1.3 ✗ MAP 1.4 ✗ MAP 1.5 ✗ MAP 1.6
 ✗ MAP 2.1 ✗ MAP 2.2 ✗ MAP 2.3 ✗ MAP 3.1 ✗ MAP 3.2 ✗ MAP 3.3 ✗ MAP 3.4 ✗ MAP 3.5 ✗ MAP 4.1
 ✗ MAP 4.2 ✗ MAP 5.1 ✗ MAP 5.2 ✗ MEASURE 1.1 ✗ MEASURE 1.2 ✗ MEASURE 1.3 ✗ MEASURE 2.1
 ✗ MEASURE 2.2 ✗ MEASURE 2.3 ✗ MEASURE 2.4 ✗ MEASURE 2.5 ✗ MEASURE 2.6 ✗ MEASURE 2.7
 ✗ MEASURE 2.8 ✗ MEASURE 2.9 ✗ MEASURE 2.10 ✗ MEASURE 2.11 ✗ MEASURE 2.12 ✗ MEASURE 2.13
 ✗ MEASURE 3.1 ✗ MEASURE 3.2 ✗ MEASURE 3.3 ✗ MEASURE 4.1 ✗ MEASURE 4.2 ✗ MEASURE 4.3

Coverage Attestation — nist-ai-600-1

Covered: 0 / 12 = 0.00% · **Partial:** 0 · **Gap:** 12

Covered (0)

No covered items on this framework.

Partial (0)

No partial items on this framework.

Gap (12)

X 2.1 X 2.2 X 2.3 X 2.4 X 2.5 X 2.6 X 2.7 X 2.8 X 2.9 X 2.10 X 2.11 X 2.12

Coverage Attestation — CWE Top 25

Covered: 0 / 93 = 0.00% · **Partial:** 8 · **Gap:** 85

Covered (0)

No covered items on this framework.

Partial (8)

● CWE-20 ● CWE-200 ● CWE-285 ● CWE-287 ● CWE-345 ● CWE-770 ● CWE-778 ● CWE-94

Gap (85)

✗ CWE-1035 ✗ CWE-1039 ✗ CWE-1104 ✗ CWE-116 ✗ CWE-117 ✗ CWE-1174 ✗ CWE-120 ✗ CWE-121
 ✗ CWE-122 ✗ CWE-125 ✗ CWE-1269 ✗ CWE-1333 ✗ CWE-1357 ✗ CWE-1395 ✗ CWE-1426 ✗ CWE-1427
 ✗ CWE-16 ✗ CWE-201 ✗ CWE-209 ✗ CWE-213 ✗ CWE-215 ✗ CWE-22 ✗ CWE-223 ✗ CWE-250
 ✗ CWE-255 ✗ CWE-256 ✗ CWE-259 ✗ CWE-260 ✗ CWE-266 ✗ CWE-269 ✗ CWE-284 ✗ CWE-290
 ✗ CWE-295 ✗ CWE-306 ✗ CWE-307 ✗ CWE-311 ✗ CWE-312 ✗ CWE-319 ✗ CWE-326 ✗ CWE-327
 ✗ CWE-352 ✗ CWE-359 ✗ CWE-384 ✗ CWE-400 ✗ CWE-407 ✗ CWE-416 ✗ CWE-434 ✗ CWE-476
 ✗ CWE-489 ✗ CWE-494 ✗ CWE-502 ✗ CWE-520 ✗ CWE-521 ✗ CWE-522 ✗ CWE-532 ✗ CWE-538
 ✗ CWE-540 ✗ CWE-565 ✗ CWE-601 ✗ CWE-611 ✗ CWE-613 ✗ CWE-614 ✗ CWE-639 ✗ CWE-693
 ✗ CWE-73 ✗ CWE-732 ✗ CWE-77 ✗ CWE-776 ✗ CWE-779 ✗ CWE-78 ✗ CWE-787 ✗ CWE-79 ✗ CWE-798
 ✗ CWE-799 ✗ CWE-829 ✗ CWE-862 ✗ CWE-863 ✗ CWE-89 ✗ CWE-90 ✗ CWE-915 ✗ CWE-916
 ✗ CWE-917 ✗ CWE-918 ✗ CWE-937 ✗ CWE-943

Per-Finding Source Attribution

The following table lists every finding in input order alongside its cited framework references. Primary citations render in **bold**; related and derived citations render in plain weight. MITRE references are prefixed with ATT&CK: or ATLAS: to distinguish the originating taxonomy within the merged MITRE column. Empty cells indicate the finding carries no citations for that framework.

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
S-1	Attacker impersonates physician via credential replay	CRITICAL	A07	—	—	CWE-287
S-5	Attacker spoofs supervisor delegation messages on inter-agent bus	CRITICAL	A07	—	—	CWE-287
S-6	Attacker impersonates Supervisor Orchestrator to issue unauthorized delegation commands	CRITICAL	A07	—	—	CWE-287
T-3	Attacker tampers with delegation messages or specialist results in transit	CRITICAL	A03	—	—	CWE-345
T-7	Compromised MCP Tool Server tampers with FHIR read/write operations	CRITICAL	A03	—	—	CWE-345
T-10	Attacker tampers with patient records, corrupting all downstream clinical decisions	CRITICAL	A03	—	—	CWE-345
T-11	Attacker poisons RAG corpus with adversarial embeddings, causing malicious guidance retrieval	CRITICAL	A03	—	—	CWE-345
T-16	Attacker injects adversarial override signals corrupting learning loop re-training	CRITICAL	A03	—	—	CWE-345
I-3	PHI disclosed through unencrypted inter-agent messages	CRITICAL	A02	—	—	CWE-200
I-7	PHI exposed to unauthorized agents through insufficient MCP tool result access controls	CRITICAL	A02	—	—	CWE-200
I-10	Patient PHI disclosed through unauthorized FHIR reads or injection attacks	CRITICAL	A02	—	—	CWE-200

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
E-7	Compromised agent escalates to unauthorized FHIR operations via tool chaining	CRITICAL	A01	—	—	CWE-285
AG-1	Autonomous delegation bypasses human oversight and RBAC checks	CRITICAL	ASI01	—	—	CWE-94
AG-2	Compromised orchestrator abuses delegation authority to circumvent per-agent access controls	CRITICAL	ASI01	—	—	CWE-94
AG-7	Tool chaining achieves unauthorized FHIR outcomes via individually-permitted operation sequences	CRITICAL	ASI01	—	—	CWE-94
LLM-1	Prompt injection causes harmful clinical completions via API Gateway	CRITICAL	LLM01	—	—	CWE-20
AGP-01	Multi-agent coordination creates potential for coordinated malicious action across specialist agents	CRITICAL	ASI06	—	—	CWE-94
S-2	Attacker submits fraudulent EHR events by spoofing patient identity	HIGH	A07	—	—	CWE-287
S-3	Attacker spoofs portal to intercept clinical recommendation responses	HIGH	A07	—	—	CWE-287
S-7	Attacker spoofs Diagnostic Agent to inject fraudulent diagnostic results	HIGH	A07	—	—	CWE-287
S-8	Attacker spoofs Treatment Planner Agent to inject malicious treatment plans	HIGH	A07	—	—	CWE-287
S-9	Attacker spoofs MCP Tool Server to return malicious tool results	HIGH	A07	—	—	CWE-287
T-1	Attacker tampers with clinical recommendation responses in transit	HIGH	A03	—	—	CWE-345
T-2	Attacker tampers with patient-facing summaries, injecting dangerous clinical guidance	HIGH	A03	—	—	CWE-345
T-4	Compromised orchestrator tampers with delegation logic or aggregated outputs	HIGH	A03	—	—	CWE-345

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
T-5	Attacker tampers with Diagnostic Agent tool call requests to inject malicious FHIR operations	HIGH	A03	—	—	CWE-345
T-6	Attacker tampers with Treatment Planner Agent inputs corrupting treatment plan generation	HIGH	A03	—	—	CWE-345
T-8	Attacker tampers with prompt inputs to inject adversarial tokens	HIGH	A03	—	—	CWE-345
T-9	Attacker tampers with fine-tuning data causing biased risk scores	HIGH	A03	—	—	CWE-345
T-12	Attacker injects malicious vector embeddings corrupting literature retrieval	HIGH	A03	—	—	CWE-345
T-14	Attacker tampers with EHR events in ingestion queue before normalization	HIGH	A03	—	—	CWE-345
T-15	Attacker tampers with audit log entries, covering tracks for unauthorized actions	HIGH	A03	—	—	CWE-345
R-5	Channel fails to provide non-repudiable records of delegation messages	HIGH	A09	—	—	CWE-778
R-6	Orchestrator fails non-repudiable records of delegation commands and aggregated results	HIGH	A09	—	—	CWE-778
R-9	MCP Tool Server fails non-repudiable records of FHIR operations	HIGH	A09	—	—	CWE-778
I-1	PHI disclosed through insecure HTTPS configuration or excessive error messages	HIGH	A02	—	—	CWE-200
I-2	Patient summaries include unauthorized PHI or delivered to wrong patients	HIGH	A02	—	—	CWE-200
I-4	Compromise exposes aggregated sensitive patient context across specialists	HIGH	A02	—	—	CWE-200
I-5	Diagnostic Agent exposes patient context through	HIGH	A02	—	—	CWE-200

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
	tool call parameters or error responses					
I-6	Treatment Planner Agent discloses patient data through insufficient session isolation	HIGH	A02	—	—	CWE-200
I-8	Clinical LLM surfaces PHI from training data in completions	HIGH	A02	—	—	CWE-200
I-9	Risk Stratification Model leaks patient cohort data through membership inference	HIGH	A02	—	—	CWE-200
I-13	API Gateway exposes inference request logs containing patient PHI	MEDIUM	A02	—	—	CWE-200
I-14	EHR update events in queue disclosed through insufficient access controls	HIGH	A02	—	—	CWE-200
I-15	Unauthorized audit log read access discloses sensitive clinical decision trails	HIGH	A02	—	—	CWE-200
I-16	Telemetry access discloses clinical patterns or enables re-identification	HIGH	A02	—	—	CWE-200
D-1	Clinical query request flood degrades availability for legitimate physicians	HIGH	A04	—	—	CWE-770
D-3	Delegation message flood starves specialist agent processing	HIGH	A04	—	—	CWE-770
D-4	High-volume task result flood causes orchestrator resource exhaustion	HIGH	A04	—	—	CWE-770
D-5	Tool call floods or retrieval storms disrupt Diagnostic Agent availability	HIGH	A04	—	—	CWE-770
D-7	Excessive JSON-RPC tool calls exhaust MCP Tool Server resources	HIGH	A04	—	—	CWE-770
D-8	Large prompt floods exhaust Clinical LLM inference capacity	HIGH	A04	—	—	CWE-770
D-10	FHIR query or write floods degrade patient record availability	HIGH	A04	—	—	CWE-770
D-13	Request floods saturate inference gateway, denying	HIGH	A04	—	—	CWE-770

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
	all agents foundation model access					
E-1	Attacker escalates from low-privilege session to access other physicians' data	HIGH	A01	—	—	CWE-285
E-2	Attacker exploits summary generator to access unauthorized patient records	HIGH	A01	—	—	CWE-285
E-3	Compromised channel allows escalation to supervisor-level delegation authority	HIGH	A01	—	—	CWE-285
E-4	Compromised orchestrator escalates to bypass RBAC or grant unauthorized permissions	HIGH	A01	—	—	CWE-285
E-5	Compromised Diagnostic Agent escalates to unauthorized FHIR operations	HIGH	A01	—	—	CWE-285
E-6	Compromised Treatment Planner Agent escalates to unauthorized FHIR resources	HIGH	A01	—	—	CWE-285
E-8	Prompt injection causes elevated reasoning authority in Clinical LLM output	HIGH	A01	—	—	CWE-285
AG-3	Diagnostic Agent autonomously executes unauthorized FHIR write operations	HIGH	ASI01	—	—	CWE-94
AG-4	Compromised Diagnostic Agent abuses MCP Tool Server for malicious FHIR operations	HIGH	ASI01	—	—	CWE-94
AG-5	Treatment Planner Agent autonomously incorporates adversarial literature without validation	HIGH	ASI01	—	—	CWE-94
AG-6	Compromised Treatment Planner Agent abuses MCP Tool Server for unauthorized FHIR operations	HIGH	ASI01	—	—	CWE-94
AG-8	Compromised agent abuses inter-agent channel for resource exhaustion attack	HIGH	ASI01	—	—	CWE-94

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
LLM-2	Adversary poisons training data via learning loop causing systematic bias	HIGH	LLM05	—	—	CWE-20
LLM-4	Adversarial patient records manipulate risk scores causing incorrect triage	HIGH	ML01	—	—	CWE-20
LLM-5	Poisoned fine-tuning dataset causes systematic high-risk patient misclassification	HIGH	ML02	—	—	CWE-20
LLM-6	Membership inference attack violates patient privacy for fine-tuning participants	HIGH	ML04	—	—	CWE-20
AGP-02	Architecture's persistent-state learning loop enables temporal attacks via gradual corruption	HIGH	ASI06	—	—	CWE-94
AGP-03	Multi-agent cascading delegation exhibits potential for emergent behavior	HIGH	ASI06	—	—	CWE-94
S-4	Attacker spoofs Patient Summary Generator to intercept patient summaries	MEDIUM	A07	—	—	CWE-287
S-10	Attacker spoofs Clinical LLM completion responses via API Gateway interception	MEDIUM	A07	—	—	CWE-287
S-11	Attacker spoofs risk stratification outputs with falsified results	MEDIUM	A07	—	—	CWE-287
S-12	Attacker spoofs API Gateway to intercept and fabricate model completions	MEDIUM	A07	—	—	CWE-287
S-13	Attacker spoofs RBAC engine to issue false access-grant decisions	MEDIUM	A07	—	—	CWE-287
S-14	Attacker spoofs guardrail response returning raw PHI to expecting de-identified data	MEDIUM	A07	—	—	CWE-287
T-13	Attacker tampers with API Gateway configuration to reroute inference requests	MEDIUM	A03	—	—	CWE-345
T-17	Attacker tampers with RBAC policy rules	MEDIUM	A03	—	—	CWE-345

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
	granting unauthorized access					
T-18	Attacker tampers with de-identification configuration exposing raw PHI	MEDIUM	A03	—	—	CWE-345
R-1	Physician denies issuing clinical query or claims different recommendation was shown	MEDIUM	A09	—	—	CWE-778
R-3	Portal fails to provide non-repudiable records of displayed recommendations	MEDIUM	A09	—	—	CWE-778
R-7	Diagnostic Agent denies issuing specific tool calls or retrieval queries	MEDIUM	A09	—	—	CWE-778
R-8	Treatment Planner Agent denies issuing retrieval queries or tool calls	MEDIUM	A09	—	—	CWE-778
R-10	Clinical LLM fails to maintain non-repudiable prompt-completion logs	MEDIUM	A09	—	—	CWE-778
R-11	Risk Stratification Model fails non-repudiable records of which patient inputs produced risk scores	MEDIUM	A09	—	—	CWE-778
R-12	API Gateway fails non-repudiable records of inference requests forwarded to foundation models	MEDIUM	A09	—	—	CWE-778
R-13	RBAC engine fails non-repudiable records of all access decisions	MEDIUM	A09	—	—	CWE-778
I-17	RBAC engine leaks access control policies through detailed error messages	LOW	A02	—	—	CWE-200
I-18	Guardrail discloses raw PHI through de-identification implementation flaws	MEDIUM	A02	—	—	CWE-200
D-2	Spurious summary requests flood Patient Summary Generator	MEDIUM	A04	—	—	CWE-770
D-6	Oversized retrieval queries or excessive tool calls exhaust Treatment Planner Agent resources	MEDIUM	A04	—	—	CWE-770
D-9	High-volume risk inference requests saturate Risk	MEDIUM	A04	—	—	CWE-770

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
	Stratification Model capacity					
D-14	Malformed EHR events cause queue saturation blocking legitimate patient record ingestion	MEDIUM	A04	—	—	CWE-770
D-15	Excessive log entries cause disk exhaustion preventing legitimate audit log writes	MEDIUM	A04	—	—	CWE-770
D-16	Spurious override signals degrade learning loop's ability to incorporate legitimate feedback	MEDIUM	A04	—	—	CWE-770
D-17	RBAC request flood causes policy engine unavailability blocking clinical data access	MEDIUM	A04	—	—	CWE-770
D-18	PHI processing request flood saturates de-identification capacity	MEDIUM	A04	—	—	CWE-770
E-9	Adversarially manipulated risk scores trigger automated escalation to high-privilege interventions	MEDIUM	A01	—	—	CWE-285
E-10	Compromised API Gateway escalates to access unauthorized model endpoints	MEDIUM	A01	—	—	CWE-285
E-11	Attacker exploits RBAC engine vulnerability to escalate to administrative access	MEDIUM	A01	—	—	CWE-285
E-12	Attacker compromises guardrail to bypass consent enforcement accessing raw PHI	MEDIUM	A01	—	—	CWE-285
R-2	Patient denies submitting EHR update events used as clinical decision basis	LOW	A09	—	—	CWE-778
R-4	Summary Generator fails non-repudiable records of summaries delivered to patients	LOW	A09	—	—	CWE-778
I-11	RAG Corpus inadvertently indexes patient data from clinical guidelines	LOW	A02	—	—	CWE-200
I-12	Vector Index exposes research data or cross-contaminates retrieval results	LOW	A02	—	—	CWE-200

Finding ID	Title	Severity	OWASP	MITRE	NIST	CWE
D-11	Retrieval floods saturate Clinical Guideline RAG Corpus capacity	LOW	A04	—	—	CWE-770
D-12	Excessive retrieval queries degrade Medical Literature Vector Index availability	LOW	A04	—	—	CWE-770
I-17	RBAC engine leaks access control policies through error messages	LOW	A02	—	—	CWE-200
LLM-3	Adversary extracts Clinical LLM clinical knowledge through targeted query patterns	LOW	LLM06	—	—	CWE-20

111 findings | Input order preserved

Control Coverage

Control Status by STRIDE Category

STRIDE Category	Found	Partial	Missing	Total
Spoofing	0	0	14	14
Tampering	0	0	18	18
Repudiation	0	0	13	13
Information Disclosure	0	0	18	18
Denial of Service	0	0	18	18
Elevation of Privilege	0	0	12	12
Agentic Threats	0	0	8	8
LLM Threats	0	0	6	6
Other	0	0	3	3

Coverage Summary

Control Status	Count	Percentage
Control Found	0	0%
Partial Control	0	0%
No Control Found	110	100%
Total	110	100%

Remediation Roadmap

■ Critical: 0 ■ High: 6 ■ Medium: 102 ■ Low: 2

110 total actions

Priority	Finding	Recommendation	SLA	Status
HIGH				
6 actions				
S-1	Attacker replays or forges clinical query credentials	Implement multi-factor authentication (MFA) and credential replay protection for the physician authentication endpoint. Deploy a short-lived JWT or OAuth 2.0 token scheme with cryptographic binding to session context. Add token replay detection using a nonce or jti claim validated against a server-side token store.	14d	No Control Found
S-2	Attacker submits fraudulent EHR update events	Implement patient identity verification with signed event envelopes on the EHR ingestion endpoint. Each incoming EHR update event should carry a verifiable patient identity token (e.g., SMART on FHIR patient context) and a message authentication code preventing tampering. Deploy input schema validation to reject malformed or unexpected event structures.	14d	No Control Found
D-1	Attacker floods portal with clinical query requests	Implement request rate limiting on the physician clinical portal API endpoints. Configure a per-IP and per-session rate limiter with thresholds calibrated to expected clinical usage patterns. Add a circuit breaker wrapping the downstream CDSS orchestration layer to prevent cascade failures under load.	14d	No Control Found
E-1	Attacker escalates from low-privilege session	Implement role-based access control (RBAC) enforcing per-physician data scope on all portal data retrieval endpoints. Add resource ownership validation that prevents horizontal privilege escalation to other physicians' or patients' data. Every data fetch endpoint must assert that the requesting session's physician ID matches the requested resource scope.	14d	No Control Found
S-5	Attacker spoofs supervisor delegation messages	Implement message authentication on the inter-agent communication channel. Each delegation message must carry a cryptographic signature from the originating supervisor agent, verified by the receiving specialist agent before execution. Use a shared asymmetric key infrastructure where the supervisor holds the private signing key	14d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		and specialist agents hold the corresponding verification key.		
T-3	Attacker tampers with delegation messages in transit	Implement message integrity protection on all inter-agent delegation messages and specialist results. Encrypt the message bus channel using TLS with mutual authentication, and add per-message HMAC integrity tokens that detect tampering in transit. Log all message integrity failures to the clinical audit log.	14d	No Control Found
MEDIUM				
102 actions				
AG-8	Compromised agent abuses inter-agent channel	Implement per-agent message quotas and channel-level rate limiting to prevent resource exhaustion by a compromised agent. Each agent instance should have a configurable message-per-second budget on the inter-agent bus. Deploy a circuit breaker that isolates an agent flooding the channel, preventing cascade to downstream specialist agents.	30d	No Control Found
D-3	Delegation message flood starves specialist agents	Implement channel-level message rate limiting and backpressure on the inter-agent delegation bus. Set maximum delegation message ingestion rates and queue depth limits. Add message priority queuing so clinical-critical delegation messages are processed ahead of non-urgent agent coordination traffic.	30d	No Control Found
E-2	Attacker exploits summary generator for unauthorized patients	Implement patient-scope authorization on the Patient Summary Generator. All summary requests must be validated against the requesting session's authorized patient list. Add an ABAC policy check verifying that the requestor has an active care relationship with the requested patient before generating the summary.	30d	No Control Found
AGP-01	Multi-agent coordination creates potential for coordinated action	Implement behavioral monitoring for coordinated agent activity patterns. Deploy a cross-agent telemetry aggregator that detects statistical anomalies in multi-agent coordination (synchronized message timing, unusual delegation fan-out, correlated output deviations across specialist agents). Trigger human-in-the-loop review when collusion indicators are detected.	30d	No Control Found
E-8	Prompt injection causes elevated reasoning authority	Implement prompt input validation and output sanitization for the Clinical LLM inference endpoint. Add a prompt injection detection layer that scans input for known injection patterns before forwarding to the model. Enforce strict output schema	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		validation to detect anomalous reasoning responses that deviate from expected clinical recommendation formats.		
E-3	Compromised channel escalates to supervisor-level authority	Implement least-privilege access controls on the inter-agent communication channel. Each agent should only be able to send message types appropriate to its role (specialist agents cannot send delegation messages; only the supervisor can initiate delegation). Enforce role-based message type restrictions at the bus level.	30d	No Control Found
T-8	Attacker tampers with prompt inputs forwarded by API Gateway	Implement request signing and integrity verification on prompts forwarded by the Model Inference API Gateway to the Clinical LLM. The gateway must attest that the prompt content has not been modified in transit from the originating agent. Add an HMAC on each prompt payload that the LLM endpoint verifies before processing.	30d	No Control Found
I-3	PHI disclosed through unencrypted inter-agent channel	Implement end-to-end encryption on the inter-agent communication channel for all messages containing PHI. Enforce TLS 1.3 on the transport layer and add application-layer field-level encryption for patient identifiers and clinical data payloads within delegation messages.	30d	No Control Found
E-7	Compromised agent escalates to unauthorized FHIR operations	Implement tool-call authorization on the Clinical MCP Tool Server. All FHIR tool operations must be authorized against the requesting agent's permitted tool scope. Add a policy engine that validates tool call intent (operation type, resource type, patient scope) against the agent's declared role before executing.	30d	No Control Found
S-6	Attacker impersonates Supervisor Orchestrator	Implement cryptographic identity verification for the Supervisor Orchestrator. The orchestrator must present a verifiable identity credential (signed JWT or mutual TLS certificate) when establishing connections with specialist agents and when receiving connections from external components. Specialist agents must verify orchestrator identity before accepting delegation messages.	30d	No Control Found
D-13	Request floods saturate inference gateway	Implement request rate limiting and adaptive throttling on the Model Inference API Gateway. Configure per-caller rate limits, total inference concurrency caps, and request queue depth limits. Add a circuit breaker that drops non-urgent inference requests when the gateway approaches capacity saturation.	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
AG-7	Tool chaining achieves unauthorized FHIR output		30d	No Control Found
T-7	Compromised MCP Tool Server tampers with FHIR operations		30d	No Control Found
D-2	Spurious summary requests flood Patient Summary Generator		30d	No Control Found
AG-2	Compromised orchestrator abuses delegation authority	Implement delegation authority limits on the Supervisor Orchestrator. The orchestrator's delegation permissions should be defined at deployment time and enforced at runtime — the orchestrator cannot grant capabilities it does not possess. Add a human-in-the-loop checkpoint for high-impact clinical delegations (e.g., treatment recommendations above a risk threshold).	30d	No Control Found
D-17	RBAC request flood causes policy engine unavailability		30d	No Control Found
I-1	PHI disclosed via insecure HTTPS config or error messages	Enforce HTTPS with HSTS on the Physician Clinical Portal and configure Content Security Policy to prevent information leakage through error responses. Implement generic error handling that does not expose PHI or stack traces. Add X-Content-Type-Options, X-Frame-Options, and Referrer-Policy headers.	30d	No Control Found
LLM-4	Adversarial patient records manipulate risk scores	Implement adversarial input detection for the Risk Stratification Model. Add a pre-inference validation layer that checks incoming patient record feature vectors for statistical anomalies indicative of adversarial perturbation. Log detected anomalies and route suspicious inputs for human review rather than automated risk stratification.	30d	No Control Found
T-10	Attacker tampers with patient records	Implement write integrity controls on the FHIR Resource Store. All patient record write operations must be authorized via the RBAC policy engine and logged to the immutable clinical audit log. Add optimistic locking (ETag/version-based) on FHIR resources to detect concurrent modification attacks.	30d	No Control Found
T-11	Attacker poisons RAG corpus adversarially	Implement content integrity verification for the Clinical Guideline RAG Corpus. All documents added to the corpus must be cryptographically hashed on ingestion and periodically re-verified. Add provenance metadata tracking source, timestamp, and ingestion authority for each document chunk. Deploy anomaly detection on	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		embedding distributions to detect injected adversarial content.		
LLM-5	Fine-tuning poisoning		30d	No Control Found
T-16	Attacker injects adversarial override signals		30d	No Control Found
T-17	Attacker tampers with RBAC policy rules	Implement change control and integrity verification for RBAC policy rules. All policy changes must be authorized through a workflow requiring approval from an authorized administrator, logged to an immutable audit log, and cryptographically signed. Deploy policy version control with rollback capability.	30d	No Control Found
E-11	Attacker exploits RBAC vulnerability to admin escalation	Harden the HIPAA RBAC Policy Engine against privilege escalation by implementing strict separation of duties: no single role should be able to both modify policies and hold admin-level permissions. Add immutable policy evaluation logging and enforce defense-in-depth with secondary authorization checks on sensitive operations.	30d	No Control Found
E-12	Attacker bypasses consent enforcement	Implement multi-layer consent enforcement with a defense-in-depth approach. The guardrail should not be a single bypass-able gate. Add secondary consent verification at the data layer and implement tamper-evident consent records that are cryptographically linked to the patient identity.	30d	No Control Found
T-2	Attacker tampers with patient-facing summaries		30d	No Control Found
T-13	Attacker tampers with API Gateway configuration		30d	No Control Found
S-3	Attacker spoofs portal to intercept clinical data		30d	No Control Found
T-5	Attacker tampers with Diagnostic Agent tool calls		30d	No Control Found
T-6	Attacker tampers with Treatment Planner Agent		30d	No Control Found
AG-5	Treatment Planner Agent incorporates adversarial context		30d	No Control Found
E-10	Compromised API Gateway escalates to access inference models		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
S-7	Attacker spoofs Diagnostic Agent to inject false findings		30d	No Control Found
S-8	Attacker spoofs Treatment Planner Agent responses		30d	No Control Found
S-9	Attacker spoofs MCP Tool Server to return malicious data		30d	No Control Found
E-5	Compromised Diagnostic Agent escalates to unauthorized operations		30d	No Control Found
E-6	Compromised Treatment Planner Agent escalates privileges		30d	No Control Found
R-1	Physician denies issuing clinical query	Implement immutable audit logging for all physician clinical queries. Each query must be logged with a cryptographically non-repudiable record including physician identity (authenticated session token hash), query parameters, timestamp, and response identifiers. Store audit logs in an append-only log store that cannot be modified by the physician or clinical portal application.	30d	No Control Found
R-2	Patient denies submitting EHR update events		30d	No Control Found
AG-3	Diagnostic Agent autonomously executes unauthorized actions		30d	No Control Found
E-4	Compromised orchestrator escalates to bypass delegation		30d	No Control Found
E-9	Adversarially manipulated risk scores trigger unintended actions		30d	No Control Found
T-4	Compromised orchestrator tampers with delegation		30d	No Control Found
I-2	Patient summaries include unauthorized PHI		30d	No Control Found
AGP-03	Multi-agent cascading delegation exhibits emergent behavior	Implement delegation depth limits and cycle detection on the Supervisor Orchestrator to prevent emergent cascading delegation behaviors. Set a maximum delegation depth (e.g., 3 hops) and enforce it at runtime. Add monitoring for unexpected delegation fan-	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		out patterns that may indicate emergent coordination.		
AG-4	Compromised Diagnostic Agent abuses MCP Tool Server		30d	No Control Found
AG-6	Compromised Treatment Planner Agent abuses MCP Tool Server		30d	No Control Found
D-8	Large prompt floods exhaust Clinical LLM inference capacity		30d	No Control Found
R-5	Channel fails non-repudiable records of delegation	Implement non-repudiable message logging for all inter-agent delegation messages. Each delegation and response must be logged with the sending agent's cryptographic signature in an append-only audit log. The log must be independent of the agent bus so that a compromised channel cannot erase its own audit trail.	30d	No Control Found
AG-1	Autonomous delegation bypasses human oversight		30d	No Control Found
R-6	Orchestrator fails non-repudiable records of decisions		30d	No Control Found
I-10	Patient PHI disclosed via unauthorized FHIR query		30d	No Control Found
D-4	High-volume task result flood causes orchestrator failure		30d	No Control Found
D-5	Tool call floods disrupt Diagnostic Agent		30d	No Control Found
D-7	Excessive JSON-RPC calls exhaust MCP server resources		30d	No Control Found
D-10	FHIR query floods degrade patient record availability		30d	No Control Found
S-4	Attacker spoofs Patient Summary Generator		30d	No Control Found
AGP-02	Persistent-state learning loop enables temporal attack	Implement temporal integrity controls on the learning loop feedback pathway. Validate that override signals in the telemetry store are consistent with contemporaneous clinical events (timestamp validation, signal provenance verification). Add rate limiting on override signal ingestion to prevent	30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
		flooding the learning loop with adversarial signals.		
I-7	PHI exposed to unauthorized agents via MCP		30d	No Control Found
LLM-1	Clinical LLM PHI exposure		30d	No Control Found
T-12	Attacker injects malicious vector embeddings		30d	No Control Found
T-14	Attacker tampers with EHR events in ingestion queue		30d	No Control Found
T-1	Attacker tampers with clinical recommendations		30d	No Control Found
D-15	Excessive log entries cause disk exhaustion		30d	No Control Found
D-18	PHI processing flood saturates de-id capacity		30d	No Control Found
I-8	Clinical LLM surfaces PHI from training data		30d	No Control Found
I-9	Risk model leaks patient cohort data		30d	No Control Found
LLM-6	Membership inference attack violates patient privacy		30d	No Control Found
I-5	Diagnostic Agent exposes patient context		30d	No Control Found
I-6	Treatment Planner Agent discloses patient data		30d	No Control Found
I-14	EHR update events in queue disclosed		30d	No Control Found
I-15	Unauthorized audit log read discloses sensitive data		30d	No Control Found
I-16	Telemetry access discloses clinical patterns		30d	No Control Found
R-3	Portal fails non-repudiable recommendation records		30d	No Control Found
R-4	Summary Generator fails non-repudiable records		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
R-9	MCP Tool Server fails non-repudiable FHIR records		30d	No Control Found
T-15	Attacker tampers with audit log entries		30d	No Control Found
I-17	RBAC engine leaks access control policies		30d	No Control Found
LLM-3	Adversary extracts Clinical LLM knowledge		30d	No Control Found
D-16	Spurious override signals degrade learning loop		30d	No Control Found
LLM-2	Adversary poisons training data via learning loop		30d	No Control Found
R-13	RBAC engine fails non-repudiable access decisions		30d	No Control Found
D-9	High-volume risk inference requests saturate model		30d	No Control Found
D-6	Oversized retrieval queries exhaust Treatment Planner		30d	No Control Found
D-11	Retrieval floods saturate RAG Corpus capacity		30d	No Control Found
D-12	Excessive retrieval queries degrade Vector Index		30d	No Control Found
D-14	Malformed EHR events cause queue saturation		30d	No Control Found
I-4	Compromise exposes aggregated sensitive patient data		30d	No Control Found
I-13	API Gateway exposes inference request logs		30d	No Control Found
S-14	Attacker spoofs guardrail returning raw PHI		30d	No Control Found
T-9	Attacker tampers with fine-tuning data		30d	No Control Found
I-18	Guardrail discloses raw PHI through de-identification failure		30d	No Control Found
S-10	Attacker spoofs Clinical LLM completion responses		30d	No Control Found

Priority	Finding	Recommendation	SLA	Status
S-11	Attacker spoofs Risk Stratification Model output		30d	No Control Found
S-12	Attacker spoofs API Gateway to return fabricated responses		30d	No Control Found
S-13	Attacker spoofs RBAC engine to issue false authorization		30d	No Control Found
T-18	Attacker tampers with de-identification configuration		30d	No Control Found
R-7	Diagnostic Agent denies issuing tool calls		30d	No Control Found
R-8	Treatment Planner Agent denies tool calls		30d	No Control Found
R-10	Clinical LLM fails non-repudiable prompt-completion records		30d	No Control Found
R-11	Risk model fails non-repudiable inference records		30d	No Control Found
R-12	API Gateway fails non-repudiable inference records		30d	No Control Found
LOW 2 actions				
I-11	RAG Corpus inadvertently indexes patient data	Implement PHI detection and prevention controls on the RAG corpus ingestion pipeline. Screen all documents before indexing to detect and redact any incidentally included patient data. Add an automated PHI scanner (NER-based) as a pre-ingestion gate.	90d	No Control Found
I-12	Vector Index exposes research data	Implement access controls and namespace isolation on the Medical Literature Vector Index. Research literature should be stored in a separate namespace from patient-adjacent data. Add read authorization checks on vector search queries to prevent cross-namespace data leakage.	90d	No Control Found